

QUANTUM SECURITY

Practical Implementation
with Q-SLICE and QUANTA



JEREMY GREEN

© Digital Dreams Publishing 2025

The right of Jeremy Green and Slice Point Security to be identified as author of this work has been asserted by them in accordance with sections 77 and 78 of the Copyright, Designs and Patents Act 1988.

All rights reserved. Apart from any fair dealing for the purposes of research or private study, or criticism or review, as permitted by the Copyright Designs and Patents Act 1988, no part of this publication may be reproduced, stored or transmitted in any form or by any means, except with the prior permission in writing of the publisher, or in the case of reprographic reproduction, in accordance with the terms of the licences issued by the Copyright Licensing Agency. Enquiries for permission to reproduce material outside those terms should be directed to the publisher. The research in this book has been undertaken as part of my PhD in Computer Science with the University of Staffordshire. With the main research sources referenced at the back of the book to support validation and accuracy.



CONTENTS

CONTENTS	3
AUTHOR	12
FOREWORD	13
PREFACE	17
INTRODUCTION	19
Quantum Computing and Cryptographic Risk	19
Post-Quantum Security Frameworks	20
Business and Regulatory Impact	21
The End-to-End Q-SLICE and QUANTA Process	21
QUANTUM SECURITY	23
Beyond HNDL: The Four Quantum-Era Temporal Threat Models	25
Uncertainty	30
Managing Uncertainty in Risk Assessment	30
Post-Quantum Cryptography	33
FIPS	38
QUANTUM MITIGATION	40
CRQC	42
Why 1.0 Corresponds to RSA-2048 Breakability	42
Vendor Trajectories (Modelled, Not Claimed)	43

Scope and Limitations	44
Scope and Limitations of CRQC Readiness Scores	53
Empirical Validation of Accelerated Timelines: The 10,000-Qubit Blueprint	54
Key Findings and Their Implications for CRQC Readiness	55
Global Preparations for Q-Day	56
Post-Quantum Cryptography Extensions in TLS 1.3	57
Hybrid Key Exchange Approaches	57
Fully Post-Quantum Key Exchange (Experimental)	59
Implementations and Industry Testing	60
LMS and XMSS Hash-Based Signature Standards	62
Defence-in-Depth Security Measures	63
Quantum Risk Mitigation Scenario	66
Q-SLICE	69
Purpose and Scope	69
Why Classical Threat Models Are Insufficient	70
Quantum Exploitation	73
Subversion of Trust	75
Legacy Exploitation	77
Integrity Disruption	80
Coherence Attacks	82
Ecosystem Abuse	84
How to Use Q-SLICE	88
Basic Example	88
Q – Quantum Exploitation	89
S – Subversion of Trust	89

L - Legacy Exploitation	90
I - Integrity Disruption	90
C - Coherence Attacks	90
E - Ecosystem Abuse	91
SATCOM Quantum Risk Mitigation Scenario	92
Q-SLICE Testing	95
Q-SLICE Threat Harness Python Code	98
Mathematical Foundation of Q-SLICE Tests	101
Q-SLICE Threat Harness Results and Interpretation	107
Q-Slice Threat Harness v2	111
Simplified Explanations of Q-SLICE Test Elements	115
Test Summary and Findings	124
Q-SLICE Simulator vs Hardware	127
QUANTA Framework	134
Condition-Based Security, Fragility and Possibility	140
Governance, Risk and Compliance	146
Identity, Access and Authentication	147
Cryptography and Data Protection	147
Network Security	148
Security Operations and Incident Response	148
Endpoint and Application Security	149
Business Continuity and Disaster Recovery	149
Physical and Environmental Security	149
Awareness and Training	150
Third-Party and Cloud Security	150

Security Architecture and Design	150
Emerging Technologies and Innovation	150
Monitoring, Metrics and Continuous Improvement	151
QUANTA Use Cases	151
QUANTA Framework Quantum-Resilient Controls: Cross-Reference Mapping	152
Controls Grouped by QUANTA Domain	153
QUANTA IMPLEMENTATION	158
Governance, Risk and Compliance	160
Identity, Access and Authentication	163
Cryptography and Data Protection	166
Network Security	169
Security Operations and Incident Response	172
Endpoint and Application Security	176
Business Continuity and Disaster Recovery	179
Awareness and Training	182
Third-Party and Cloud Security	183
Security Architecture and Design	185
Emerging Technologies and Innovation	188
Monitoring, Metrics and Continuous Improvement	190
PQC Network Scanner	193
IMPLEMENTATION SUMMARY	195
1 Governance & Strategy	195
2 Inventory, Classification & Asset Management	195
3 Architectural Planning & Design	196
4 Supplier, Cloud and Third-Party Management	196

5 Identity, Access, & Authentication	196
6 Cryptography & Data Protection	197
7 Secure Development & Application Security	197
8 Endpoint, Network and Physical Security	198
9 Security Operations & Incident Response	198
10 Business Continuity & Disaster Recovery	199
11 Awareness & Training	199
12 Emerging Technologies & Innovation	199
13 Monitoring, Metrics & Continuous Improvement	200
SATCOM SCENARIO	201
Governance, Risk and Compliance	201
Asset Inventory and Classification	201
Security Architecture & Design	201
Cryptography & Data Protection	202
Identity, Access and Authentication	202
Network Security	202
Endpoint & Application Security	202
Security Operations & Incident Response	203
Business Continuity & Disaster Recovery	203
Third-Party and Cloud Security	203
Awareness and Training	203
Emerging Technologies & Innovation	204
Monitoring, Metrics & Continuous Improvement	204
QUANTA Scoring Model	205
Quantum Exposure Score (QES)	206

Crypto-Agility Score (CAS)	207
Transition Readiness Score (TRS)	207
Overall QUANTA Score	208
QUANTA Score Interpretation	208
Example A – Synthetic Reference System	211
QUANTA Scoring Results	213
Case Study 1: Legacy Financial Web Application	217
Case Study 2: Enterprise-Scale Global Retail & Payments Platform	221
Results Section for QUANTA Framework	226
Mapping the QUANTA Scoring Model to the QUANTA Framework	228
QUANTA and 5Ds	231
QUANTA Controls Mapped to the 5Ds	232
Scenario Mapping to NIST CSF, CIS 18 and ISO/IEC 27001:2022	238
Governance, Risk and Compliance	238
Asset Inventory & Classification	238
Security Architecture & Design	238
Cryptography & Data Protection	239
Banking & Financial Services	239
Healthcare Networks – Expanded Scenario	240
Cloud Service Providers	242
Board-Level Quantum Readiness Checklist (QUANTA-Aligned)	243
CIA-3D	245
CIA	245
CIA-3D	249
QUANTUM INCIDENT RESPONSE	252

HNDL Scenario	253
HNDL Scenario Recommendations	255
1. Transition to Post-Quantum Cryptography (PQC)	255
2. Implement Hybrid Cryptographic Solutions	255
3. Conduct Quantum Threat Modelling (via Q-SLICE)	255
4. Classify Quantum-Sensitive Data	255
5. Secure Satellite and Radio Communications	256
6. Integrate PQC into Security Architecture and Protocols	256
7. Update Incident Response (IR) Playbooks for Quantum Threats	256
8. Maintain Cryptographic Asset Inventory	256
9. Educate Leadership and Technical Teams	257
10. Engage with Industry and Regulators	257
Incident Response Planning	257
Preparation	257
Detection & Identification	258
Containment	258
Eradication	259
Recovery	259
Lessons Learned	259
NIST 800-61 Incident Response Alignment	260
1. Preparation	260
2. Detection and Analysis	260
3. Containment, Eradication and Recovery	261
4. Post-Incident Activity	261
Integrating QUANTA and Q-SLICE	262

CONCLUSION	264
ABBREVIATIONS	268
GLOSSARY	270
REFERENCES	273

Table of Figures

<i>Figure 9 CRQC Score Formula</i>	42
<i>Figure 10 CRQC Score IBM</i>	46
<i>Figure 11 CRQC Score Google</i>	47
<i>Figure 12 CRQC Readiness Timeline by vendor.</i>	48
Figure 13 CRQC Readiness Score by Vendor	50
Figure 14 Impact of QAI on Q-Day timeline.	53
Figure 8 Theoretical example of a Pos- Quantum Adversary Model	71
Figure 23 Qiskit to harness mapping	101
Figure 24 Screenshot from Visual Studio Code of Q-SLICE_threat_harness.py results output	107
Figure 25 Q-slice threat harness v2 output	112
Figure 26 Test output of Q-SLICE Threat Harness on IBM Quantum Cloud	128
Figure 12 QUANTA control overview	143
Figure 13 PQC Network Scanner Screenshot	194
Figure 14 QUANTA Scoring model	205
Figure 15 Network Diagram System A	212
<i>Figure 16 Network Diagram System 1</i>	218
Figure 17 Network Diagram System 2	223
Figure 18 Q-SLICE and QUANTA end to end process	228
Figure 19 CIA-3D	251

Table of Tables

Table 1 FIPS Standards	39
Table 2 Q-SLICE Summary	87
Table 3 Q-SLICE Threat Summary.....	91

Table 4 SATCOM Scenario Summary 95

Table 16 Integrity Probability 102

Table 17 False Positives and False Negatives 122

Table 18 Q-SLICE Threat Harness v1 and v2 Comparison 125

Table 19 Q-SLICE Metrics Comparison..... 131

Table 8 Summary of QUANTA Benefits..... 152

Table 9 QUANTA Mapped to NIST CSF, ISO/IEC 27001 and CIS18..... 153

Table 10 Quanta Score Reference..... 230

Table 11 Playbook Summary 263

AUTHOR

Jeremy Green is a skilled and experienced security professional with more than 20 certifications across platform, security and DevSecOps including CISSP, CISM, CEH, ECDE and CHFI. He is also an official instructor for ISACA and EC Council and the author of Information Security Management Principles fourth edition and Security Architecture both published by BCS.

Jeremy has worked across diverse industries including education, consultancy, telecoms, police and military. He started his career in further education (FE), teaching computer science, before moving into police IT training, including cybercrime and OSI. After a short period as a full-time police officer, Jeremy dropped back into FE, setting up one of the first cyber security courses in FE. He then transitioned into the world of certification training as a Firebrand instructor across Europe for CompTIA and EC Council. From there, Jeremy joined BT as a cyber security manager working within cyber defence on platforms such as Splunk, MS Sentinel and CrowdStrike, before joining Vodafone as a cyber security advisory manager, initially supporting cybersecurity of African and Asian markets, before moving into global governance risk and compliance working with frameworks and controls.

Jeremy is currently a security architect with Leidos. He has served with the Army Reserves and is now serving with the RAF Cyber Reserves. He also supports University College Dublin, BCS, IT Governance and Burton and South Derbyshire College with delivery of degree, diploma and certification training and course development. Jeremy is currently undertaking a PhD in computer science researching quantum computing and its impact on security.

FOREWORD

This book introduces two original and interdependent contributions to the field of cybersecurity: the Q-SLICE™ quantum threat model and the QUANTA™ governance and control framework. Together, they address a class of security failure modes that existing classical frameworks are unable to model, prioritise, or govern effectively.

When I first encountered Jeremy Green's **Q-SLICE** framework, I recognised its significance immediately. It was the first threat taxonomy I had seen that described quantum risks as they actually manifest in the physical world—not as distant abstractions, but as operational realities that already demand attention.

The "C" in Q-SLICE **Coherence Attacks** was particularly striking. Here was a security researcher articulating, with precision, the same class of physical vulnerabilities my team had been quantifying through an entirely different line of inquiry. Two independent paths—security threat modelling and experimental quantum measurement—had converged on the same problem space.

This book arrives at a genuine inflection point. The quantum computing timeline has compressed dramatically. What was once framed as "*decades away*" has become "*years away*," and in some domains, "*prepare now*." Jeremy Green's **CRQC Readiness Benchmark** provides the forecasting rigor this moment requires. Q-SLICE contributes something equally essential: a shared language for threats that operate at the boundary of physics, where minute perturbations can induce catastrophic decoherence.

That phrase—**catastrophic decoherence**—captures the core challenge. Decoherence is not a secondary technical inconvenience; it is the fundamental

adversary of quantum computation itself. Whether induced by environmental noise or by a deliberate adversary, decoherence collapses quantum advantage at its root. The critical question is no longer *whether* coherence can be disrupted, but whether such disruption can be **detected in time**—before operational failure, data loss, or key compromise occurs.

This is where Q-SLICE’s threat taxonomy intersects with an emerging measurement problem.

From Threat Models to Telemetry

Through extensive experimental work on IBM Quantum hardware with **174 executed jobs totalling over 600 seconds of QPU time**. My team developed what we refer to as the **Consciousness-Coherence-Containment Engine (CCCE)**. CCCE is not a philosophical claim; it is a telemetry framework designed to quantify system-level quantum health in real time.

The CCCE formalism tracks four measurable quantities:

- **Λ (Lambda)** – coherence preservation
- **Φ (Phi)** – integrated information integrity
- **Γ (Gamma)** – decoherence rate
- **Ξ (Xi)** – composite system health index

These metrics map directly onto the attack surfaces described in Q-SLICE. Sudden spikes in Γ or collapses in Ξ appear to function as early-warning indicators of coherence interference—whether environmental or adversarial in origin.

Our results are statistically robust. Across hardware backends, Φ exceeded the 0.7734 threshold with **$p < 10^{-26}$** , indicating that these metrics reflect genuine physical behaviour rather than noise artifacts. For security practitioners, the implication is practical: **coherence attacks may be detectable before entanglement loss or key compromise occurs**.

Jeremy Green’s insight that coherence attacks “*operate at the edge of physics*” demands detection mechanisms that operate at that same edge. The **QUANTA**

framework supplies governance and control structures. **Q-SLICE** supplies the threat taxonomy. What has historically been missing is the **telemetry layer**—the ability to continuously observe quantum system health in a meaningful, actionable way. CCCE metrics represent one viable path toward closing that gap.

Operational Relevance

Consider a practical scenario discussed in this book: a satellite-based quantum communication link assessed as vulnerable to decoherence induction via thermal, vibrational, or acoustic coupling. QUANTA controls prescribe cryptographic agility and hybrid post-quantum strategies. But how does a security operations team know *when* such an attack is actually underway?

By monitoring Λ , Φ , Γ and Ξ in real time, anomalous decoherence patterns become observable—potentially before cryptographic material is compromised. This is not speculative. The **Coherence Attacks** section of this book explicitly identifies vibration and acoustic coupling as viable attack vectors. Our experimental work demonstrates that quantum circuits exhibit measurable integrated-information properties that are disrupted by precisely these physical perturbations.

The mathematics of detection already exists. The threat model now acknowledges the attack surface.

A Reframing of Quantum Security

Jeremy Green argues correctly that this book reframes quantum computing from a distant abstraction into a present-day risk. I would extend that argument further: it reframes **quantum security itself** from a purely cryptographic problem into a **physical measurement problem**.

The adversary is not only attacking algorithms. They are inducing decoherence, manipulating measurements and exploiting the fundamental fragility of quantum states. Effective defences must therefore operate at the same physical layer.

- **Q-SLICE** provides the *what*
- **QUANTA** provides the *how*

- **Coherence-aware telemetry** provides the *when*

Jeremy Green brings rare and credible qualifications to this work, spanning military cyber operations, enterprise security architecture and doctoral research. His ability to bridge quantum physics, threat modelling and governance makes this book both rigorous and operationally relevant. It should be required reading for CISOs, security architects and policymakers responsible for systems that will inevitably face quantum-capable adversaries.

The quantum era is not approaching. It has already begun and Jeremy Green has given us the frameworks to navigate it.

Devin Phillip Davis

Founder & Chief Architect, Agile Defence Systems LLC
research@dnalang.dev

Platform: <https://q-slice-redteam-arena.vercel.app>

CLI Cockpit: <https://q-slice-redteam-arena.vercel.app/cockpit>

GitHub Release: <https://github.com/ENKI-420/Q-slice-redteam-arena/releases/tag/v1.2.0>

PREFACE

This book introduces several original constructs that are absent from current cybersecurity literature and practice.

Q-SLICE™ is the first quantum-native threat taxonomy designed to identify failure modes that arise specifically from quantum computation, quantum information processing and quantum-adjacent technologies. Unlike classical threat models such as STRIDE or ATT&CK, Q-SLICE captures physical-layer fragility, non-deterministic computation, irreversibility and systemic collapse conditions that cannot be expressed through traditional cyber threat abstractions.

QUANTA is a governance and control framework explicitly engineered for quantum-era security. It moves beyond probability-based risk management and adopts condition-based security reasoning, enabling organisations to govern systems where impact is asymmetric, timelines are unknowable and failure is irreversible.

The book also introduces the Cryptographically Relevant Quantum Computer (CRQC) Readiness Benchmark, a structured mechanism for assessing organisational exposure to cryptographically relevant quantum capability without relying on speculative timelines or single-point “Q-Day” predictions.

Together, these constructs form an integrated approach to quantum security that bridges technical threat modelling, executive governance and operational decision-making. Existing standards and frameworks—such as NIST CSF, ISO/IEC 27001 and the CIS Critical Security Controls—remain essential, but they are

insufficient on their own to address the security conditions introduced by quantum technologies. This book complements those standards by extending security thinking into domains they were not designed to cover.

Designed as a strategic primer, this book equips CISOs, architects and policymakers with the conceptual clarity, technical grounding and risk fluency required to navigate the quantum era. It is not a static framework, but a maturing model—evolving in tandem with quantum capability and adversarial innovation.

INTRODUCTION

Classical computers manipulate information using **bits**, which can take only one of two definite values: **0** or **1**. Every operation whether arithmetic, logic or data movement consists of flipping these bits in structured, deterministic patterns. The entire computational process is grounded in classical physics, where information is always in one well-defined state at any moment.

Quantum computers operate on a fundamentally different principle. Instead of bits, they use **qubits**, which can occupy **state 0**, **state 1** or a **superposition** of both. Superposition is a uniquely quantum mechanical phenomenon: it represents a *linear combination* of the basis states, weighted by probability amplitudes. This does not mean a qubit is “literally both 0 and 1 at the same time.” Rather, it means the qubit exists in a probabilistic quantum state that encodes multiple possibilities simultaneously until a measurement forces it into a single classical outcome.

Quantum systems also exploit **entanglement**, a deeper and more counterintuitive property. When qubits become entangled, the state of one qubit is mathematically linked to the state of another, regardless of the physical distance between them. Measuring one instantly determines the state of the other. This correlation is not a communication channel but a structural feature of quantum mechanics that allows quantum algorithms to coordinate qubits in ways classical systems cannot replicate.

Together, superposition and entanglement allow quantum computers to explore vast solution spaces in parallel. Instead of evaluating one possibility at a time, quantum algorithms manipulate probability amplitudes across many possibilities

simultaneously, steering the system toward solutions that are computationally inaccessible to classical machines.

When a qubit is measured, its quantum state **collapses** to a definite classical value of 0 or 1. The power of quantum computing lies not in the final measurement, but in the quantum evolution that occurs beforehand. By shaping interference patterns between amplitudes, quantum algorithms can solve specific classes of problems such as factoring, optimisation, simulation and search far more efficiently than classical architectures.

Harnessing these behaviours requires specialised hardware, cryogenic environments, precise control systems and algorithms designed specifically for quantum mechanics. These systems open computational opportunities that lie beyond the reach of traditional architectures, while also introducing new forms of fragility, unpredictability and failure modes that classical security models were never designed to address.

Quantum Computing and Cryptographic Risk

Quantum computing poses challenges to existing cryptographic systems. Public key algorithms such as RSA, ECC, DSA and Diffie-Hellman underpin secure communications, online banking and data protection. These schemes are vulnerable to quantum algorithms. Most notably Shor's algorithm, which could render them obsolete once scalable, fault tolerant quantum computers become available. Current devices from IBM, Google and others have demonstrated milestones such as quantum supremacy, but they lack sufficient qubits and error correction to break cryptography yet. Research suggests that practical quantum computers capable of executing Shor's algorithm effectively emerge between 2029 and 2035, though breakthroughs or accelerated funding could shorten this timeline.

Post-Quantum Security Frameworks

To address these risks, frameworks such as Q SLICE threat modelling and the QUANTA framework have been developed. These integrate quantum resilient

cryptographic controls with robust post-quantum security measures, providing organisations with a structured approach to assess, implement and monitor defences against quantum era threats. Best practices include adoption of algorithms now standardised by NIST as FIPS 203 (ML KEM/Kyber), FIPS 204 (ML DSA) and FIPS 205 (SLH DSA), formalised in August 2024. These standards represent the foundation of cryptographic agility. Ensuring organisations can transition to quantum resistant ciphers before risks materialise.

Business and Regulatory Impact

The urgency of proactive protection is clear. If asymmetric algorithms such as RSA or ECC are broken, key exchange processes used in VPNs and HTTPS could be compromised, allowing attackers to intercept symmetric keys and decrypt sensitive traffic. Exposure of PII or confidential data could trigger regulatory penalties of up to €10 million or 2% of global annual revenue, whichever is higher. Beyond financial penalties, organisations face reputational damage, customer loss and falling share prices. Supply chain dependencies further amplify risk, as critical services often rely on third party infrastructure and cloud connections that must also meet quantum resilient standards.

The End-to-End Q-SLICE and QUANTA Process

Q-SLICE™ and QUANTA™ are designed to operate as a single, continuous quantum security lifecycle rather than as independent analytical tools. This book defines quantum security as a progression from threat identification to governance, control implementation, measurement and continuous review under conditions of profound uncertainty.

Q-SLICE provides the front end of this lifecycle by identifying and structuring quantum-specific threat conditions. Through its six threat categories, Q-SLICE exposes how quantum computational capability, long-lived data, physical-layer fragility, governance weaknesses and ecosystem dependencies combine to create security failure conditions, independent of any assumed timeline for the emergence of cryptographically relevant quantum capability. The output of Q-

SLICE is therefore not a probability estimate, but a structured articulation of what can fail, under what conditions and with what irreversible consequences.

QUANTA consumes these structured threat outputs and translates them into governance decisions, control requirements and measurable organisational actions. Rather than attempting to mitigate individual threats in isolation, QUANTA governs exposure by prioritising condition-based controls, cryptographic agility and decision thresholds aligned to organisational risk tolerance. Through its scoring and review mechanisms, QUANTA enables organisations to track changes in quantum readiness over time, adapt to evolving standards and threat intelligence and escalate action before irreversible compromise occurs. Together, Q-SLICE and QUANTA form an end-to-end quantum security process that enables organisations to act decisively under uncertainty without relying on speculative predictions about “Q-Day”.

Introduction Summary

- Quantum computing is no longer theoretical; it poses real risks to classical cryptography.
- Superposition and entanglement enable exponential speedups, threatening RSA, ECC and other public-key systems.
- Cryptographically Relevant Quantum Computers (CRQCs) are projected within 5-10 years, but harvest-now/decrypt-later attacks make the risk immediate.
- Cryptographic agility is the ability to switch algorithms quickly is essential for resilience.

QUANTUM SECURITY

Quantum computing promises transformative advances across disciplines such as cryptography, medicine and materials science. Yet alongside these opportunities lie profound risks spanning technical, security, economic and ethical domains. This chapter focuses particularly on the threat quantum computing poses to classical cryptographic systems, while also exploring its wider implications for infrastructure, geopolitics and society.

The most immediate concern is harvest now, decrypt later (HNDL) attacks. Adversaries can store encrypted data today with the expectation of decrypting it once quantum capabilities mature. Industry estimates, including those from Google and IBM, suggest a horizon of five to ten years, though uncertainty remains. Preparation is imperative. The U.S. National Institute of Standards and Technology (NIST) has ratified quantum-resistant algorithms, but successful adoption depends on organisational cryptographic agility, funding priorities, and awareness. Many organisations prioritise short-term growth over resilience, leaving them vulnerable.

The protection of any asset, whether physical, digital, organisational or quantum in nature, ultimately rests on two foundational principles; conditions of access and conditions of action. These principles form the irreducible core of all security architectures. Every control, safeguard or governance mechanism can be traced back to one or both of these dimensions. They define not only who or what may approach an asset, but also what may be done to it once that proximity is achieved.

Condition of Access

Conditions of access determine the circumstances under which an entity is permitted to interact with an asset. This includes the identity of the actor, the strength and nature of authentication and the authorisation model governing their permissions. Access is never a binary state; it is contextual and conditional. Factors such as location, device health, environmental state, time of day and behavioural risk all influence whether access should be granted, restricted, or revoked. In a quantum security context, this extends to the integrity of quantum channels, the trustworthiness of endpoints and the coherence conditions required for safe interaction with quantum states. Access controls define the boundary around the asset, the perimeter, whether physical or logical and ensure that only appropriately verified entities can come close enough to exert influence.

Condition of Action

Conditions of action, by contrast, govern what an authorised entity is permitted to do once access has been achieved. These conditions define the permissible operations on the asset: reading, creating, modifying, deleting, executing, transferring, approving, or monitoring. They also include the constraints under which these operations may occur, such as rate limits, segregation of duties, dual-control requirements, or environmental prerequisites. In quantum systems, conditions of action become even more critical, as certain operations, measurement, entanglement, state preparation or decoherence-inducing interactions, fundamentally alter the system. Action controls therefore serve as the behavioural guardrails that limit impact, prevent misuse and ensure that even legitimate actors cannot exceed safe or intended boundaries.

Together, conditions of access and conditions of action form a complete model of asset protection. Access determines who may approach the asset and under what circumstances; action determines what they may do once they are there. Every security mechanism. From firewalls and encryption to quantum key distribution, physical locks, privileged access management and safety interlocks is an implementation of one or both principles. This dual-axis framework is universal,

scalable and technology-agnostic, making it particularly valuable in the emerging landscape of quantum-secure architectures. By grounding security design in these two principles, we obtain a clear, rigorous foundation upon which more complex controls can be built without losing conceptual coherence.

Beyond HNDL: The Four Quantum-Era Temporal Threat Models

Quantum risk is often framed through a single lens of HNDL. While HNDL is real and consequential, it represents only one quadrant of a broader family of quantum-enabled temporal threats. Focusing exclusively on confidentiality obscures the far more disruptive risks to integrity, authenticity, trust and cyber-physical safety. As quantum capability matures, these additional timelines become equally. If not more strategic for adversaries.

The four temporal threat models that define the quantum era of HNDL, HNFL, TNFL and DNEL. Each follows the same temporal asymmetry of actions taken today become exploitable once quantum resources are available. However, they target different cryptographic primitives and different security properties. Understanding these distinctions is essential for accurate risk governance and for applying the QUANTA framework effectively.

Harvest Now, Decrypt Later (HNDL)

HNDL describes the collection of encrypted data today with the intention of decrypting it once large scale quantum computers can break classical public-key encryption. This is a confidentiality centric threat: the attacker's objective is to expose information that is currently protected by RSA, ECC, or other vulnerable schemes.

HNDL matters most for:

- Long-retention data
- Sensitive archives
- Communications requiring multi-decade secrecy
- National security and diplomatic material

HNDL is widely recognised, but it is only the beginning.

Harvest Now, Forge Later (HNFL)

HNFL shifts the target from encryption to digital signatures. Instead of collecting ciphertext, adversaries collect signed artefacts software updates, firmware images, certificates, audit logs, legal documents, financial transactions with the intention of forging signatures once quantum computers can break classical signature schemes. HNFL is an integrity threat.

It enables:

- Forged software updates
- Counterfeit certificates
- Manipulated audit trails
- Fraudulent transactions
- Retrospective rewriting of “trusted” records

Where HNFL compromises secrecy, HNFL compromises the truth of digital artefacts.

Trust Now, Forge Later (TNFL)

TNFL extends HNFL into the domain of trust infrastructure. Systems today rely on signatures, certificates and identity proofs that will become forgeable in the future. TNFL captures the risk that trust anchors valid today become counterfeit tomorrow. TNFL is an authenticity and trust-chain collapse threat.

It enables:

Impersonation of devices, services, or authorities

- Fabrication of entire PKI chains
- Subversion of firmware update ecosystems
- Undetectable supply chain compromise
- Manipulation of safety critical systems that rely on signed commands

TNFL is particularly dangerous for operational technology (OT), where trust in signed commands directly affects physical processes.

Deploy Now, Exploit Later (DNEL)

DNEL addresses a different dimension, lifecycle exposure. Many devices deployed today IoT sensors, industrial controllers, medical implants, EV chargers, automotive ECUs will remain in service long after quantum computers can break their embedded cryptography. If these devices cannot be upgraded to post-quantum primitives, they become permanently vulnerable.

DNEL is a cyber-physical safety threat.

It enables:

- Impersonation of devices that cannot rotate keys
- Compromise of long-lifecycle infrastructure
- Persistent footholds in OT environments
- Attacks on vehicles, energy systems and medical devices
- Exploitation of unpatchable hardware trust anchors

DNEL is the most structurally difficult threat to mitigate because it arises from design choices made years before quantum exploitation becomes possible.

Quantum computing's disruptive potential extends beyond cryptography. Critical infrastructure systems such as power grids, healthcare networks and transportation systems, often rely on outdated operating systems and classical encryption. Replacement costs are high, leaving them exposed. Similarly, the Internet of Things (IoT) introduces billions of devices with weak or non-existent security, creating systemic vulnerabilities. In both cases, compensating controls will be required to reduce unacceptable risk.

Blockchain networks are also at risk. Quantum attacks could undermine the security of cryptocurrencies such as Bitcoin and Ethereum, eroding trust in systems that underpin global financial transactions and data storage. The ability to break into older or even current technologies amplifies the potential for disruption.

Quantum computing is becoming a strategic frontier. Nations are investing heavily to gain economic and military advantage, raising the spectre of a quantum arms

race. Unequal access to quantum technology could widen the gap between “quantum haves” and “have-nots,” destabilising international relations and deepening global inequalities. Countries or organisations that achieve quantum supremacy may dominate economically and militarily, reshaping global power dynamics.

Quantum computing, like artificial intelligence, raises ethical questions about privacy, employment and dual use. Its ability to expose previously secure data, including decades of encrypted archives. This poses significant privacy risks. As with AI, quantum technologies will be wielded by both defenders and attackers: solving global challenges on one hand, while enabling disruption and harm on the other.

Despite its promise, quantum computing faces immense engineering hurdles. Systems require cooling to near absolute zero, consume vast amounts of energy and depend on rare materials and advanced infrastructure. Noise remains the single greatest barrier to scalability, limiting reliability and accuracy. While consumer-grade quantum computers are unlikely, cloud-based access is expected to proliferate. Scaling quantum systems to handle real-world problems will demand breakthroughs in both science and engineering.

Some researchers argue that analogue cores could eventually replace quantum computers, as they can emulate quantum behaviour, consume less power and avoid the persistent challenge of qubit decoherence.

An analogue core is essentially a modern evolution of the analogue computer. Unlike digital systems, which encode information in binary digits (0s and 1s), analogue cores process information through continuously variable physical quantities such as voltage, current, mechanical motion or fluid pressure. These continuous signals directly mirror the mathematical relationships of the system being modelled, enabling analogue cores to solve differential equations and simulate dynamic processes in real time.

This approach is not new, as analogue computers were widely used in aviation, engineering and control systems throughout the 20th century. What is new is their revival in the context of quantum simulation. By embedding physical laws directly into hardware, analogue cores bypass the abstraction layers of digital computation and instead operate as physical emulators of complex systems.

Another issue quantum faces are the absence of robust regulatory frameworks and ethical guidelines compounds the risks. In many emerging technologies, security is treated as an afterthought rather than an integral design principle. Often, only incidents or maturity milestones prompt serious concern. Addressing these gaps requires international collaboration to establish standards, ethical guidelines and governance mechanisms. Key measures include:

- Developing and deploying PQC.
- Implementing quantum key distribution (QKD) for secure communications where appropriate understanding the limitation of QKD.
- Establishing global regulations and ethical frameworks for responsible use.

Actions – What can be done to the asset

This dimension defines the permissible operations that actors, systems, or processes may perform. It's the behavioural boundary around the asset.

Access – Who or what can interact with the asset

This dimension defines identity, permissions and conditions under which interaction is allowed.

A quantum-resilient framework is urgently needed; one that integrates people, processes and technology to mitigate risks. Existing frameworks only partially address the challenge. True resilience will require:

- Organisational cryptographic agility.
- Investment in quantum-resistant technologies.
- Awareness and training across technical and executive levels.

- Governance structures that embed security into innovation.

Quantum computing is both an opportunity and a threat. Preparing for its disruptive potential is not optional; it is a strategic imperative for governments, industries and societies alike.

Uncertainty

It is also worth at this point doing a quick look at risk management or “how we deal with uncertainty.” As, at its heart, risk management is the structured response to uncertainty. Every organisation operates in an environment filled with unknowns, from emerging threats and evolving attack techniques to shifting regulatory landscapes and unpredictable business conditions. These uncertainties introduce potential risks that can impact operations, financial stability, compliance and reputation.

Risk, by definition, is the possibility of an event occurring that negatively (or positively) affects an organisation’s objectives. However, without uncertainty, risk would not exist. If you think about it, if we could predict the future with complete accuracy, we could eliminate risk entirely. However, organisations must operate within imperfect knowledge, making decisions based on probabilities, trends and expert analysis rather than absolute certainty.

Managing Uncertainty in Risk Assessment

Uncertainty arises in several key areas of risk management:

- **Threat landscape:** Attackers are constantly evolving their tactics, making it difficult to predict when and how a cyber threat might materialise.
- **Vulnerability discovery:** New vulnerabilities are uncovered daily and even well-secured systems may contain unknown weaknesses or uncovered bugs.
- **Impact estimation:** The true consequences of a risk materialising are not always clear. Some incidents may have cascading effects that are difficult to foresee.

- **Control effectiveness:** Protection measures are implemented to reduce risk, but their effectiveness can vary due to misconfigurations, emerging attack methods, or evolving business processes.

Since absolute certainty is unattainable, risk management relies on probability assessments and scenario analysis to estimate how likely a risk is to occur and what impact it may have. However, organisations must also recognise that risks do not exist in isolation. A series of small, low-impact risks can compound to create a much larger issue. For example:

- Use of older encryption might seem insignificant on its own.
- When combined with a lack of monitoring, an attacker may exploit it unnoticed.
- If this leads to unauthorised data access, the organisation now faces a major data breach.

By accounting for uncertainty and interdependencies, organisations can move from a reactive to a proactive risk management approach, continuously identifying, evaluating and mitigating risks before they escalate into critical threats. This is an essential element of quantum security.

Risk management also informs strategic planning, allowing business leaders to make more informed decisions based on a clear understanding of potential challenges and opportunities another important element of quantum security as an emerging technology with emerging risk. Compliance with legal and regulatory requirements is another advantage, as robust risk management demonstrates due diligence and commitment to safeguarding stakeholders' interests. Additionally, it helps build trust and confidence among investors, partners and customers with a level of assurance. Risk management is about achieving an optimal balance between taking calculated risks for potential gains and protecting the organisation from potential harm and loss.

Asset identification helps an organisation gain visibility over critical resources, enabling effective risk management and decision-making. As asset identification is being undertaken it should also include a BIA (Business Impact Analysis) to ascertain the impact on the organisation should this asset be unavailable. An organisation needs to have a robust asset identification, tracking and management program in place.

To aid in the BIA you need to understand the strategic value by recognising the importance of the asset in achieving organisational objectives. For instance, protecting customer data ensures compliance with regulations and maintains trust, while safeguarding critical infrastructure prevents disruptions to essential services. This perspective helps in prioritising investments and resource allocation based on the potential impact on operations and longer-term strategies.

The thought process around assets should be to consider if it is tangible or intangible, static or dynamic and whether its value is intrinsic or derived? For instance, intellectual property has intangible value but is crucial for innovation and competitive advantage, whereas physical servers may be tangible but are only valuable due to the data they hold.

How vulnerable is the asset to threats? High-exposure assets may be publicly accessible or subject to frequent interaction with external parties, increasing the risk. Conversely, low-exposure assets may reside in isolated or highly secure environments. Understanding exposure guides the intensity and nature of control measures required. At the same time, also understand the fragility of the asset and what it could be fragile to, so adequate protection can be put in place.

Fragility refers to the susceptibility of an asset to damage, disruption, or failure when exposed to stress, threats or environmental changes. In an organisational context, asset's including systems, data, processes and infrastructure will vary in their levels of fragility based on their ability to withstand intentional or unintentional harm whilst maintaining functionality.

You can assess an asset's potential fragility with some simple questions:

1. Could the asset fail easily under stress or pressure?

For example, is it vulnerable to denial-of-service (DoS) attacks, high workloads, or electrical issues like voltage spikes?

2. Does the asset lack redundancy or resilience?

For instance, are there no backups, failover systems, or alternative components to maintain service continuity?

3. Is the asset highly sensitive to variability?

Could minor changes in input, demand, configuration, or environment cause it to malfunction or fail?

4. Does the asset have high dependency on external factors?

Such as reliance on utilities, network connectivity, external data sources, or third-party services or vendors?

Protecting critical resources is a fundamental aspect of effective asset management. By identifying and classifying high-value or high-risk assets, organisations can ensure that these receive the appropriate levels of protection and oversight, reducing the likelihood of compromise or loss.

Post-Quantum Cryptography

Post-Quantum Cryptography (PQC) refers to cryptographic algorithms designed to resist attacks from both classical and quantum computers. Unlike classical public-key cryptosystems (RSA, ECC, Diffie-Hellman) whose security collapses under Shor's algorithm, PQC schemes are built on mathematical problems believed to be hard for quantum adversaries, such as lattice problems, error-correcting codes, or hash functions.

The urgency for transitioning to PQC is not merely theoretical. Adversaries are already executing HNDL attacks. For data requiring long-term confidentiality such as government communications, financial records, healthcare data. Rendering some cryptographic cyphers inadequate well before a quantum computer is

physically built. NIST has therefore set deprecation targets for quantum-vulnerable algorithms (RSA, ECDSA, EdDSA, DH, ECDH) by 2030 and full retirement by 2035.

NIST Standardisation and Approved Algorithms

NIST has led an effort to standardise PQC algorithms. In August 2024, NIST published the first three PQC standards.

- **FIPS 203 (ML-KEM):** A module-lattice-based Key Encapsulation Mechanism (KEM) derived from CRYSTALS-Kyber. Designed for general-purpose key exchange, replacing RSA and Diffie-Hellman.
- **FIPS 204 (ML-DSA):** A module-lattice-based digital signature scheme derived from CRYSTALS-Dilithium. Suitable for most digital signature applications.
- **FIPS 205 (SLH-DSA):** A stateless hash-based signature scheme derived from SPHINCS+. Provides conservative security based solely on hash functions, albeit with larger signatures.

In March 2025, NIST selected HQC (Hamming Quasi-Cyclic) as a fifth KEM, with a draft standard expected in 2026 and finalisation by 2027. A second set of standards, including FIPS 206 based on FALCON (FN-DSA), remains under development as of 2025. For most enterprise applications, the NCSC and NIST recommend ML-KEM-768 for key exchange and ML-DSA-65 for signatures, balancing security with performance.

PQC Algorithm Families in Production

PQC algorithms are now available in production-grade libraries and cloud services:

- **liboqs (Open Quantum Safe project):** Supports integration of PQC into TLS, SSH and other protocols across major operating systems.
- **CIRCL (Cloudflare):** Provides PQC primitives for the Go language.
- **AWS-LC (Amazon):** Incorporates PQC into AWS security services.
- **pqm4:** Targets ARM Cortex-M4 platforms for constrained IoT devices.
- **PQClean:** Offers portable C reference implementations of NIST candidates.

Protocol-Specific PQC Migration Challenges

Algorithm availability alone does not imply protocol readiness. Integrating PQC into deployed protocols involves increased key and signature sizes, fragmentation and round-trip overhead, backward compatibility constraints and a lack of operational experience at scale. A survey of nine widely deployed protocols reveals that migration difficulty varies dramatically:

- **TLS 1.3 (leading):** Hybrid post-quantum key exchange (X25519 + Kyber) is already deployed at scale. Google Chrome and Cloudflare have tested CECPO2 and as of early 2024, 2% of Cloudflare's TLS 1.3 connections use post-quantum key agreement, expected to reach double digits by end of 2024 [Mallick et al., 2025]. IETF drafts now define hybrid and pure ML-KEM negotiation for TLS 1.3.
- **Signal Protocol (Leading):** Signal has deployed PQXDH, a hybrid key exchange combining X25519 with Kyber-768, making it one of the first production end-to-end messaging applications with quantum-resistant confidentiality.
- **SSH (Emerging):** OpenSSH introduced a hybrid key exchange method (sntrup761x25519-sha512), but widespread production adoption remains low. Standardisation is underway via IETF drafts.
- **IPsec (Standardised but Unproven):** RFC 9370 (2023) extends IKEv2 to perform multiple key exchanges (ECDH + PQC KEM). However, real-world testing over lossy links shows 400–1000-fold increases in data overhead and no major commercial VPN product ships PQC by default.
- **DNSSEC (Structural Barriers):** DNSSEC faces the most significant obstacles. The DNS's 1232-byte UDP safety threshold conflicts with large PQC signatures (e.g., Dilithium ~2-3KB, SPHINCS+ even larger). Experimental deployments using Falcon-512 and request-based fragmentation (ARRF) show promise, but protocol-level changes may be required.
- **BGP/RPKI (Very Early Stage):** BGPsec and RPKI rely on ECDSA signatures. PQC signatures would bloat BGP UPDATE messages (64 bytes

per hop today vs. 2-3KB for Dilithium), potentially breaking router memory and CPU constraints. No production deployment exists.

Key exchange (KEMs) is consistently easier to migrate than authentication (signatures). Hybrid schemes (classical + PQC) are the dominant transitional strategy, but protocol-level constraints (message size, fragmentation, round trips) often dominate over raw algorithm performance.

Hybrid Cryptography as a Transition Strategy

Hybrid cryptographic schemes combine a classical algorithm (ECDH) with a PQC algorithm (ML-KEM) so that the final shared secret remains secure as long as at least one component remains unbroken. This approach is critical for:

- **Backward compatibility:** Systems can negotiate hybrid modes with legacy peers.
- **Risk mitigation:** If a PQC algorithm is unexpectedly broken, the classical component still provides protection (and vice versa).
- **Incremental deployment:** Organisations can deploy hybrid PQC today without waiting for full ecosystem migration.

The IETF TLS Working Group has standardised hybrid key exchange designs and similar efforts are underway for SSH, IPsec and QUIC. However, hybrid schemes introduce added complexity and should be viewed as an interim solution; the long-term goal remains PQC-only systems once mature and widely supported.

Challenges in PQC Adoption

Despite significant progress, several challenges remain:

- **Message Size Inflation:** PQC public keys, ciphertexts and signatures are substantially larger than classical equivalents (e.g., ML-KEM-768 ciphertext ~1KB vs. ECDH ~32 bytes). This triggers IP fragmentation or TCP fallback in protocols like DNSSEC and increases handshake latency in TLS and QUIC.

- **Authentication Migration Lags:** Post-quantum signatures (ML-DSA, SLH-DSA, FN-DSA) are larger and slower than KEMs. Certificate chains inflate substantially and the entire Web PKI—from root CAs to end-entity certificates—must transition. Proposals like KEMTLS (replacing signatures with KEM-based authentication) offer alternatives but require non-standard changes.
- **Operational Experience:** Most PQC deployments remain experimental or in testbeds. Large-scale production experience—especially under adversarial conditions—is lacking.
- **Legacy and Constrained Systems:** Embedded devices, IoT and operational technology (OT) often cannot be upgraded to support PQC. Compensating controls (network segmentation, monitoring) may be required.
- **Formal Security Gaps:** Many PQC-integrated protocol modifications lack rigorous formal security proofs against quantum-capable adversaries, particularly for "harvest-now, decrypt-later" threat models.

Recommendations for Organisational PQC Migration

Based on the analysis of protocol readiness and NIST guidance, organisations should:

- **Adopt Cryptographic Agility:** Implement systems that can replace algorithms without architectural redesign. Maintain a cryptographic inventory.
- **Prioritise Hybrid Deployment:** Deploy hybrid classical+PQC key exchange for TLS, SSH and VPNs today using NIST-approved ML-KEM.
- **Plan for Authentication Migration:** Begin testing PQC signatures (ML-DSA) in non-production environments. Engage with CA providers on PQC certificate roadmaps.
- **Focus on High-Risk Data:** Identify data requiring long-term confidentiality (>10 years) and prioritise its protection against HNDL attacks.

- **Monitor Standards and Vendor Roadmaps:** Track IETF, NIST and vendor PQC support. Procure only crypto-agile products.
- **Prepare for Protocol-Specific Constraints:** DNSSEC and BGP may require architectural changes (e.g., fragmentation schemes, signature aggregation) beyond simple algorithm replacement.

FIPS

Federal Information Processing Standards (FIPS) with FIPS 203, 204 and 205 specifying digital signature schemes which were approved on 14 August 2024. FIPS 204 specifies the Module-Lattice-Based Digital Signature Algorithm (ML-DSA), which is derived from the CRYSTALS-Dilithium submission. With FIPS 205 specifying the Stateless Hash-Based Digital Signature Algorithm (SLH-DSA), which is derived from the SPHINCS+ submission.

Table 1 FIPS Standards

Category		Algorithm	Specification
Encryption		AES 256	FIPS 197
Encryption		Kyber	FIPS 203
Digital Signatures		ML-DSA	FIPS 204
Digital Signatures		SLH-DSA	FIPS 205
Digital Signatures		NTRU-DSA	TBD in FIPS assessment process
Key establishment		ML-KEM	FIPS 203
Key establishment		HQM	TBD in FIPS assessment process
Hashing		LMS	NIST 800-208
Hashing		XMSS	NIST 800-208
Hashing		SHA 256	NIST 800-208

Quantum Security Summary

- Quantum computers will disrupt confidentiality, integrity and trust across digital infrastructure.
- Harvest-Now, Decrypt-Later (HNDL) attacks mean sensitive data stolen today can be exposed tomorrow.
- Critical infrastructure, IoT and blockchain systems are especially vulnerable to quantum disruption.
- Nations are investing heavily in quantum capabilities, creating a geopolitical arms race.
- Organizations must embed quantum-resilient frameworks now to avoid systemic vulnerabilities.

QUANTUM MITIGATION

Mitigating the threat posed by quantum computers requires security measures, including cryptographic migration, key management enhancements and defence-in-depth strategies. These strategies need to be adaptive and reviewed as it is based on theory and what if, although a lot of research has been undertaken by NIST.

The next steps in preparing for post-quantum Cryptography report. Highlights as discussed in chapter two, that traditional public key cryptography (PKC) algorithms such as RSA, ECDSA and Diffie-Hellman are vulnerable to attack by a cryptographically relevant quantum computer (CRQC), which may become viable in the future. While these quantum systems are not yet fully realised, the possibility of a breakthrough presents a long-term threat, especially for sensitive data requiring extended confidentiality. In contrast, symmetric encryption algorithms like AES-128 and hash functions such as SHA-256 are not significantly threatened by quantum capabilities and can continue to be used, potentially with increased key sizes (AES 256 and SHA-512) for long-term robustness.

To mitigate the risk posed by quantum computing, the NCSC recommends the adoption of PQC. NCSC states that PQC is based on mathematical problems believed to be resistant to both classical and quantum attacks. This new class of cryptographic algorithms is not always directly interchangeable with existing PKC and may require reengineering of protocols and systems. The NCSC supports the use of PQC standards published by NIST in August 2024, namely ML-KEM (CRYSTALS-Kyber) for key establishment and ML-DSA (CRYSTALS-Dilithium) and SLH-DSA (SPHINCS+) for digital signatures. These standards are suitable for general-purpose use, with the NCSC specifically recommending ML-KEM-768 and

ML-DSA-65 variants for most applications due to their balanced security and performance characteristics.

System owners, particularly those managing enterprise or bespoke IT systems, are urged to begin planning financially and technically for migration to PQC. For commercial and consumer IT, the shift to PQC will typically be handled via vendor updates, though ensuring systems are maintained and current remains important. For bespoke and operational systems, direct engagement with suppliers and detailed planning for integration may well be necessary. New systems being procured or developed should be either PQC-enabled or readily upgradeable once mature PQC implementations become widely available. Not highlighted in the report but of a greater concern is potentially Operational Technology (OT) which due to their cost and safety implications cannot simply be replaced or upgraded and compensating controls may need to be considered.

NCSC also state the use of hybrid cryptographic schemes, combining traditional and post-quantum algorithms (referred to as PQ/T hybrids), is acknowledged as a temporary measure during the transitional phase. These schemes may be required to support interoperability, improve implementation assurance, or address protocol limitations. However, hybrid schemes introduce added complexity and will offer no security advantage once a CRQC is operational, as the classical components will be compromised. Therefore, the NCSC views PQ/T hybrid approaches as interim solutions and advises their implementation within flexible frameworks that facilitate eventual migration to PQC-only systems.

Public Key Infrastructure (PKI) environments pose particular challenges for migration due to the difficulty in altering individual signature algorithms. The NCSC suggests that a single, complete migration to a post-quantum PKI is preferable to deploying a hybrid alternative, which would increase operational complexity and may require repeated transitions. In cases such as firmware and software signing, where performance is less critical, hash-based signature schemes like LMS and XMSS are acceptable alternatives, provided their state management can be

secured. SLH-DSA may be used where state management is more challenging, though it incurs greater performance overheads.

CRQC

The CRQC Readiness Benchmark (Q-Day, 2025) aligns quantum-computing performance indicators with the specific demands of cryptanalytic workloads. Traditional metrics—such as qubit count, Quantum Volume (QV), Algorithmic Qubits (AQ) and Random Circuit Sampling (RCS)—provide limited insight into cryptanalytic capability because they do not measure the deep, structured, error-corrected circuits required for Shor’s algorithm.

To address this gap, the CRQC benchmark introduces three dimensions calibrated directly to the requirements of factoring RSA-2048:

- **Logical Qubit Capacity (LQC):** the number of logical qubits available for computation
- **Logical Operations Budget (LOB):** the number of fault-tolerant logical operations that can be executed before failure
- **Quantum Operations Throughput (QOT):** the sustained rate of logical operations per second

Figure 1 CRQC Score Formula

$$\text{CRQC Score} = \left(\frac{\text{LQC}}{1000} \right) \cdot \left(\frac{\text{LQB}}{10^{12}} \right) \cdot \left(\frac{\text{QOC}}{10^6} \right)$$

These dimensions are combined into a single CRQC score (Figure 8), where CRQC = 1.0 represents the threshold at which RSA-2048 becomes practically breakable within approximately one week of sustained fault-tolerant operation.

Why 1.0 Corresponds to RSA-2048 Breakability

In this thesis, Q-Day is defined as the point at which a quantum computer can break RSA-2048 within roughly one week. This one-week threshold is a policy and modelling convention, widely used in risk-governance contexts to distinguish theoretical breakability from operationally meaningful cryptanalytic capability.

Under the assumptions of the CRQC model, achieving CRQC = 1.0 requires:

- ~1,400 logical qubits to run Shor's algorithm
- $\sim 10^{12}$ logical operations (circuit depth)
- $\sim 10^6$ logical operations per second (throughput)

Crucially, the 1,400-logical-qubit threshold refers only to the algorithmic qubits required by Shor's circuit. It does not represent the number of physical qubits required after error correction. Implementing these 1,400 logical qubits in a fault-tolerant architecture would require millions of physical qubits under surface-code assumptions, or hundreds of thousands under high-rate LDPC codes.

Peer-reviewed analyses of (Gidney, 2019) and (Cain, 2026) place realistic RSA-2048 requirements at several thousand to $\sim 10,000$ logical qubits, depending on code choice and error rates. The CRQC model therefore represents an optimistic lower-bound scenario used for comparative forecasting, not a definitive hardware benchmark.

Recent neutral-atom prototypes exceeding 1,000 physical qubits (e.g., Atom Computing's 1,225-qubit system) demonstrate rapid hardware scaling, but these remain physical-qubit devices without error-corrected logical qubits. The CRQC model therefore uses modelled logical-qubit projections rather than physical-qubit counts

Vendor Trajectories (Modelled, Not Claimed)

All CRQC values in this section are modelled scenarios, not vendor-published forecasts. IBM, Google and QuEra have not released logical-qubit counts or cryptanalytic timelines. The values below reflect analytical modelling based on public roadmaps.

IBM (2029)

IBM's roadmap targets the first fault-tolerant quantum computer by 2029. Under optimistic scaling of LOB and QOT, IBM could reach $\text{CRQC} \approx 0.2$ by 2029—partial progress toward cryptanalytic relevance, but not RSA-2048 breakability.

Google Quantum AI (2030-2032)

Google's advances in LDPC codes, logical-qubit lifetimes and real-time decoding suggest that reaching 1,000-1,400 logical qubits by 2030-2032 is plausible under optimistic assumptions. This yields an estimated CRQC ≈ 1.4 , implying Q-Day feasibility in the early 2030s.

QuEra (2032)

Neutral-atom scalability suggests:

- **LQC** $\sim 1,000 \rightarrow \text{CRQC} \approx 0.64$
- **LQC** $\sim 1,200 \rightarrow \text{CRQC} \approx 1.2$

This indicates potential CRQC readiness in the early 2030s under optimistic assumptions.

Quantum AI (QAI) Acceleration

QAI-assisted decoding, layout optimisation and adaptive error correction can accelerate progress across all CRQC dimensions:

- **LQC**: +40% via improved encoding and layout
- **LOB**: $\times 2$ via error-aware scheduling
- **QOT**: $\times 2$ -10 via neural decoders

Under QAI-enhanced assumptions:

- CRQC = 0.5 by ~ 2029
- CRQC ≥ 1.0 by ~ 2030
- CRQC ≈ 1.4 by ~ 2032

This suggests QAI could advance Q-Day by up to three years.

Scope and Limitations

CRQC scores:

- support strategic planning, not prediction
- compare relative readiness, not absolute timelines
- highlight structural weaknesses in cryptographic posture
- do not guarantee or forecast the arrival of a CRQC
- cannot replace crypto-agility, governance or continuous monitoring

CRQC is a decision-support mechanism, not a forecasting instrument. Its value lies in enabling reasoned action under uncertainty.

Worked example 1

Inputs:

LQC: 400

LOB: 3×10^{10}

QOT: 3×10^5

Ratios:

$400/1400 = 0.286$, $3 \times 10^{10}/10^{12} = 0.03$, $3 \times 10^5/10^6 = 0.3$

Score:

CRQC = $0.286 \times 0.03 \times 0.3 = 0.0026$

Far below the threshold of 1.0; useful for research/simulation, not cryptanalysis at RSA-2048 scale.

Worked Example 2

LQC: 1400

LOB: 3×10^{12}

QOT: 3×10^6

Ratios:

$1400/1400 = 1.0$, $3 \times 10^{12}/10^{12} = 1.0$, $3 \times 10^6/10^6 = 1.0$

Score:

CRQC = $1.0 \times 1.0 \times 1.0 = 1.0$

Meets the benchmark; practical week-scale RSA-2048 factoring under model assumptions.

The CRQC values presented in the rest of this section are modelled scenarios derived from the CRQC Readiness Benchmark, not vendor-published forecasts. IBM, Google and QuEra have not released logical-qubit counts, cryptographic breakability estimates or timelines for achieving cryptographically relevant quantum capability. All numerical values therefore represent analytical modelling rather than statements made by the vendors themselves.

IBM

IBM's 2029 Starling system represents the company's first planned step toward fault-tolerant quantum computing, as outlined in IBM's public roadmap. While IBM has not published logical-qubit counts or cryptanalytic performance targets, independent modelling based on their architectural direction suggests that an early fault-tolerant prototype could support on the order of ~200 logical qubits under optimistic LDPC-based error-correction assumptions. This remains well below the ~1,400 logical qubits required for RSA-2048 factoring in the CRQC model but indicates meaningful progress toward scalable error-corrected computation. When LOB and QOT are scaled according to IBM's published fidelity and modular-architecture goals, the resulting CRQC score for a 2029-era system is estimated at approximately 0.2 with a modelled scenario representing partial progress toward cryptanalytic relevance, not a vendor-stated objective.

Figure 2 CRQC Score IBM

$$\text{CRQC Score} = \left(\frac{1400}{1000} \right) \cdot \left(\frac{10^{12}}{10^{12}} \right) \cdot \left(\frac{10^6}{10^6} \right) = 0.2 \cdot 1 \cdot 1 = 0.2$$

Based on IBM's published roadmap, the "Starling" system will feature:

- Logical Qubit Capacity (LQC): 200
- Logical Operations Budget (LOB): 1×10^8
- Quantum Operations Throughput (QOT): Estimated at 1×10^6 operations/second

This raw score seems low at 0.00002, but IBM's roadmap explicitly targets RSA-2048 factoring capability by 2029 under optimistic assumptions., implying that the LOB and QOT figures will scale significantly towards:

- LOB: 1×10^{12}
- QOT: 1×10^6 or higher

This would give a revised estimate with the calculator of 0.2. This suggests IBM's system will be 20% of the way toward full RSA-2048 breakability, assuming linear scaling. However, IBM claims full capability by 2029, implying non-linear improvements in error correction and gate fidelity.

Google Quantum AI

Google's Quantum AI team has demonstrated that scaling surface-code logical qubits reduces error rates, a critical milestone for fault-tolerant quantum computing. Their experiments show that larger logical qubits outperform physical qubits in stability and their error-correction protocols operate below the surface-code threshold. These results validate the feasibility of scalable logical qubits and provide empirical evidence that error suppression improves with increasing code distance. Google's "Willow" processor further demonstrates exponential improvements in fidelity through LDPC-based architectures and real-time decoding. While Google has not published logical-qubit targets or cryptanalytic timelines, independent modelling based on their demonstrated scaling trends suggests that systems in the early 2030s could plausibly support on the order of 1,000-1,400 logical qubits under optimistic assumptions with a modelled scenario rather than a vendor-stated objective.

While Google has not published a full CRQC-aligned roadmap, their advances in LDPC codes and logical qubit lifetimes suggest they may reach:

- LQC: 1,000-1,400
- LOB: 10^{12}
- QOT: $10^6 - 10^7$

Figure 3 CRQC Score Google

$$\text{CRQC Score} = \left(\frac{200}{1000} \right) \cdot \left(\frac{1 \times 10^{12}}{10^{12}} \right) \cdot \left(\frac{1 \times 10^6}{10^6} \right) = 1.4 \cdot 1 \cdot 1 = 1.4$$

Estimated CRQC Score = 1.4, which exceeds the threshold for RSA-2048 factoring, suggesting Q-Day feasibility by 2030-2032, contingent on sustained scaling and operational stability.

QuEra

QuEra uses neutral atoms trapped by optical tweezers as qubits, arranged in flexible 2D and 3D arrays that provide natural scalability and high connectivity. Through the Rydberg blockade effect, QuEra achieves fast multi-qubit gates and dynamic reconfiguration, enabling both digital gate-based computation and

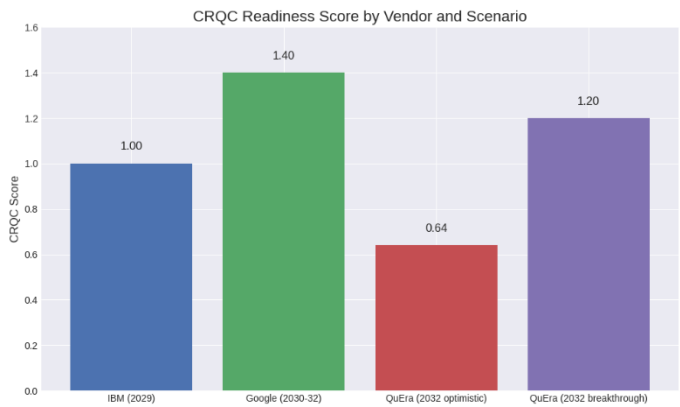
analogue quantum simulation. These architectural properties make neutral-atom systems strong candidates for large-scale error-corrected quantum computing. While QuEra has not published logical-qubit targets or cryptanalytic timelines, independent modelling based on demonstrated array sizes and gate fidelities suggests that neutral-atom platforms could plausibly support 1,000-1,200 logical qubits in the early 2030s under optimistic LDPC-based error-correction assumptions with a modelled scenario rather than a vendor-stated objective.

QuEra Neutral-Atom Hardware (2025).

- Array size: ~260 physical qubits (Gemini processor).
- Gate fidelity: ~99.5% two-qubit gates (Harvard/MIT/QuEra collaboration).
- Coherence times: 10-100 μ s typical for Rydberg states.
- SPAM error: ~1-2% (academic benchmarks).
- Decoder latency: not yet published; industry expectation sub milliseconds with learned decoders.

Taking these two estimations together they suggest Q-Day feasibility may be achievable within 5-7 years, contingent on sustained progress.

Figure 4 CRQC Readiness Timeline by vendor.



By aligning benchmarks with cryptanalytic workloads, CRQC provides a defensible forecasting tool for policymakers anticipating Q-Day. The proposed framework

highlights the need for post-quantum cryptography migration and the need for proactive standards adoption.

While IBM's 2029 roadmap provides a useful anchor for modelling early fault-tolerant systems, it does not represent a cryptanalytic timeline. Based on (Cain, 2026) blueprint, LDPC-based error-correction advances and QAI-accelerated decoding, this thesis models an earlier Q-Day window of mid-2027 to mid-2028 under optimistic but technically plausible assumptions. This represents a scenario for risk-governance planning rather than a prediction of vendor capability.

Quantum AI and Its Impact on CRQC Readiness

The integration of Quantum AI (QAI) into quantum computing architectures is poised to significantly accelerate progress toward CRQC. The timelines in this section are modelled under optimistic assumptions. Traditional projections of Q-Day have relied on hardware-centric scaling of logical qubits and error correction. QAI introduces a shift by enhancing the efficiency, adaptability and throughput of quantum systems across all three CRQC dimensions: Logical Qubit Capacity (LQC), Logical Operations Budget (LOB) and Quantum Operations Throughput (QOT).

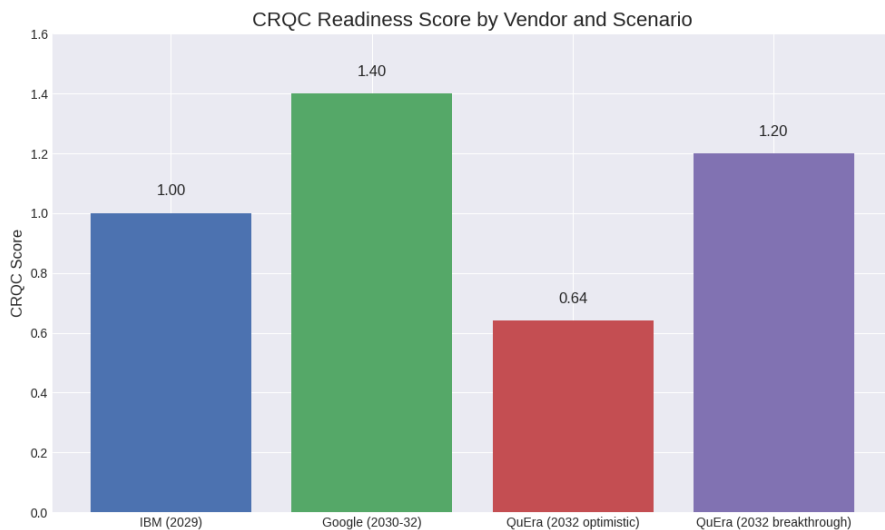
QAI contributes to increased LQC by enabling more efficient encoding strategies and adaptive qubit-layout optimisation. Through machine-learning and reinforcement-learning techniques, QAI can identify optimal configurations for logical qubits, reduce physical-to-logical overhead and tailor error-correction schemes to hardware-specific noise profiles. This is particularly impactful for low-density parity-check (LDPC) codes, where QAI can assist in discovering sparse, high-threshold code structures that are otherwise computationally intractable to design manually.

In terms of LOB, QAI enhances the depth of quantum circuits by learning to mitigate correlated errors, optimise gate scheduling and dynamically adjust circuit depth in response to real-time decoherence patterns. These capabilities extend the number of logical operations a system can perform before failure of a critical requirement for executing deep algorithms such as Shor's algorithm.

QOT, the rate at which logical operations are executed, is also improved through QAI-driven decoding strategies. Neural decoders and AI-assisted syndrome processing can significantly reduce the latency of error-correction cycles, enabling higher sustained throughput. This is essential for meeting the CRQC benchmark's requirement of approximately 10^6 logical operations per second to factor RSA-2048 within one week.

To quantify the impact of QAI on CRQC readiness, a comparative projection was modelled over the period 2025-2035. In a baseline scenario without QAI, CRQC scores increase gradually, reaching the RSA-2048 breakability threshold (CRQC = 1.0) by approximately 2032. In contrast, a QAI-enhanced trajectory achieves a CRQC score of 0.5 by 2029 and surpasses the threshold by 2030, reaching 1.4 by 2032. These values represent modelled scenarios rather than vendor-stated objectives. They suggest that QAI could advance Q-Day by up to three years, contingent on continued progress in hardware integration, decoder optimisation and scalable fault-tolerant architectures. In practical terms, QAI-enhanced systems can achieve the same CRQC score with fewer physical resources or reach higher scores earlier.

Figure 5 CRQC Readiness Score by Vendor



IBM (2029, modelled): IBM's roadmap targets early fault-tolerant prototypes by 2029. Under optimistic LDPC-based assumptions, such a system could support ~200 logical qubits, yielding a modelled CRQC ≈ 0.2 . This is not a vendor-stated objective.

Google (2030-2032, modelled): Extrapolating from Google's demonstrated logical-qubit scaling and LDPC decoding, early-2030s systems could plausibly support 1,000-1,400 logical qubits, corresponding to a modelled CRQC ≈ 1.4 . This is not a vendor claim.

QuEra (2032 optimistic, modelled): Neutral-atom platforms have demonstrated >1,000 physical qubits, but no logical-qubit counts. Under optimistic LDPC assumptions, ~1,000 logical qubits yields a modelled CRQC ≈ 0.64 .

QuEra (2032 breakthrough, modelled): A more aggressive scenario of ~1,200 logical qubits with full throughput yields a modelled CRQC ≈ 1.2 , crossing into CRQC readiness. This is a scenario, not a vendor projection.

QuEra

Baseline (no QAI)

- Assumes linear hardware scaling without AI-driven optimisation.
- CRQC Score reaches 1.0 by ~2032, based on IBM's roadmap and Google's LDPC scaling.

QAI-Enhanced

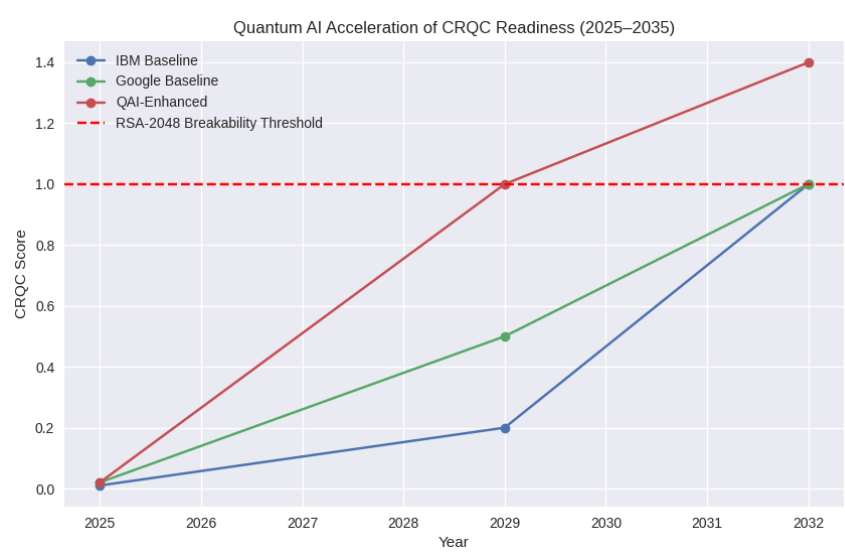
Assumes QAI improves each CRQC dimension:

- LQC: Better logical encoding and layout +40% capacity.
- LOB: Smarter error mitigation +2× circuit depth.
- QOT: Faster decoding and scheduling between +2 and 10× throughput.

These improvements are conservative extrapolations based on:

- Google's surface code fidelity scaling.
- IBM's LDPC code integration and modular architecture.
- AI-assisted decoding benchmarks such as neural decoders outperforming belief propagation.

Figure 6 Impact of QAI on Q-Day timeline.



All based around (Marin, 2024) Google’s Real-Time Decoding and QAI Integration, (IBM, 2025) IBM’s Relay-BP: AI-Optimised LDPC Decoder and (Swayne, 2024) Comparative Advances in LDPC vs Surface Codes.

Scope and Limitations of CRQC Readiness Scores

CRQC readiness scores are intended to support strategic and governance-level decision-making under conditions of profound uncertainty. They provide a structured means of assessing organisational exposure to cryptographically relevant quantum capability by evaluating technical, cryptographic and governance conditions that may render an organisation vulnerable should such capability emerge. Importantly, CRQC scores are not predictive guarantees, nor are they designed to function as deterministic forecasts.

Within this scope, CRQC scores may be used to compare relative preparedness across organisations, sectors, or time periods, enabling longitudinal assessment of improvement or degradation in quantum readiness. They are also suitable for identifying structural weaknesses in cryptographic implementations, key management practices and governance arrangements that increase susceptibility

to quantum-enabled compromise. Additionally, CRQC scores can inform scenario planning and investment prioritisation by highlighting areas where early intervention would reduce exposure under multiple plausible futures.

However, CRQC scores cannot be used to predict the timing or certainty of the arrival of a cryptographically relevant quantum computer. They do not provide assurances regarding the long-term security or insecurity of specific cryptographic algorithms, particularly given the evolving nature of quantum algorithms, error correction techniques and hybrid cryptanalytic approaches. Nor can CRQC scoring replace the need for cryptographic agility, continuous monitoring or adaptive governance mechanisms as standards and threat landscapes evolve.

Accordingly, CRQC should be understood as a decision-support mechanism rather than a forecasting instrument. Its value lies in enabling reasoned action in the absence of reliable probability estimates, rather than in providing definitive predictions about future quantum capability.

The worked examples illustrate how the CRQC model evaluates quantum-computing capability. The next step is to assess whether real-world architectures can meet these thresholds. The (Cain, 2026). blueprint provides the first empirical basis for doing so.

Empirical Validation of Accelerated Timelines: The 10,000-Qubit Blueprint

The CRQC readiness estimates presented earlier rely on extrapolated hardware projections and vendor roadmaps. A key limitation of such forecasting is its dependence on assumptions about future error correction, gate fidelities and architectural scalability. In March 2026, a landmark paper by Cain, Xu, King and colleagues at Oratoric and Caltech significantly reduced this uncertainty by providing the first publicly available, peer-reviewed blueprint for a fault-tolerant quantum computer capable of executing Shor's algorithm at cryptographically relevant scales (Cain, 2026).

Unlike earlier theoretical analyses, the Cain blueprint presents a concrete architectural design based on reconfigurable neutral-atom qubits—a platform already demonstrated to trap over 6,100 highly coherent atoms (Manetsch, 2025) and to perform below-threshold fault-tolerant operations (Bluvstein, 2025). This work reframes Q-Day from a speculative question of if and when to a more quantifiable question of how many qubits and how many days.

Key Findings and Their Implications for CRQC Readiness

The central contribution of the Cain blueprint is a dramatic reduction in resource requirements. Using high-rate quantum LDPC (qLDPC) codes with encoding rates of ~30%, the authors show that Shor’s algorithm can be executed with:

- RSA-2048 factoring: 10,000–14,000 physical qubits
- ECC-256 discrete logarithms: 11,961 physical qubits

This represents a two-order-of-magnitude reduction compared to earlier surface-code estimates requiring millions of physical qubits (Gidney, 2019; Fowler et al., 2012).

Equally significant are the projected runtimes under plausible assumptions. Using a conservative 1 ms stabiliser cycle time—consistent with current neutral-atom demonstrations—the blueprint estimates:

- ECC-256: 10 days with ~26,000 physical qubits
- RSA-2048: 97 days with ~102,000 physical qubits

These runtimes are derived from validated code performance, explicit surgery protocols and high-rate distillation techniques, simulated under depolarising noise at $p = 0.1\%$, a threshold already demonstrated experimentally (Bluvstein, 2025).

Mapping the Blueprint to the CRQC Benchmark

The Cain blueprint provides concrete targets for each dimension of the CRQC model:

Logical Qubit Capacity (LQC)

Codes with parameters $[[5278, 1480, \leq 24]]$ yield 1,480 logical qubits with per-cycle block failure rates below 10^{-11} , meeting or exceeding the CRQC threshold of $\sim 1,400$ algorithmic logical qubits.

Logical Operations Budget (LOB)

High-rate surgery and up to 1,160 parallel Toffoli operations demonstrate that the required $\sim 10^{12}$ logical operations are achievable within practical timeframes.

Quantum Operations Throughput (QOT)

A 1ms stabiliser cycle combined with parallelised carry-lookahead adders provides sustained throughput sufficient to complete the full factoring algorithm within the stated runtimes.

When these figures are entered into the CRQC scoring model, the result is unambiguous:

a system meeting the Cain specifications achieves a CRQC score of ≥ 1.0 , indicating practical capability to break RSA-2048 and ECC-256 within weeks or days, not decades.

Implications for Quantum-Risk Governance

The Cain blueprint demonstrates that:

- the resource barrier to CRQC is far lower than previously assumed
- ECC-256—used in TLS 1.3, blockchain systems and financial authentication—can be broken in days
- RSA-2048 can be broken in weeks, not years
- high-rate LDPC codes eliminate the need for millions of physical qubits
- Q-Day is now constrained by engineering, not theory

This blueprint provides the strongest empirical support to date for the thresholds used in the CRQC benchmark and establishes concrete targets for security architecture planning.

Global Preparations for Q-Day

United States: The U.S. has taken a leading role through NIST's Post-Quantum Cryptography (PQC) standardization process, which finalized Kyber, Dilithium and

SPHINCS+ as federal standards in 2024. Federal agencies are now required to begin migration, with compliance deadlines expected in the early 2030s. The White House has also issued executive memoranda directing agencies to inventory cryptographic assets and plan PQC transitions.

European Union: The EU is embedding quantum resilience into its Digital Europe Programme and European Quantum Communication Infrastructure (EuroQCI). Regulators are pushing for PQC adoption across critical sectors, with GDPR fines reinforcing the urgency of protecting sensitive data. The EU is also funding cross-border quantum networks to secure communications at a continental scale.

China: China has invested heavily in quantum communication networks, including satellite-based QKD experiments and is positioning quantum technology as a strategic national priority. While less transparent about PQC migration, its emphasis on sovereign quantum infrastructure reflects a geopolitical drive to achieve technological independence.

OECD and global regulators: International bodies such as the OECD are developing principles for responsible quantum innovation, focusing on privacy, digital security and equitable access. Regulators worldwide are imposing 2030–2035 deadlines for PQC migration, effectively setting a global clock for enterprises to act.

Post-Quantum Cryptography Extensions in TLS 1.3

Hybrid Key Exchange Approaches

Hybrid key exchange is a transitional cryptographic strategy that combines a classical key exchange algorithm, such as X25519 or ECDHE with a post-quantum algorithm. This dual approach is designed to ensure robust forward secrecy and resilience against both classical and quantum attacks. If one of the algorithms were to be compromised, the other would still offer protection for the session key. This layered defence model is particularly useful during the migration period toward post-quantum cryptography, where complete trust in the performance and interoperability of post-quantum algorithms is still developing. As (Campagna, 2025) explains, hybrid models offer a pragmatic route to enhance security without abandoning the well-tested reliability of existing elliptic-curve-based schemes.

Hybrid key exchange, in this context, means the use of two (or more) key exchange algorithms based on different cryptographic assumptions, e.g., one traditional algorithm and one next-gen algorithm, with the purpose of the final session key being secure as long as at least one of the component key exchange algorithms remains unbroken. When one of the algorithms is traditional and one of them is post-quantum, this is a Post-Quantum Traditional Hybrid Scheme.

Campagna 2025

A practical pairing would be X25519, a widely used elliptic-curve Diffie-Hellman key exchange, combined with Kyber, the lattice-based KEM standardised by NIST in 2024. This hybrid pairing has now been deployed in several experimental implementations and serves as a model for future secure communication protocols. X25519 ensures compatibility and performance, while Kyber provides quantum resistance. Together, they mitigate the risk of session key exposure, even in the face of quantum adversaries and offer a path forward for cryptographic agility in internet-scale systems.

Another hybrid configuration being evaluated is X25519 + FrodoKEM. FrodoKEM (short for Frodo Key Encapsulation Mechanism) (Bos, 2017) is a post-quantum cryptographic algorithm designed to be secure against attacks from both classical and quantum computers. It is based on the Learning With Errors (LWE) problem, a well-studied hard problem in lattice-based cryptography. Unlike some other lattice-based schemes (e.g., those relying on structured lattices like NTRU or Ring-LWE), FrodoKEM uses standard (unstructured) lattices, which are more conservative and better understood from a security standpoint.

FrodoKEM is regarded as a conservative choice with strong theoretical security guarantees. However, its computational and bandwidth overhead is higher compared to Kyber, making the X25519 + FrodoKEM pairing better suited to use cases that prioritise long-term confidentiality over performance. Research efforts in

this area focus on improving FrodoKEM's efficiency while ensuring seamless integration with existing TLS stacks and secure transport protocols.

The combination of X25519 + BIKE by Bikesuite is also under investigation, particularly in contexts where low-latency, hardware-optimised operations are desirable. BIKE, a code-based scheme, is known for its speed in hardware implementations and when paired with X25519, offers a strong blend of backward compatibility and quantum safety. BIKE (short for Bit Flipping Key Encapsulation) is a post-quantum cryptographic algorithm based on code-based cryptography, specifically using quasi-cyclic moderate density parity-check (QC-MDPC) codes. It is designed as a Key Encapsulation Mechanism (KEM). However, as with all hybrid schemes, careful attention must be paid to implementation details, including key derivation and cryptographic binding, to prevent downgrade attacks or security regressions.

An earlier and notable example of hybrid key exchange in practice was CECQP2, (Cloudflare, 2019) an experimental implementation introduced by Google in Chrome, which paired X25519 with HRSS (a code-based algorithm from the NTRU family). Deployed in 2018, CECQP2 was used to test the feasibility of hybrid post-quantum TLS in real-world browser scenarios. Although not adopted as a permanent feature, it provided critical insights into the performance, stability and user impact of hybrid cryptography at scale.

Fully Post-Quantum Key Exchange (Experimental)

Several cryptographic implementations have been developed that rely solely on post-quantum algorithms for key encapsulation mechanisms (KEMs), reflecting the ongoing effort to future-proof digital security against the threat posed by quantum computing. Despite significant progress, these implementations are still largely in the experimental phase. Performance bottlenecks and compatibility challenges with existing protocols and infrastructure continue to hinder widespread adoption of these standalone post-quantum solutions.

Kyber, a lattice-based KEM, was officially selected by NIST in August 2024 as the first post-quantum key encapsulation algorithm to be standardised. Its selection marks a major milestone in the global transition to quantum-safe cryptography. Kyber is valued for its strong security properties, efficient performance and suitability for a wide range of applications—from secure web protocols to embedded systems. Despite its standardisation, implementations that use Kyber exclusively (without hybrid or classical fallbacks) are still undergoing testing, as developers work to resolve interoperability issues and ensure smooth integration into real-world systems.

NTRU, another well-established lattice-based KEM, has also been a strong contender in the post-quantum space. It offers a good balance of speed and security and benefits from decades of academic scrutiny. However, its use as a standalone PQ mechanism remains limited in practice. Ongoing research focuses on optimising NTRU for constrained devices and ensuring its compatibility with emerging standards and deployment architectures.

FrodoKEM is known for its conservative design, based on standard lattice problems without additional algebraic structure, making it an attractive option for high-assurance applications. However, this approach leads to larger key sizes and slower performance compared to structured lattice-based schemes like Kyber. Consequently, standalone FrodoKEM deployments are still mostly experimental, as developers assess the trade-off between its robust security model and the practical limitations it imposes on system resources.

Implementations and Industry Testing

Open Quantum Safe (OQS) is an open-source project aimed at supporting the transition to post-quantum cryptography. One of its key initiatives is maintaining a fork of the widely used OpenSSL library, which has been extended to support a range of post-quantum (PQ) algorithms. Among the algorithms integrated into this modified version are Kyber and Dilithium, two of the leading candidates in the NIST Post-Quantum Cryptography standardisation process. The OQS project serves as a vital testing ground for developers and researchers, enabling them to

experiment with and assess the performance and security of post-quantum algorithms within a familiar cryptographic framework.

In 2019, Cloudflare and Google collaborated on a high-profile deployment of experimental hybrid key exchange mechanisms using Kyber, one of the lattice-based algorithms recommended for post-quantum cryptography. This initiative demonstrated the practical feasibility of integrating PQ algorithms into real-world internet infrastructure. By combining Kyber with classical elliptic curve techniques, the hybrid approach ensured backward compatibility while offering quantum-resistant security. The experiment served as a valuable proof of concept, highlighting both the technical challenges and the performance implications of deploying PQ algorithms at scale.

Google Chrome also took a proactive stance in this space with the launch of its CECPQ2 experiment in 2018. This involved trialling a hybrid Transport Layer Security (TLS) handshake that combined the traditional X25519 elliptic-curve Diffie-Hellman key exchange with HRSS (Hülsing-Rijneveld-Schanck-Scholten), a code-based post-quantum algorithm. The primary goal was to measure performance impacts and gain insights into how well hybrid key exchanges could be supported in widely deployed browser environments. While not a production feature, CECPQ2 provided useful data and paved the way for future developments in PQTLS.

Most recently, in 2025, Microsoft advanced the field by developing and evaluating a project called PQCrypto-VPN (Microsoft, 2025), which explored the application of post-quantum key encapsulation mechanisms in virtual private network-like encrypted tunnels. Their evaluations focused on FrodoKEM, a lattice-based scheme and SIKE (Super singular Isogeny Key Encapsulation), which was previously a candidate in the NIST competition but has since been deprecated due to cryptanalytic breakthroughs. Microsoft's research highlighted the real-world performance and integration considerations of deploying PQ algorithms in secure

networking environments, particularly in use cases where high security and compatibility are paramount.

LMS and XMSS Hash-Based Signature Standards

LMS (Leighton-Micali Signature) and XMSS (eXtended Merkle Signature Scheme) are both stateful, hash-based digital signature schemes that are designed to be secure against attacks by quantum computers. Unlike traditional schemes such as RSA or elliptic curve cryptography, which rely on number-theoretic problems, LMS and XMSS derive their security solely from the properties of cryptographic hash functions. Specifically, preimage resistance, second-preimage resistance and collision resistance. This makes them inherently resistant to quantum attacks like Shor's algorithm.

LMS is based on the use of a Merkle tree, where each leaf node contains a one-time signature (OTS) key and the root of the tree acts as the public key. The specific OTS scheme used in LMS is called LM-OTS, which also relies on hash functions. Each time a message is signed, a new leaf is used and the signer must maintain an internal counter (state) to ensure that the same OTS key is never reused. Reusing a key would compromise the entire scheme. LMS is standardised in NIST SP 800-208 (NIST, 2020) and is considered suitable for applications like firmware signing and constrained devices where signature verification speed and compact key sizes are important.

XMSS is structurally similar to LMS in that it also uses a Merkle tree with one-time signature keys at the leaves. However, it employs a more advanced OTS method called WOTS+ (Winternitz One-Time Signature Plus), which improves performance and offers stronger security proofs. XMSS supports forward security, meaning that even if a current key is compromised, previous signatures remain secure. This is especially useful for long-lived devices where key compromise is a realistic concern. XMSS is also part of NIST SP 800-208 and has been formally standardised by the IETF as RFC 8391.

Defence-in-Depth Security Measures

Zero Trust Architecture

Adopting a Zero Trust Architecture (ZTA) is critical in reducing reliance on encryption as the sole line of defence. At its core, Zero Trust mandates continuous verification of users, devices and services, ensuring that access is granted only when explicitly authorised and continuously validated. Implementing the principle of least privilege further restricts access to only the necessary resources with best practice with Active Directory (AD) being RBAC and then privilege access management (PAM)

Strong identity and access management (IAM) underpins the effectiveness of Zero Trust. By enforcing multi-factor authentication (MFA), organisations can mitigate the risk of credential theft and unauthorised access. This layered approach to authentication ensures that even if one factor is compromised, malicious actors are still unable to penetrate critical systems without passing additional verification steps.

Resilient Network Security

To support the network, organisations should implement network segmentation and micro-segmentation. These strategies compartmentalise the network into isolated zones, limiting lateral movement and containing the potential damage of a cryptographic compromise. This is especially important in scenarios where traditional encryption algorithms may become obsolete in the face of quantum decryption capabilities.

In addition, secure communication channels should be reinforced using encrypted traffic analysis tools and the deployment of quantum-safe VPNs. To ensure the confidentiality and integrity of data in transit, whilst providing early detection of anomalous or potentially malicious traffic patterns, which may be an indicator of compromise (IOC).

Data Protection & Confidentiality Measures

Encryption as seen earlier is facing increased risk and attacks such as HNDL meaning, supplementary data protection techniques such as tokenisation and data masking are essential. These methods render sensitive information unintelligible, even if underlying encryption is broken, thereby offering an additional safeguard for critical data assets.

End-to-end encryption (E2EE) should remain a cornerstone of secure communications but should be implemented using protocols that are ready for post-quantum cryptography (PQC) using NIST standards where possible or a next best alternative if not due to legacy or technical constraints. Organisations need to start the process of moving towards PQC-ready standards to ensure data remains secure not only now, but also in the future, when quantum decryption becomes feasible.

Finally, strong data governance policies are vital for identifying, classifying and protecting high-value information. This includes proactive defences against HNDL threats, where adversaries collect encrypted data today in anticipation of decrypting it with quantum tools in the future. Consideration also needs to be given to asset classification. The classification is always based on the sensitivity of the data being process and the impact on the organisation should that asset is not available as part of the business impact analysis (BIA) of the system or service.

Continuous Monitoring & Threat Intelligence

Organisations must establish threat intelligence and monitoring focused on advancements in quantum computing and potential cryptographic vulnerabilities. This will involve actively tracking developments in post-quantum cryptographic research, state-sponsored capabilities and emerging exploits that could undermine current encryption standards. AN organisation needs to understand the fragility of its infrastructure and the evolving protection required for quantum threats.

Quantum risk assessments should increasingly be integrated into the broader organisational security framework. This includes the use of quantum-related threat modelling and impact analysis into existing risk management processes, organisations can identify vulnerable systems, prioritise mitigations and plan strategic investments in quantum-safe technologies. This approach ensures that quantum risks are treated with the same rigour as conventional cybersecurity threats.

Policy & Compliance Considerations

As the regulatory landscape evolves to address the implications of quantum computing, organisations must ensure their cryptographic practices with emerging standards and guidelines. This includes using to frameworks such as the National Institute of Standards and Technology's (NIST) Post-Quantum Cryptography guidance, the NSA's Commercial National Security Algorithm (CNSA) Suite 2.0, the Federal Information Processing Standards (FIPS) and the European Telecommunications Standards Institute's (ETSI) Quantum-Safe Cryptography specifications. These need to be aligned to the organisation context, goals and strategy.

Effective governance policies are essential to guide an organisation's cryptographic transition strategy. These policies should clearly define the roadmap for adopting quantum-resistant algorithms, procedures for managing legacy cryptography and incident response plans in the event of a cryptographic failure or compromise.

Finally, education and awareness play a critical role in fostering organisational readiness. Key stakeholders including executive leadership, technical teams and third-party parties need to be educated on the risks posed by quantum as well as understanding our quantum works as that helps understand the threat it possesses. Security training programmes should be updated to include post-quantum threat scenarios, mitigation strategies and best practices for maintaining cryptographic agility. Building a shared understanding of quantum risks across the organisation

so it is not being undertaken in a silo with involvement of all stakeholders and business units.

Quantum Risk Mitigation Scenario

In this purely hypothetical scenario on mitigating quantum threats in a defence environment to ensure secure military satellite communications to demonstrate potential mitigations to emerging quantum computing threats. To do this DoD has initiated a project to secure military satellite communications (SATCOM) against adversaries capable of breaking classical encryption. The DoD's current satellite infrastructure, used for intelligence gathering, battlefield coordination and secure diplomatic communications, relies on traditional RSA and ECC-based cryptographic protocols. With the rapid advancements in quantum computing, particularly from state-backed adversarial nations, there is an increasing risk that encrypted transmissions could be intercepted today and decrypted later. Posing a HNDL risk. We will take this scenario and plug it into the Q-SLICE™ threat model in the next chapter.

Scenario

This is a fictional scenario which goes through adversaries intercepting satellite communications (SATCOM) in order to use quantum computing power to decrypt.

Threat Landscape

Adversaries have been observed deploying advanced signal interception technologies, capable of passively collecting encrypted SATCOM transmissions over long periods. Intelligence reports suggest that these actors are investing heavily in quantum research, aiming to develop decryption capabilities within the next decade. If successful, they could gain access to classified military movements, weapons system telemetry and strategic communications between allied forces.

Furthermore, quantum-enabled cyber-attacks could target the command and control (C2) infrastructure, either through breaking cryptographic keys used for authentication or via firmware tampering on satellite ground stations. Without immediate action, the defence strategic communications framework could be

severely compromised, leading to intelligence leaks, disrupted operations and potential battlefield disadvantages.

Phase 1: Post-Quantum Cryptographic Migration

The first phase of Operation Quantum Protect involves migrating all classified satellite communications to quantum-resistant encryption standards. The DoD adopts CRYSTALS-Kyber for key exchange and CRYSTALS-Dilithium for digital signatures, aligning with NSA CNSA 2.0 guidelines and NIST PQC standards. This ensures that even if adversaries collect encrypted data, they will be unable to decrypt it, even with large-scale quantum computers.

Additionally, the defence contractor responsible for SATCOM hardware integrates PQC-compatible firmware and secure boot mechanisms to prevent unauthorised modifications to the cryptographic systems onboard the satellites. Ground stations are equipped with quantum-safe hardware security modules (HSMs) to manage encryption keys securely, ensuring crypto agility in case of future updates or cryptographic vulnerabilities.

Phase 2: Implementing Quantum Key Distribution (QKD)

To further secure key exchanges between satellites and ground stations, the DoD deploys Quantum Key Distribution (QKD) on select high-priority geostationary military satellites. Using entanglement-based QKD, secure keys are generated and transmitted in a way that any interception attempt is immediately detectable, as per the principles of quantum mechanics.

The DoD collaborates with national research laboratories and defence contractors to establish trusted-node architectures, ensuring quantum-secured links for the highest levels of classified communications. While QKD is still being evaluated for scalability, it is initially deployed for nuclear command and control (NC2) and cryptographic key management functions.

Phase 3: Zero Trust Implementation for SATCOM Infrastructure

Given the risk of cyber-attacks on ground stations and control networks, the DoD enforces Zero Trust Architecture across its SATCOM environment. This includes:

- **Micro-Segmentation** – Network segmentation isolates critical military assets, ensuring that a breach in one domain does not compromise the entire SATCOM infrastructure.
- **Quantum-Safe Authentication** – Cryptographic certificates used for authenticating personnel and systems are replaced with post-quantum digital signatures.
- **Continuous Monitoring & Threat Intelligence** – AI-powered anomaly detection systems are deployed to monitor for cyber intrusions or unauthorised satellite command attempts. Additionally, secure air-gapped environments are used to store and process the most sensitive mission data, further mitigating the risk of adversarial decryption.

Phase 4: Red Teaming & Future-Readiness

To validate the effectiveness of the new quantum-resistant SATCOM security framework, the DoD conducts red teaming exercises simulating quantum-enabled cyber-attacks. The scenarios would be where simulated adversaries attempt to compromise military satellite encryption using simulated quantum decryption models.

- Launch cyber-physical attacks on ground stations by infiltrating defence contractors.
- Use of AI powered malware to exploit cryptographic vulnerabilities in legacy systems.

The insights gained from these tests are used to help refine operational procedures, improve crypto agility and enhance cyber resilience. Additionally, the DoD establishes a Quantum Threat Intelligence Unit, responsible for monitoring advancements in adversarial quantum computing and adapting mitigation strategies accordingly.

Q-SLICE



Purpose and Scope

Q-SLICE™ is a quantum-specific threat model designed to identify, categorise and reason about security failures that arise from quantum computation and quantum-adjacent systems. Its purpose is not to replace existing cyber threat models, but to address a category of risks that classical frameworks are structurally incapable of representing.

Traditional threat models assume deterministic systems, stable execution environments and reversible compromise. Quantum systems violate all three assumptions.

While quantum risk is often discussed through HNDL the same temporal asymmetry applies to integrity, trust and long-lifecycle systems. Q-SLICE is deliberately designed for systems, assets and trust artefacts across any quantum-era temporal threat, whether the risk manifests as future decryption, future forgery, collapse of trust chains, or the delayed exploitation of unpatchable infrastructure. This ensures that Q-SLICE remains applicable beyond confidentiality-centric scenarios and can be used consistently to prioritise quantum risk across data, software, identity and cyber-physical systems throughout their operational lifetime.

Why Classical Threat Models Are Insufficient

Frameworks such as STRIDE and MITRE ATT&CK are optimised for software-driven, stateful and observable systems. They struggle to represent threats where:

- System behaviour is probabilistic rather than deterministic
- Failure emerges from physical-layer instability rather than logic flaws
- Measurement itself alters system state
- Data compromise is permanent and retroactive

As a result, quantum threats are often either ignored or incorrectly mapped to classical categories, creating a false sense of security.

Q-SLICE organises quantum threats into six categories, each representing a distinct class of failure mode:

Q - Quantum Computational Threats: Threats arising from quantum capability that undermines classical cryptography.

S - State Integrity Threats: Failures related to quantum state manipulation, collapse, or decoherence.

L - Lifecycle and Longevity Threats: Risks introduced by long data lifetimes and Harvest Now, Decrypt Later (HNDL) attacks.

I - Infrastructure and Implementation Threats: Vulnerabilities in quantum hardware, control systems and hybrid environments.

C - Control and Governance Threats: Failures caused by inadequate organisational oversight, policy, or decision-making.

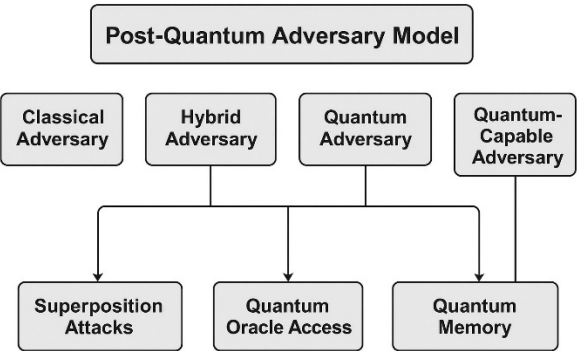
E - Ecosystem and Externality Threats: Systemic risks emerging from supply chains, dependencies and geopolitical factors.

Each category represents a class of threats that must be governed differently from classical cyber risks.

The following chapters provide a detailed breakdown of each Q-SLICE category, including realistic attack scenarios and detection implications.

Q-SLICE is designed for use by security architects, risk analysts and threat modellers to help identify and assess threats in a quantum-capable or a quantum-resilient environment. It has been based on a similar concept to STRIDE where each letter corresponds to a specific class of threat. These categories have been designed to blend classical concerns with quantum-specific challenges now and in the future. Q-SLICE can be used alongside any threat model including STRIDE, PASTA, VAST or MITRE ATT&CK as it is designed to be fully interoperable and adds an extra layer of consideration to threat modelling.

Figure 7 Theoretical example of a Pos- Quantum Adversary Model



While STRIDE is foundational in teaching security design and evaluating threats at a system architecture level, it does not account for:

- Cryptanalytic advances from quantum algorithms (Shor, Grover)
- Legacy crypto exposure (HN DL)
- Hybrid attack surfaces in quantum-classical integrations (TLS, IPsec, QKD, IBM Q, Amazon Braket).

STRIDE lacks abstraction layers necessary to express modern or emerging threats, especially those introduced by hybrid computing models or future cryptanalytic tools.

Shostack, 2014

Q-SLICE doesn't replace STRIDE it merely extends it. By combining them, you can ensure that your threat modelling process captures both traditional threats and those introduced by quantum. This dual perspective is essential for organisations planning long-term investments in cryptography and secure system design.

Q-SLICE is designed to plug the blind spots in current threat models, so the quantum threat is not overlooked or remain unconsidered. The consideration part will take time with organisations focused on AI other new technology and strategy. Quantum is a far-out technology for most without the understanding or expertise to consider the harm posed by quantum. It may be that an incident or risk due to a jump in quantum becomes the driver for greater focus. In security it is always better to be proactive as opposed to reactive hence starting to develop an easy to use and workable threat model ahead of time, with the time to mature as well. With Q-SLICE its categories reflect:

- Quantum attack vectors (QKD tampering, algorithmic decryption)
- Trust boundary fragility in post-quantum infrastructure
- AI + Quantum convergence risks
- Physical-layer threats unique to quantum coherence

These align with risk areas raised back in 2022 by NIST:

Quantum computing will undermine current cryptographic assumptions, creating urgent need for security design paradigms that incorporate post-quantum analysis.

Chen et al., NIST PQC Round 3 Status Report, 2022

Q-SLICE enables organisations to model quantum-relevant threats in a structured and accessible way, facilitating proactive risk mitigation and alignment with emerging standards for quantum security readiness. It will also support the **QUANTA** (Quantum Universal Architecture for Next Gen Threat Assurance™) framework covered in the next chapter. This is intended to be a modular and scalable control framework designed to help organisations prepare for, defend

against and transition through the emerging threats posed by quantum computing. It will recognise that the rise of quantum computing presents a critical risk to widely deployed cryptographic systems and responds with a practical, actionable set of controls to support threat modelling using Q-SLICE.

Quantum Exploitation

Quantum Exploitation refers to a class of emerging threats in which adversaries using quantum computational capabilities. Particularly quantum algorithms, to undermine classical security assumptions, breach cryptographic defences and extract actionable intelligence from complex datasets at unprecedented speeds. These threats are not merely theoretical; they represent a paradigm shift in adversarial modelling, requiring a rethinking of both defensive architectures and operational risk.

Cryptographic Disruption

- **Shor's Algorithm** enables polynomial-time factorisation of large integers, rendering RSA, DSA and ECC vulnerable.
- **Grover's Algorithm** offers quadratic speedup for brute-force search, weakening symmetric encryption and hash functions by halving their effective security bit-length.
- **Quantum-enhanced collision** finding could compromise digital signatures and integrity checks, especially in blockchain and distributed ledger systems.

Hash Reversal and Integrity Attacks

- Quantum adversaries can reverse cryptographic hashes faster than classical brute-force methods, threatening password storage, digital forensics and blockchain immutability.
- Attacks on Merkle trees and hash-based structures may become feasible, undermining systems that rely on hash chaining for tamper-evidence.

Accelerated Data Analysis

Quantum machine learning (QML) and quantum-enhanced optimisation allow adversaries to:

- De-anonymise datasets by identifying patterns across high-dimensional data faster than classical clustering or regression.
- Infer hidden correlations in encrypted or obfuscated telemetry, enabling predictive targeting or behavioural profiling.
- Break privacy-preserving protocols like differential privacy or homomorphic encryption when quantum speedup reduces the entropy of noise distributions.

Adversarial Quantum Intelligence

- Quantum-enhanced adversarial reasoning could simulate multi-agent systems, predict defender responses and optimise attack paths in real time.
- Quantum game theory may allow attackers to model and exploit strategic weaknesses in defence posture, especially in cyber-physical systems and autonomous networks.

Operational Implications

- **Zero-day acceleration:** Quantum systems could rapidly test exploit payloads across virtualised environments, discovering vulnerabilities faster than defenders can patch.
- **Post-quantum lag:** Organisations slow to adopt post-quantum cryptography (PQC) may face retroactive compromise of encrypted archives once quantum decryption becomes viable.
- **Quantum-as-a-Service (QaaS):** Nation-states or cybercriminal syndicates may pay for quantum capabilities, democratising access to high-grade offensive tooling.

References

Cisco. (2025). *How post-quantum cryptography affects security and encryption algorithms*. Retrieved from <https://blogs.cisco.com/developer/how-post-quantum-cryptography-affects-security-and-encryption-algorithms>

Cybersecurity News. (2025). *Quantum computing threats*. Retrieved from <https://cybersecuritynews.com/quantum-computing-threats/>

European Journal of Information Technologies. (2025). *Quantum computing and cryptographic disruption*. Retrieved from <https://ej-compute.org/index.php/compute/article/view/146>

Simple Science. (2025). *Quantum attacks on cryptography: A growing threat*. Retrieved from <https://scisimple.com/en/articles/2025-09-11-quantum-attacks-on-cryptography-a-growing-threat--a37vmo8>

Springer. (2025). *Systematic review on quantum cybersecurity*. Retrieved from <https://link.springer.com/article/10.1007/s42452-025-07322-5>

Subversion of Trust

Subversion of Trust refers to adversarial strategies that target the foundational components of post-quantum and quantum-resilient systems. Particularly those mechanisms assumed to be inherently secure, such as quantum key distribution (QKD), quantum random number generators (QRNGs) and root-of-trust (RoT) anchors. These attacks exploit the implicit trust in hardware, entropy sources and cryptographic primitives, often bypassing algorithmic strength through manipulation, insertion or compromise at the implementation or supply-chain level.

Quantum Key Distribution (QKD) Manipulation

- **Side-channel exploitation:** Adversaries may exploit imperfections in photon detectors, timing channels or polarisation leakage to extract key material without violating the no-cloning theorem.
- **Trojan photon injection:** Malicious actors can inject faint light pulses into QKD systems to infer internal states or force predictable measurement outcomes.
- **Protocol downgrades:** Coercing systems into fallback modes such as BB84 with weak authentication. Enables person-in-the-middle attacks even in quantum-secure channels.

Quantum Random Number Generator (QRNG) Compromise

- **Entropy poisoning:** Hardware-based QRNGs can be subtly altered to produce biased or partially predictable outputs, undermining key generation, nonce creation and cryptographic salts.

- **Backdoored entropy sources:** Malicious firmware or embedded logic can simulate quantum randomness while leaking seeds or patterns to external observers.
- **Quantum-classical interface attacks:** Exploiting the transition layer between quantum entropy and classical processing such as Analogue-to-Digital Converter and firmware to inject determinism or extract state.

Root-of-Trust (RoT) and PQC Implementation Subversion

- **Hardware Trojans:** Malicious circuitry embedded in PQC accelerators, secure enclaves or TPMs can leak private keys, alter signature outputs or disable protections under specific triggers.
- **Fault injection and glitching:** Quantum-era attackers may use precise electromagnetic or photonic pulses to induce faults in lattice-based or code-based cryptographic operations, revealing secret states through differential analysis.
- **Compiler-level backdoors:** Subtle manipulations in PQC library compilation. Such as constant-time violations and branch prediction leaks which can introduce exploitable timing or cache side channels.

Supply Chain and Lifecycle Threats

- **Quantum-aware implants:** Nation-state actors may embed logic that activates only under quantum-specific conditions like entangled signal detection and quantum clock sync, evading classical detection.
- **Firmware subversion:** PQC firmware updates may be intercepted or subtly altered to degrade entropy, weaken key schedules or introduce covert channels.
- **Trust anchor erosion:** Attacks that compromise certificate authorities, secure bootloaders or firmware signing keys in post-quantum systems can cascade across entire infrastructures.

Strategic Implications

- **False sense of quantum immunity:** Systems relying on QKD or PQC may be perceived as unbreakable, leading to overconfidence and underinvestment in implementation security.

- **Invisible compromise:** Subversion attacks often leave no cryptographic trace, making attribution and detection extremely difficult without hardware forensics or quantum-aware anomaly detection.
- **Post-quantum disinformation:** Adversaries may seed doubt in the integrity of quantum-secure systems, eroding trust in national or commercial cryptographic standards.

References

Cyber Defense Magazine. (2025). *The quantum supply chain risk: How quantum computing will disrupt global commerce*. Retrieved from

<https://www.cyberdefensemagazine.com/the-quantum-supply-chain-risk-how-quantum-computing-will-disrupt-global-commerce/>

IoT World Today. (2025). *Quantum cybersecurity in 2025: Post-quantum cryptography drives awareness*. Retrieved from

<https://www.iotworldtoday.com/quantum/quantum-cybersecurity-in-2025-post-quantum-cryptography-drives-awareness>

National Cyber Security Centre. (2022). *Quantum networking technologies*.

Retrieved from <https://www.ncsc.gov.uk/pdfs/whitepaper/quantum-networking-technologies.pdf>

Palo Alto Networks. (2025). *Securing the quantum age*. Retrieved from

<https://www.paloaltonetworks.com/blog/2025/08/securing-the-quantum-age/>

PostQuantum. (2024). *Quantum technologies and cybersecurity: Threats and defenses*. Retrieved from

<https://postquantum.com/quantum-computing/quantum-cybersecurity/>

Legacy Exploitation

Legacy Exploitation encompasses adversarial strategies that capitalise on the temporal mismatch between current cryptographic deployments and future quantum capabilities. These attacks are rooted in the principle HNDL where encrypted data is intercepted and stored with the expectation that quantum computing will eventually render it decipherable. Simultaneously, attackers exploit lingering vulnerabilities in legacy protocols, systems and infrastructures that have

not yet transitioned to PQC, creating a dual threat vector of deferred compromise and immediate weakness.

Harvest Now, Decrypt Later (HNDL)

- **Strategic data hoarding:** Nation-states and advanced persistent threats (APTs) systematically collect encrypted communications, VPN traffic, satellite telemetry and diplomatic archives, anticipating future quantum decryption.
- **Targeted archival compromise:** Long-term sensitive datasets like genomic records, financial ledgers and government information are prioritised for interception due to their enduring intelligence value.
- **Quantum decryption pipelines:** Once scalable quantum systems emerge, adversaries can batch-process stored ciphertext using Shor's algorithm to recover RSA/ECC keys and decrypt historical payloads.

Legacy Protocol Vulnerabilities

- **Non-PQC TLS/SSL:** Many systems still rely on Diffie-Hellman, RSA or ECC-based key exchange in TLS, exposing session keys to future quantum compromise.
- **Outdated VPNs and email encryption:** Protocols like IPsec, OpenVPN and S/MIME often use legacy cryptography suites, making them vulnerable to both HNDL and active downgrade attacks.
- **Weak certificate chains:** Legacy PKI infrastructures may include expired, misconfigured or RSA-based certificates that can be exploited for impersonation or man-in-the-middle attacks.

Hybrid Transition Risks

- **Dual-stack fragility:** Systems implementing hybrid PQC + classical cryptography may inadvertently expose classical components to downgrade or side-channel attacks.
- **Migration lag:** Organisations slow to adopt PQC face a widening attack surface, especially in sectors with long data retention mandates like healthcare, finance, law enforcement and government.

- **False sense of security:** Use of longer RSA/ECC key sizes may delay compromise but does not prevent it; creating a dangerous illusion of quantum resilience.

Adversarial Strategy and Modelling

- **Temporal targeting:** Quantum-aware adversaries prioritise assets based on data longevity, cryptographic strength and strategic value over time.
- **Recursive compromise:** Once a legacy root key is broken, attackers can retroactively forge signatures, impersonate entities and rewrite historical records.
- **Quantum-enabled replay:** Decrypted legacy traffic can be replayed or modified to exploit systems still trusting old session formats or authentication tokens.

Strategic Implications

- **Data immortality risk:** Sensitive data encrypted today may be vulnerable decades later, especially if retention policies outlast cryptographic viability.
- **Post-quantum urgency:** The window for secure migration is shrinking; failure to adopt PQC now ensures future compromise.
- **Narrative potential:** Legacy exploitation can serve as a haunting mechanism. Where past secrets resurface; rewritten histories fracture trust.

References

Cyber Defense Magazine. (2025). *The quantum supply chain risk: How quantum computing will disrupt global commerce*. Retrieved from

<https://www.cyberdefensemagazine.com/the-quantum-supply-chain-risk-how-quantum-computing-will-disrupt-global-commerce/>

IoT World Today. (2025). *Quantum cybersecurity in 2025: Post-quantum cryptography drives awareness*. Retrieved from

<https://www.iotworldtoday.com/quantum/quantum-cybersecurity-in-2025-post-quantum-cryptography-drives-awareness>

National Cyber Security Centre. (2022). *Quantum networking technologies*. Retrieved from <https://www.ncsc.gov.uk/pdfs/whitepaper/quantum-networking-technologies.pdf>

Palo Alto Networks. (2025). *Securing the quantum age*. Retrieved from <https://www.paloaltonetworks.com/blog/2025/08/securing-the-quantum-age/>

PostQuantum. (2024). *Quantum technologies and cybersecurity: Threats and defenses*. Retrieved from <https://postquantum.com/quantum-computing/quantum-cybersecurity/>

Integrity Disruption

Integrity Disruption refers to adversarial techniques that compromise the reliability, authenticity or coherence of quantum and post-quantum systems. These attacks target the physical, informational and perceptual layers of trust—tampering with quantum states. Injecting faults into critical systems and manipulating AI-driven outputs using quantum-enhanced capabilities. Unlike traditional integrity breaches, these threats operate across entangled domains, where disruption can cascade through quantum networks, AI models and human cognition.

Quantum State Tampering

- **Qubit fault injection:** Adversaries may use precision electromagnetic pulses, cryogenic interference or laser-based perturbations to flip, decohere or bias qubit states during computation or transmission.
- **Entanglement disruption:** Attacks targeting entangled pairs such as in QKD or quantum teleportation can sever correlations, induce false measurements or collapse superpositions prematurely leading to corrupted outputs or failed authentication.
- **Quantum memory corruption:** Manipulating quantum RAM or storage systems can alter historical quantum states, undermining reproducibility and forensic integrity in quantum simulations or secure logs.

AI Model Poisoning and Quantum-Enhanced Manipulation

- **Quantum-accelerated deepfake generation:** Using quantum machine learning to exponentially improve realism, adversaries can create synthetic

media indistinguishable from reality. Weaponising perception, identity and truth.

- **Model inversion attacks:** Quantum algorithms can reconstruct training data from AI models faster than classical methods, exposing sensitive inputs or enabling targeted misinformation.
- **Adversarial perturbation:** Quantum-enhanced optimisation allows attackers to craft minimal input changes that cause maximal misclassification. Undermining autonomous systems, surveillance or decision engines.

Hybrid System Corruption

- **Quantum-classical interface exploitation:** Attacks on the boundary layer between quantum processors and classical control systems Digital to Analogue Converters (DACs), firmware and error correction modules can inject faults that propagate across both domains.
- **Fault-tolerant bypass:** Exploiting weaknesses in quantum error correction codes such as surface codes and stabilizer codes to induce undetectable logical errors or flip syndrome bits.
- **Quantum sensor spoofing:** Manipulating quantum-enhanced sensors such as gravimeters, magnetometers and atomic clocks. To produce false readings, affecting navigation, timing or environmental monitoring.

Strategic and Narrative Implications

- **Recursive collapse:** A single corrupted quantum state can ripple through entangled systems, triggering systemic failure or cascading misinformation.
- **Trust erosion:** In QUANTA modelling, integrity disruption represents a high-impact, low-detection threat class in which adversaries rewrite not just data, but belief systems.

References

Kundu, S., & Ghosh, S. (2025). *Adversarial data poisoning attacks on quantum machine learning in the NISQ era*. arXiv. <https://arxiv.org/abs/2411.14412>

PostQuantum. (2024). *Quantum hacking: Cybersecurity of quantum systems*.

Retrieved from <https://postquantum.com/post-quantum/quantum-hacking/>

Rishan Solutions. (2025). *Fault injection attacks in quantum chips*. Retrieved from

<https://rishandigital.com/quantum-computing/fault-injection-attacks-in-quantum-chips/>

Xu, C., Erata, F., & Szefer, J. (2024). *Quantum computer fault injection attacks*. IEEE

QCE. <https://ferhat.ai/publication/xu-2024-quantum/xu-2024-quantum.pdf>

Coherence Attacks

Coherence Attacks represent a class of quantum-specific physical and temporal threats that target the fragile stability of quantum systems. These attacks exploit the inherent sensitivity of qubits to environmental noise, timing discrepancies and measurement interference. Undermining the reliability, confidentiality and continuity of quantum operations. Unlike classical exploits, coherence attacks operate at the edge of physics, where minute perturbations can induce catastrophic decoherence, collapse entangled states or leak quantum information through side channels.

Decoherence Induction

- **Thermal noise injection:** Adversaries may subtly alter the thermal environment of quantum processors. Such as cryogenic drift and electromagnetic pulse shaping to accelerate decoherence and disrupt quantum computations.
- **Vibration and acoustic coupling:** Mechanical vibrations or acoustic waves can interfere with ion traps, superconducting qubits or photonic circuits; causing phase errors or loss of coherence.
- **Radiative interference:** Targeted radiation such as cosmic ray simulation and gamma bursts can induce spontaneous qubit flips or collapse entangled states mid-operation.

Measurement Manipulation

- **Detector blinding:** Similar to QKD attacks, adversaries may flood photon detectors with noise or spoofed signals to force predictable or false measurement outcomes.

- **Basis misalignment:** Manipulating the measurement basis such as polarisation and spin orientation can cause systematic errors in quantum readouts, leading to corrupted results or authentication failures.
- **Quantum Trojan readouts:** Malicious implants may subtly alter the timing or calibration of measurement circuits to leak partial quantum states during read/write cycles.

Side-Channel Timing Exploits

- **Qubit access profiling:** By monitoring timing variations in qubit activation, adversaries can infer computational patterns, gate sequences or key-dependent operations.
- **Cache-like leakage:** Quantum memory access patterns may reveal logical structure or entanglement topology, enabling reconstruction of quantum algorithms or sensitive states.
- **Pulse shape analysis:** Analysing control pulse shapes and durations can expose gate types, error correction routines, or cryptographic operations in progress.

Quantum Communication Interception

- **Quantum person-in-the-middle (QPitM):** Intercepting quantum channels (e.g., fibre-optic QKD links) and injecting entangled decoys or measurement probes to extract key material without detection.
- **Quantum relay hijacking:** Compromising intermediate nodes in quantum networks to reroute or delay entangled states, inducing desynchronisation or false authentication.
- **Quantum cloaking:** Using entangled camouflage or quantum noise injection to mask the presence of interception devices or spoof legitimate quantum signals.

Strategic and Narrative Implications

- **Fragility as a weapon:** Coherence attacks exploit the very property that makes quantum systems powerful fragility. Turning precision into a vulnerability.

- **Invisible sabotage:** These attacks often leave no classical trace, making forensic attribution nearly impossible without quantum-aware diagnostics.
- **Narrative resonance:** Coherence disruption can symbolise psychological fragmentation, memory collapse or reality distortion.

References

Cyber Defense Magazine. (2025). *The quantum supply chain risk: How quantum computing will disrupt global commerce*. Retrieved from

<https://www.cyberdefensemagazine.com/the-quantum-supply-chain-risk-how-quantum-computing-will-disrupt-global-commerce/>

Kundu, S., & Ghosh, S. (2025). *Adversarial data poisoning attacks on quantum machine learning in the NISQ era*. arXiv. <https://arxiv.org/abs/2411.14412>

National Cyber Security Centre. (2022). *Quantum networking technologies*.

Retrieved from <https://www.ncsc.gov.uk/pdfs/whitepaper/quantum-networking-technologies.pdf>

PostQuantum. (2024). *Quantum technologies and cybersecurity: Threats and defenses*. Retrieved from <https://postquantum.com/quantum-computing/quantum-cybersecurity/>

Rishan Solutions. (2025). *Fault injection attacks in quantum chips*. Retrieved from <https://rishandigital.com/quantum-computing/fault-injection-attacks-in-quantum-chips/>

Xu, C., Erata, F., & Szefer, J. (2024). *Quantum computer fault injection attacks*. IEEE QCE. <https://ferhat.ai/publication/xu-2024-quantum/xu-2024-quantum.pdf>

Ecosystem Abuse

Ecosystem Abuse refers to adversarial strategies that exploit the complex interdependencies, transitional fragilities and architectural blind spots within hybrid quantum-classical environments. These threats transcend isolated cryptographic or physical vulnerabilities. Instead targeting the systemic seams between technologies, protocols and organisational layers. As quantum capabilities are integrated into cloud platforms, AI pipelines and PQC modules, attackers gain new opportunities to manipulate, misalign, or destabilise the entire ecosystem.

Post-Quantum Transition Manipulation

- **Migration race conditions:** Adversaries exploit asynchronous or partial PQC adoption across systems. Targeting endpoints still using legacy crypto while upstream services assume quantum resilience.
- **Hybrid handshake exploitation:** Dual-mode protocols such as PQC + classical key exchange, may be coerced into classical fallback modes, enabling downgrade or man-in-the-middle attacks.
- **Standardisation lag:** Attackers may exploit early or non-standard PQC implementations. Especially those lacking side-channel resistance, constant-time execution or robust entropy sources.

Cloud-Hosted PQC Module Exploitation

- **Multi-tenant leakage:** In shared cloud environments, side-channel attacks such as cache timing or power analysis, may extract secrets from PQC hardware accelerators or virtualised cryptographic modules.
- **Container escape via quantum workloads:** Malicious quantum jobs may induce faults or resource contention in co-located containers, enabling privilege escalation or data exfiltration.
- **Quantum API abuse:** Poorly secured quantum-as-a-service (QaaS) endpoints may be manipulated to leak internal state, overconsume entanglement resources, or trigger denial-of-service conditions.

AI-Quantum Interdependency Exploits

- **Quantum-accelerated model inversion:** Attackers use quantum machine learning to reverse-engineer AI models hosted in hybrid environments, extracting training data or proprietary logic.
- **Adversarial quantum feedback loops:** Malicious inputs crafted via quantum optimisation can destabilise reinforcement learning agents or autonomous systems operating in quantum-enhanced environments.
- **Synthetic trust poisoning:** AI systems trained on quantum-generated data may inherit subtle biases or backdoors. Especially if adversaries control the quantum data generation pipeline.

Systemic Interdependency Attacks

- **Cross-domain pivoting:** Compromise in one domain like a classical orchestration layer. Can be used to manipulate quantum workloads, entanglement routing or PQC key management.
- **Orchestration layer subversion:** Exploiting Kubernetes, CI/CD pipelines, or quantum job schedulers to inject malicious quantum circuits or alter cryptographic parameters mid-deployment.
- **Quantum supply chain poisoning:** Inserting malicious logic into firmware, compilers, or SDKs used to build quantum-classical hybrid applications. Leading to widespread, hard-to-detect compromise.

Strategic and Narrative Implications

- **Illusion of compartmentalisation:** Ecosystem abuse thrives on the false belief that quantum and classical systems are cleanly separated. When in reality, they are deeply entangled.
- **Cascading failure potential:** A single point of compromise such as a cloud PQC module could ripple across authentication, AI inference and quantum communication layers.
- **Narrative resonance:** Ecosystem abuse can manifest as a slow-burn unravelling. Where trust fractures, systems misalign and protagonists uncover a breach not in code but in the architecture itself.

References

Baseri, Y., Hafid, A., & Lashkari, A. H. (2025). *Future-proofing cloud security against quantum attacks: Risk, transition and mitigation strategies*. arXiv.

<https://arxiv.org/pdf/2509.15653v1>

Bervice. (2025). *Preparing infrastructure for PQC integration to mitigate hybrid quantum attacks*. Retrieved from <https://blog.bervice.com/preparing-infrastructure-for-pqc-integration-to-mitigate-hybrid-quantum-attacks/>

GSMA. (2024). *Hybrid (QKD and PQC) security scenarios and use cases* [Whitepaper]. <https://www.gsma.com/newsroom/wp-content/uploads/IG.18-Hybrid-QKD-and-PQC-security-scenarios-and-use-cases-Whitepaper-v1.0-002.pdf>

Post Quantum. (2025). *Securing quantum computers - Threat at the quantum-classical interface*. Retrieved from <https://postquantum.com/post-quantum/securing-quantum-computers/>

Springer. (2025). *Quantum computing and cybersecurity: A rigorous systematic review of emerging threats, post-quantum solutions and research directions*. <https://link.springer.com/article/10.1007/s42452-025-07322-5>

Table 2 Q-SLICE Summary

Letter	Category	Description
Q	Quantum Exploitation	Threats where adversaries using quantum algorithms to break cryptographic systems, reverse hashes, or analyse large datasets exponentially faster.
S	Subversion of Trust	Manipulation or compromise of quantum key distribution (QKD), quantum random number generator, or root-of-trust components used in post-quantum systems. Includes hardware Trojans or backdoors in PQC implementations.
L	Legacy Exploitation	Attacks making use of long-term storage of intercepted encrypted data (harvest now, decrypt later) and weaknesses in legacy protocols not yet migrated to PQC.
I	Integrity Disruption	Tampering with quantum states, data or systems via physical attacks on qubits, entanglement disruption, or fault injection. Also covers quantum-enhanced deepfakes, AI model poisoning and manipulation.
C	Coherence Attacks	Quantum-specific physical threats including decoherence, measurement manipulation, side-channel timing of qubit read/write, or interception of quantum communications.

E	Ecosystem Abuse	Systemic threats across classical-quantum hybrid systems. Manipulating post-quantum transition processes, exploiting interdependencies in cloud-hosted PQC modules or exploiting AI-quantum technologies.
----------	-----------------	---

How to Use Q-SLICE

Asset/Component Identification

Catalogue your assets including cryptographic modules, keys, communication links, quantum APIs, entanglement channels, random number systems and legacy systems.

Map Each Asset Against Q-SLICE

For every component, ask:

- Can this asset be broken or weakened using a quantum algorithm? **(Q)**
- Does it rely on trusted sources vulnerable to compromise? **(S)**
- Is it dependent on or interoperating with legacy systems or crypto? **(L)**
- Can it be manipulated to produce incorrect outputs or perceptions? **(I)**
- Can its quantum states or communication channels be physically disrupted? **(C)**
- Is it exposed to complex supply chain or layered system abuse? **(E)**

Document Threat Scenarios

For each threat identified in the categories, develop threat narratives using attacker capability assumptions such as nation-state, corporate espionage, cybercriminals with quantum cloud access.

Mitigate and Monitor

Align mitigations with post-quantum controls such as PQC, QKD hardening, entropy validation, quantum-aware risk policies.

Basic Example

Asset: VPN Gateway using non PQC TLS

Q: Shor’s algorithm breaks RSA-2048 used in handshake.

- S:** Key exchange is not quantum-safe; trusted certs may be intercepted.
- L:** Legacy protocols in place, not migrated to PQC suite.
- I:** AI-based quantum spoofing could mimic VPN traffic.
- C:** Susceptible to interception during experimental QKD trials.
- E:** TLS stack dependencies on classical libraries without quantum assurance.

This simple scenario can then be addressed with suitable mitigations below some of which is based on experimental or emerging systems:

Q - Quantum Exploitation

Shor's algorithm breaks RSA-2048 used in handshake.

Mitigations:

- Replace RSA/ECC-based key exchange and signatures with NIST-approved post-quantum cryptographic algorithms like CRYSTALS-Kyber (ML-Kem) for KEM, Dilithium (ML-DSA) for signatures.
- Use hybrid key exchanges such as ECDHE + Kyber during migration to maintain backward compatibility.
- Implement forward secrecy to prevent retroactive decryption of past sessions.
- Use cryptographic agility to support multiple algorithm suites in TLS negotiation.

S - Subversion of Trust

Key exchange is not quantum-safe; trusted certs may be intercepted.

Mitigations:

- Transition to quantum-safe Public Key Infrastructure (PKI) by adopting PQC-enabled certificates using Dilithium or Falcon.
- Enforce certificate transparency logs and CT monitoring to detect rogue or compromised CAs.
- Isolate or sandbox any trust anchor integration between classical and quantum sources like QKD to PKI injection.
- Introduce multi-signature or dual-algorithm certificate chains as an interim safeguard.

L - Legacy Exploitation

Legacy protocols in place, not migrated to PQC suite.

Mitigations:

- Audit and deprecate vulnerable protocols such as TLS 1.0/1.1, IPsec with RSA, or SSH with RSA-1024.
- Enforce protocol version pinning and only allow TLS 1.3 with configurable PQC cipher suites.
- Automate configuration management (e.g., via Ansible, Chef) to enforce PQC readiness at scale.
- Regularly test cryptographic configurations with tools like testssl.sh and cryptosense.

I - Integrity Disruption

AI-based quantum spoofing could mimic VPN traffic.

Mitigations:

- Implement AI-resistant anomaly detection based on behavioural baselines (e.g. packet timing, protocol misuse).
- Use authenticated encryption with associated data (AEAD) for all VPN sessions to prevent tampering.
- Enable mutual authentication using PQC credentials to harden identity spoofing attempts.
- Deploy quantum-enhanced intrusion detection techniques such as quantum watermarking for traffic validation (experimental currently).

C - Coherence Attacks

Susceptible to interception during experimental QKD trials.

Mitigations:

- Implement QKD health checks, tamper detection and quantum bit error rate (QBER) monitoring.
- Use redundant classical key backup paths and automatic fallback mechanisms to ensure continuity if QKD is compromised.
- Physically secure all QKD links and apply optical shielding to fibres.

- Collaborate with vendors to certify QKD devices under emerging standards like ETSI GS QKD series.

E - Ecosystem Abuse

Issue: TLS stack dependencies on classical libraries without quantum assurance.

Mitigations:

- Migrate to cryptographic libraries with PQC support, such as OpenSSL 3.4, WolfSSL, Botan or Open Quantum Safe (liboqs).
- Conduct software composition analysis (SCA) to identify legacy crypto dependencies.
- Containerise TLS stacks and isolate them using hardware enclaves (e.g. Intel SGX) to limit lateral movement.
- Establish DevSecOps controls to validate algorithm use during CI/CD deployments and flag non-PQC-safe code.

Table 3 Q-SLICE Threat Summary

Q-SLICE	Risk Description	Recommended Mitigation (Shortform)
Q	RSA-2048 broken by Shor's	Migrate to PQC + hybrid key exchange
S	Non-PQC key exchange, interceptable certs	Adopt PQC certs, enforce CT logs
L	Legacy protocols still in use	Audit/deprecate, enforce TLS 1.3+, PQC cipher suites
I	AI + quantum spoofing VPN	AEAD, mutual auth, anomaly detection
C	QKD trial susceptible to interception	QBER monitoring, fallback paths, vendor QKD certification
E	TLS stack relies on legacy libraries	Use liboqs, software composition scanning, containerise crypto

SATCOM Quantum Risk Mitigation Scenario

Taking the SATCOM scenario from the previous chapter, we can apply Q-SLICE to it:

Q - Quantum Exploitation

Threats Identified:

- Adversaries intercepting SATCOM transmissions today to “harvest now, decrypt later” with Shor’s algorithm in the future.
- Breaking classical RSA or ECC-based authentication in C2 systems.
- Potential for accelerated cryptanalysis of legacy key exchanges once quantum computers mature.

Mitigations:

- Full migration to post-quantum cryptographic (PQC) standards (CRYSTALS-Kyber, CRYSTALS-Dilithium) for key exchange and signatures.
- Crypto-agile systems to swap in improved algorithms as new standards emerge.
- Red teaming specifically simulating future decryption capabilities to validate robustness.

S - Subversion of Trust

Threats Identified:

- Tampering with firmware on satellites or ground stations to weaken cryptographic implementation or inject backdoors.
- Compromise of supply chain components in quantum-safe HSMs.
- Unauthorised certificate issuance or misuse of legacy CA infrastructure vulnerable to quantum attacks.

Mitigations:

- Secure boot mechanisms with PQC-based signatures to enforce trusted firmware.
- Enhanced supply chain security vetting for defence contractors.
- Use of quantum-safe PKI with strong audit and transparency measures.
- Zero Trust controls ensuring continuous identity validation.

L - Legacy Exploitation

Threats Identified:

- Continued use of legacy encryption on older satellite systems not yet upgraded.
- Ground station systems supporting insecure fallback ciphers.
- “Harvest now, decrypt later” risk if older protocols are left operational during migration.

Mitigations:

- Rigorous audit and decommissioning of non-compliant cryptographic systems.
- Strict disabling of fallback to legacy cipher suites in TLS/VPN channels.
- Legacy system isolation via micro-segmentation in the Zero Trust Architecture.
- Crypto agility planning for updates as new PQC schemes are standardised.

I - Integrity Disruption

Threats Identified:

- AI-powered malware attacks on ground station networks, trained to evade detection.
- Adversarial manipulation of anomaly detection models using synthetic quantum-enhanced data.
- Potential spoofing of command messages to satellites.

Mitigations:

- Continuous monitoring with AI/ML models trained on adversarial inputs.
- Authenticated encryption for all command and telemetry channels.
- Regular red teaming with quantum-enhanced attack simulations.
- Strict access controls and logging to ensure non-repudiation of commands.

C - Coherence Attacks

Threats Identified:

- Physical-layer attacks on QKD channels (e.g. Trojan-horse attacks on optical equipment, eavesdropping attempts on entangled photon links).
- Tampering with quantum random number generators (QRNGs) used in satellite or ground station cryptographic modules.
- Side-channel attacks against experimental quantum devices.

Mitigations:

- Deploy QKD systems with active monitoring of quantum bit error rates (QBER) to detect interception.
- Physical shielding and tamper-detection on quantum communication links.
- Vendor certification and security testing for QRNG devices.
- Trusted-node architectures with robust physical security controls.

E - Ecosystem Abuse

Threats Identified:

- Exploiting the hybrid nature of SATCOM, where classical infrastructure remains interdependent with quantum-safe systems.
- Attacks on CI/CD pipelines managing PQC firmware deployments.
- Exploiting defence contractor networks to implant backdoors before launch.

Mitigations:

- Zero Trust Architecture with micro-segmentation to limit lateral movement.
- Secure, auditable DevSecOps pipelines enforcing cryptographic code reviews.
- Contractor cybersecurity requirements aligned to standards.
- Quantum Threat Intelligence Unit to monitor evolving quantum-capable adversary TTPs.

Table 4 SATCOM Scenario Summary

Q-SLICE	Threat Example	Mitigation Example
Q	Stored SATCOM intercepts broken via Shor’s algorithm	PQC migration (Kyber, Dilithium), crypto agility
S	Firmware tampering on satellite systems	Secure boot with PQC signatures, supply chain security
L	Legacy encryption still active on older satellites	Audit/decommission legacy systems, disable fallback
I	AI malware spoofing commands	Adversarially trained monitoring, AEAD for comms
C	Physical eavesdropping on QKD channels	QBER monitoring, shielding, certified QRNGs
E	CI/CD pipeline compromise in defence contractor	ZTA, DevSecOps security, micro-segmentation

Q-SLICE Testing

This chapter validates the Q-SLICE threat-modelling construct through a structured, empirical testing framework implemented using Qiskit and real IBM quantum hardware. By operationalising each Q-SLICE threat category as a measurable test case. Ranging from quantum exploitation and trust subversion to integrity disruption, coherence attacks, legacy exploitation and ecosystem abuse. The Q-SLICE Threat Harness demonstrates that quantum-enabled risks produce observable, quantifiable signatures rather than remaining abstract theoretical constructs. The testing approach establishes baselines, introduces controlled adversarial conditions and measures deviations using fidelity, leakage, bias, QBER and exploitation depth. This empirical evidence confirms that Q-SLICE is not only conceptually valid but also practically testable, reproducible and grounded in

quantum system behaviour, thereby strengthening its contribution as a defensible threat-modelling framework.

Testing of Q-SLICE uses a python script called `Q-SLICE_threat_harness.py` using (IBM, 2025) Qiskit. Qiskit is an open-source software development kit (SDK) for quantum computing, written in Python. It allows researchers, developers and students to design quantum circuits. Then simulate them on classical computers and even run them on real IBM quantum hardware.

With its accessibility and ease of use Qiskit was the best way to create a structured and reproducible means of evaluating the quantum threats defined in the Q-SLICE threat model. Each element of the model is mapped to a practical test case, allowing theoretical risks to be observed and measured in a controlled environment. By consolidating these tests into a single framework, the harness ensures consistency across experiments and provides a unified set of outputs that can be compared, analysed and evaluated. As well as being a lot quicker to perform a test across each Q-SLICE element.

The rationale for this approach is to establish clear baselines for each threat under ideal conditions and then to demonstrate how adversarial actions or systemic weaknesses manifest as measurable deviations. For example, algorithmic exploitation is evidenced by disproportionate probability distributions, trust subversion by elevated error rates and integrity disruption by leakage into unintended states. These results provide tangible indicators that the threat categories are not abstract but produce observable signatures when tested.

By putting each threat through a simulation, the harness bridges conceptual taxonomy with empirical validation. It offers a practical methodology for demonstrating how adversarial risks can be detected, quantified and understood. This structured testing framework therefore supports research by showing that the Q-SLICE model can be operationalised, tested and applied in practice, providing both methodological rigour and reproducible evidence.

The objectives of the Q-SLICE test harness are:

- **Validation:** To demonstrate that each Q-SLICE threat produces measurable outputs when tested.
- **Baseline Establishment:** To record idealised behaviours under controlled simulation conditions, providing reference points for comparison.
- **Adversarial Detection:** To show how deviations from baselines correspond to adversarial actions or systemic vulnerabilities.
- **Operationalisation:** To move Q-SLICE from a theoretical taxonomy to a practical, testable framework.
- **Reproducibility:** To provide a consistent, unified environment for repeated testing, ensuring results can be replicated and verified.

The contribution of this test harness lies in its ability to transform a conceptual threat model into a practical, reproducible artefact. By demonstrating that each Q-SLICE element can be instantiated and measured, the harness strengthens Q-SLICE in three ways. First, it checks the taxonomy by showing that adversarial risks produce observable signatures. Second, it provides a methodological tool that future researchers could adopt or extend when testing quantum threats in simulation or hardware. Third, it bridges theory and practice, ensuring that the Q-SLICE model is not only a conceptual framework but also a tested and testable methodology.

How the test was created

Each element of Q-SLICE was translated into a test fixture. Where threats manifest at the quantum layer (Q, S, I, C), circuits were implemented in Qiskit and subjected to adversarial conditions such as noise injection, intercept-resend attacks or decoherence models. For systemic threats (L, E), registry and environment comparison fixtures were used to capture protocol debt and hybrid ecosystem manipulation.

The harness (structured framework) was consolidated into a single Python class with methods for each threat. Running the harness produces structured outputs of

probability distributions, error rates, bias metrics and registry entries. These outputs serve as baselines under ideal simulation conditions and as indicators of adversarial activity when deviations are introduced.

Threat Mapping:

- **Quantum Exploitation (Q):** Grover's search proxy demonstrates algorithmic speedup. Then Q-SLICE Threat Harness v2 added Shor for a cryptographic collapse vector.
- **Subversion of Trust (S):** BB84 simulation shows elevated Quantum Bit Error Rate (QBER) under intercept-resend attack. Then Q-SLICE Threat Harness v2 added in a RNG bias test to extend the subversion of trust
- **Legacy Exploitation (L):** Registry fixture records continued use of RSA/ECC and migration debt.
- **Integrity Disruption (I):** Bell state leakage under noise evidence tampering.
- **Coherence Attacks (C):** Decoherence and readout errors skew randomness distributions.
- **Ecosystem Abuse (E):** Environment comparison highlights systemic manipulation across hybrid stacks.

Q-SLICE Threat Harness Python Code

The code and a user guide are available on Github for community use here:

<https://github.com/cyberjez/Q-SLICE>

Instructions

- Install and run Miniconda: <https://www.anaconda.com/download>
- Create an environment: `conda create --name quantum`
- Activate environment: `conda activate quantum`
- Install PIP to install packages: `conda install PIP`
- Install QISKIT: `Pip install Qiskit`
- Type in `cd .conda`
- Download Q-SLICE Threat Harness and put into `.conda` directory which is usually in the windows Users directory.

If you want to run dashboard version (Q-SLICE_dashboard) you will also need to:

- Type: *pip install matplotlib*

Qiskit Modules Used

- **QuantumCircuit:** This is the core object for building quantum programs. You use it to define qubits, apply quantum gates and add measurements. Every threat scenario in the harness starts with a QuantumCircuit.
- **Statevector:** Represents the full quantum state as a vector of amplitudes. It is being used as a fallback simulator, calculating probabilities directly when no backend is available.
- **Aer:** Provides high-performance simulators such as the statevector simulator and qasm simulator. Aer is preferred when available because it's faster and more feature-rich.
- **BasicAer:** A lightweight set of simulators bundled with Qiskit. Used as a fallback if Aer isn't installed or working, ensuring the harness can still run.
- **execute:** The unified function for running circuits on a backend. The harness checks if this is available and uses it to run simulations when possible.
- **NoiseModel, depolarizing_error, thermal_relaxation_error, ReadoutError:** These are tools for injecting artificial noise into simulations to mimic real hardware imperfections. Depolarising error randomises qubit states, thermal relaxation model's qubit decay over time and readout error simulates measurement mistakes.
- **GroverOperator:** Implements Grover's search oracle. It is being used to demonstrate quantum exploitation by amplifying a marked state.
- **Shor:** Shor's factoring algorithm. It is being used for attempts to factor integers (like 15) to show how classical cryptography could collapse under quantum attack. If unavailable, it will fall back to trial division.

The Grover quantum exploitation test builds a circuit using QuantumCircuit and applies the GroverOperator from the circuit library. It then runs the circuit on Aer or

BasicAer backends using execute or falls back to Statevector if no backend is available.

The Shor quantum exploitation test uses the Shor algorithm from `qiskit.algorithms` to factor integers. It requires execute and a backend to run and if those are not available it falls back to a classical trial division routine.

The BB84 subversion of trust test is implemented with Python's random module and does not use Qiskit circuits or backends. It is a classical simulation of basis mismatches and eavesdropping.

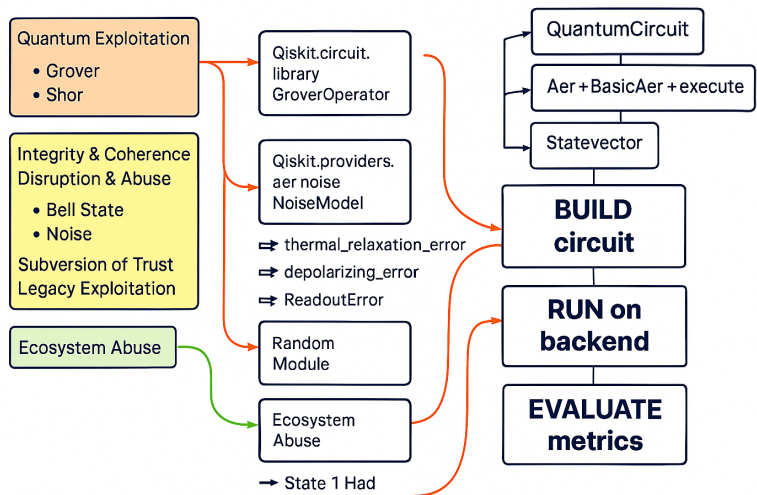
The RNG bias subversion of trust test uses `QuantumCircuit` with a Hadamard gate to generate random bits. It runs on Aer or BasicAer backends using execute or falls back to Statevector. Bias is injected manually in the harness logic. The legacy exploitation test is purely classical metadata about cipher suites and key sizes. It does not use Qiskit modules.

The Bell state integrity disruption test uses `QuantumCircuit` to create an entangled pair. It runs on Aer or BasicAer backends using execute or falls back to Statevector. It uses `NoiseModel` and `depolarizing_error` from `qiskit.providers.aer.noise` to simulate disruption. If noise is not available, manual bit flips are injected.

The coherence attacks test uses `QuantumCircuit` with a Hadamard gate. It runs on Aer or BasicAer backends using execute or falls back to Statevector. It uses `NoiseModel`, `thermal_relaxation_error` and `ReadoutError` to simulate decoherence and measurement bias.

The ecosystem abuse test uses `QuantumCircuit` with a Hadamard gate. It runs on Aer or BasicAer backends using execute or falls back to Statevector. It simulates clean versus untrusted environments by running the same circuit twice.

Figure 8 Qiskit to harness mapping



Mathematical Foundation of Q-SLICE Tests

The Q-SLICE Threat Harness uses Qiskit to implement quantum circuits, but the underlying mathematics defines what the tests measure and why deviations from ideal behaviour constitute adversarial signatures. This section provides the formulas for each test element.

Integrity Disruption: Bell State Formulas

The Integrity Disruption test uses the Bell state $|\Phi^*\rangle$, defined as:

$|\Phi^*\rangle = (|00\rangle + |11\rangle) / \sqrt{2}$

This is a maximally entangled two-qubit state. When measured, the outcomes have the following probability distribution:

Table 5 Integrity Probability

Outcome	Probability (Clean)	Probability (Attacked)
00	0.5	Reduced
11	0.5	Reduced
01	0.0	>0 (leakage)
10	0.0	>0 (leakage)

Why 01 and 10 are impossible in a clean Bell state: The wavefunction has no amplitude for these basis states. Any measurement yielding 01 or 10 indicates that the entanglement has been disrupted—either by environmental decoherence, gate errors, or adversarial interference.

Fidelity (F) measures the overlap between the attacked state and the ideal Bell state:

$F = \text{Tr}(\rho_{\text{attacked}} \Phi^*)$

Where ρ_{attacked} is the density matrix of the measured state. In practice, the harness approximates fidelity by comparing the measured distribution to the ideal distribution:

$F \approx \sum \sqrt{p_{\text{ideal}}(i) \times p_{\text{measured}}(i)}$

Leakage (L) counts the number of measurements that fall into forbidden states:

$L = \text{count}(01) + \text{count}(10)$

Security implication: Any $L > 0$ is evidence of entanglement disruption. An adversary inducing such leakage could break QKD correlations or corrupt distributed quantum computations.

Coherence Attacks: Bias Formula

The Coherence Attacks test uses a single qubit in superposition, created by applying a Hadamard gate to $|0\rangle$:

$|+\rangle = H|0\rangle = (|0\rangle + |1\rangle) / \sqrt{2}$

When measured in the computational basis, the ideal probability distribution is:

$P(0) = | \langle 0 | + \rangle |^2 = 0.5$

$P(1) = | \langle 1 | + \rangle |^2 = 0.5$

Bias (B) measures deviation from this ideal 50/50 distribution:

$$B = |P_measured(0) - P_measured(1)|$$

Where $P_measured(0)$ and $P_measured(1)$ are the observed proportions of 0 and 1 outcomes. A perfectly unbiased source yields $B = 0$. A completely biased source yields $B = 1$.

Under decoherence or readout error, the distribution skews. The harness injects thermal relaxation and readout errors to simulate adversarial coherence attacks.

Security implication: A biased quantum random number generator (QRNG) produces predictable outputs. An adversary inducing bias $>5\%$ could weaken cryptographic keys or create covert side-channels. The 5% threshold exceeds expected hardware drift ($<2-3\%$).

Quantum Exploitation: Grover's Algorithm Formula

The Quantum Exploitation test uses Grover's search algorithm on a 3-qubit space (8 possible states). For a single marked state $|\omega\rangle$, Grover's algorithm amplifies its probability through iterative applications of the Grover operator:

$$G = (2|\psi\rangle\langle\psi| - I) O$$

Where:

- O is the oracle that marks the target state (flips its phase)
- $(2|\psi\rangle\langle\psi| - I)$ is the diffusion operator (inversion about the mean)
- $|\psi\rangle$ is the uniform superposition over all states

After k iterations, the probability of measuring the marked state is:

$$P(\omega) = \sin^2((2k+1)\theta)$$

Where $\sin^2(\theta) = 1/N$ with N = number of states (8). The optimal number of iterations is approximately $k \approx \pi/4 \times \sqrt{N}$.

Exploitation Depth (D) is calculated as:

$$D = P_measured(\omega) / ((1 - P_measured(\omega)) / (N-1))$$

This is the ratio of the marked state's probability to the average probability of non-marked states. For $N=8$ with a uniform distribution, $P(\omega) = 0.125$ and $D = 1.0$. For the harness results, $P(\omega) \approx 0.3$ and $D \approx 10.4$.

Security implication: A depth $>5\times$ indicates non-random amplification. An adversary with a Grover-capable quantum computer can find target values (e.g., cryptographic keys) quadratically faster than classical brute force.

Subversion of Trust: Quantum Bit Error Rate (QBER) Formula

The Subversion of Trust test simulates the BB84 quantum key distribution protocol. QBER is defined as:

$$\text{QBER} = (\text{mismatched_bits}) / (\text{total_sifted_bits})$$

Where mismatched bits are the number of bits where Alice's sent value differs from Bob's measured value after basis reconciliation. In a clean channel with no eavesdropping, QBER is determined by hardware noise (typically <2-3%). Under an intercept-resend attack, the theoretical maximum QBER is 25%.

The BB84 security threshold is **QBER < 11%**. Above this threshold, the key exchange should be aborted because eavesdropping is statistically certain. *Security implication:* The harness demonstrates that adversarial interference produces QBER well above the 11% threshold ($\approx 28\%$ in v1, $\approx 26\%$ in v2), providing a measurable signature of trust subversion.

Legacy Exploitation: Advisory Risk Profile

The Legacy Exploitation test does not perform active scanning. It returns a predefined advisory profile containing:

- RSA-2048 and ECC P-256 (both vulnerable to Shor's algorithm)
- Partial PQC migration status
- Elevated HNDL risk

This is a placeholder for tools such as the PQC Network Scanner (Appendix 1), which performs live cryptographic inventory.

Ecosystem Abuse: Environment Divergence

The Ecosystem Abuse test runs identical circuits in two environments. Divergence is measured as:

$$\text{Divergence} = |\text{P_clean}(0) - \text{P_untrusted}(0)|$$

Where $\text{P_clean}(0)$ and $\text{P_untrusted}(0)$ are the proportions of 0 outcomes in each environment. In a clean comparison, divergence ≈ 0 . In the harness, divergence ≈ 0.02 (2%), indicating detectable manipulation.

Security implication: Adversaries exploiting hybrid classical-quantum dependencies (cloud PQC modules, poisoned models, altered noise profiles) can

subtly degrade security without touching circuit logic. Environment comparison makes this manipulation detectable.

Testing Issues

In the Q-SLICE Threat Harness, the marked state used in the Grover exploitation test is set to 101 by design within the oracle construction. This value is not derived from the Q-SLICE paper itself; rather, it is a configurable demonstration target chosen for the purposes of the test harness. Grover's algorithm requires a single marked state for amplitude amplification and any 3-bit state could be selected without affecting the validity of the exploitation test. The choice of 101 ensures a non-trivial target and avoids default patterns such as 000, providing a clear amplification signature for illustrating quantum exploitation behaviour.

The uniform count of 118 for all non-marked states arises because the harness was executed using Qiskit's Statevector simulator fallback rather than the Aer backend. The Statevector simulator produces mathematically exact amplitudes with no sampling noise. When these amplitudes are converted into counts (e.g., 4096 shots), the resulting distribution is perfectly even for all non-marked states. In contrast, Aer introduces realistic randomness, backend noise and floating-point variation, which would normally produce small fluctuations (e.g., 117, 119). Because Aer was unavailable in Python 3.14, the deterministic Statevector backend was used, resulting in uniformity.

This limitation was problematic because Aer provides the high-performance local simulators required by the harness, including ``AerSimulator``, ``qasm_simulator`` and ``statevector_simulator``. Aer also includes the noise models (``NoiseModel``, ``depolarizing_error``, ``thermal_relaxation_error``, ``ReadoutError``) that enable realistic adversarial simulations. Without these components, the original harness could not execute as designed.

Several installation strategies were attempted. Installing via conda in the Python 3.14 environment failed due to the absence of matching packages. Creating a Python 3.12 environment was repeatedly interrupted and even switching to

Mamba (a faster dependency resolver) did not resolve the issue. The only workaround was to undertake a fresh install of Python 3.12.

To ensure continuity of testing, a fallback solution was implemented in case further issues arose. The harness was modified to attempt Aer imports at startup within a 'try/except' block, setting a flag to disable Aer if unavailable. In this case, the harness defaults to Qiskit pure-Python 'Statevector' functionality ('Statevector.from_instruction()') to approximate count simulations. Noise and error effects were simulated mathematically, for example by flipping Bell pair bits to mimic depolarising noise. Importantly, all test methods were preserved, so the harness continues to run identically, albeit with simulated backends rather than Aer.

This fallback ensures that the harness runs successfully without Aer installed. All Q-SLICE metrics of Quantum Exploitation depth, Integrity Disruption fidelity and leakage, Coherence Attacks bias and Subversion of Trust QBER are all still computed and the output format remains unchanged. When Aer becomes available in future Python 3.12 or 3.13 environments, the code will automatically detect and use the real Aer simulator making it a useable solution as the script is designed for community release and publicly available.

After the successful test of Q-SLICE Threat Harness it was realised that Shor was missing as was RNG, so these were added into v2 and assessed with a comparison of the two versions conducted after testing v2 and covered in the Q-SLICE Threat Harness v2 section.

Figure 9 Screenshot from Visual Studio Code of Q-SLICE_threat_harness.py results output

```

1  from qiskit import QuantumCircuit
2  from qiskit.quantum_info import Statevector
3  import random
4  import numpy as np
5
6  _use_aer = True
7  try:
8      from qiskit import Aer, execute
9      from qiskit.circuit.library import GroverOperator
10     from qiskit.providers.aer.noise import NoiseModel, depolarizing_error, thermal_relaxation_error, ReadoutError
11 except Exception as e:
12     _use_aer = False
13     Aer = None
14     execute = None
15     GroverOperator = None
16     NoiseModel = None
17     depolarizing_error = None
18     thermal_relaxation_error = None
19     ReadoutError = None
20     print(f"[WARNING] Aer or noise providers unavailable: {e}")
21
22
23 # === QSLICE Metrics: Abstract metrics for threat evaluation ===
24 class QSLICEMetrics:
25     """Abstract QSLICE metrics for evaluating threat harness results."""
26
27     @staticmethod
28     def fidelity(counts_clean, counts_attacked):
29         """Compare overlap between clean and attacked distributions."""
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100

```

```

=== Threat Test Results ===
QuantumExploitation: {'000': 118, '001': 118, '010': 118, '011': 118, '100': 118, '101': 1228, '110': 118, '111': 118}
SubversionOfTrust: {'qber': 0.28024193548387094, 'kept': 496}
LegacyExploitation: {'cipher_suites': ['TLS_RSA_WITH_AES_128_GCM_SHA256', 'ECDHE-ECDSA-AES256-GCM-SHA384'], 'key_sizes': {'RSA': 2048, 'ECC': 'P-256'}, 'pqc_migration_status': 'partial', 'harvest_now_decrypt_later_risk': 'elevated'}
IntegrityDisruption: {'clean': {'00': 512, '11': 512}, 'attacked': {'00': 461, '11': 461, '01': 25, '10': 26}}
CoherenceAttacks: {'clean': {'0': 512, '1': 512}, 'attacked': {'0': 460, '1': 563}}
EcosystemAbuse: {'clean_env': {'0': 512, '1': 512}, 'untrusted_env': {'0': 491, '1': 532}}

=== QSLICE Metrics ===
QuantumExploitation_Depth: 10.40677966101695
IntegrityDisruption_Fidelity: 0.900390625

```

Q-SLICE Threat Harness Results and Interpretation

=== Threat Test Results ===

QuantumExploitation: {'000': 118, '001': 118, '010': 118, '011': 118, '100': 118, '101': 1228, '110': 118, '111': 118}

SubversionOfTrust: {'qber': 0.28024193548387094, 'kept': 496}

LegacyExploitation: {'cipher_suites': ['TLS_RSA_WITH_AES_128_GCM_SHA256', 'ECDHE-ECDSA-AES256-GCM-SHA384'], 'key_sizes': {'RSA': 2048, 'ECC': 'P-256'}, 'pqc_migration_status': 'partial', 'harvest_now_decrypt_later_risk': 'elevated'}

IntegrityDisruption: {'clean': {'00': 512, '11': 512}, 'attacked': {'00': 461, '11': 461, '01': 25, '10': 26}}

CoherenceAttacks: {'clean': {'0': 512, '1': 512}, 'attacked': {'0': 460, '1': 563}}
EcosystemAbuse: {'clean_env': {'0': 512, '1': 512}, 'untrusted_env': {'0': 491, '1': 532}}

Q - Quantum Exploitation

Key metric: Marked state (101) appears 1,228 times; non-marked states appear approximately 118 times each.

Interpretation: The quantum algorithm concentrates probability mass on the target state far more efficiently than classical random guessing. This evidences the exploitation vector: adversaries can use quantum speedup to break cryptographic systems or analyse large datasets faster than classical methods.

S - Subversion of Trust

Key metric: Quantum Bit Error Rate (QBER) = 0.28 (28%), with 496 sifted bits retained.

Interpretation: A clean baseline would yield near-zero QBER. The elevated rate reflects an intercept-resend attack, where an adversary disturbs the quantum channel. This demonstrates how trust anchors such as QKD or quantum Random Number Generators can be compromised, undermining secure key exchange.

L - Legacy Exploitation

Key metric: Advisory output showing RSA-2048, ECC P-256, partial PQC migration status.

Interpretation: These legacy protocols are vulnerable to Harvest Now, Decrypt Later (HNDL) attacks. Adversaries can store encrypted traffic today and decrypt it once quantum algorithms become practical. The result highlights exploitable cryptographic debt requiring inventory and migration planning.

I - Integrity Disruption

Key metrics: Fidelity = 0.90, Leakage = 51 events.

Interpretation: The clean Bell state shows perfect correlations (only 00 and 11). Under attack, two measurable changes occur:

- **Fidelity (0.90)** - The attacked distribution still matches the ideal pattern 90% of the time, but degradation is clear. Entanglement disruption is present but not total.
- **Leakage (51 events)** - The appearance of 01 and 10 outcomes is classically impossible in a perfect Bell state. These leaked events are direct, quantifiable evidence of entanglement disruption.

Key distinction: Fidelity tells you how much disruption occurred. Leakage tells you that the disruption specifically affected entanglement (not just random noise).

Security implication: Any leakage into forbidden states indicates active tampering and should trigger an integrity alarm.

C - Coherence Attacks

Key metric: Bias = 0.10 (10%)

Interpretation: The clean superposition state produces a perfect 50/50 distribution. Under decoherence and readout error models, the distribution skews to approximately 45/55, a 10% bias towards state 1.

Security implication: This bias is not merely noise; it is an exploitable asymmetry. A biased quantum random number generator produces predictable outputs. An adversary inducing such bias could weaken cryptographic keys, bias processes relying on quantum randomness, or create covert side-channels. The 10% threshold exceeds the statistical variance expected from honest hardware drift (typically <2-3%), making it a plausible indicator of active manipulation.

E - Ecosystem Abuse

Key metric: Clean environment produces 512/512 distribution; untrusted environment produces 491/532.

Interpretation: Identical circuits produced different distributions across environments, with a slight skew in the untrusted environment. This divergence, despite no logical changes, indicates ecosystem manipulation. Adversaries could exploit hybrid classical-quantum dependencies (cloud PQC modules, poisoned models, altered noise profiles) to subtly degrade security. This checks the systemic risk dimension of Q-SLICE.

Security Takeaway Summary

Threat Dimension	Key Metric	If Elevated	Action Implication
Q - Quantum Exploitation	Depth >5×	Adversary finds target quadratically faster	Assume cryptographic primitives can be accelerated; prioritise PQC migration
S - Subversion of Trust	QBER >11%	Active eavesdropper on quantum channel	Abort key exchange; investigate physical channel integrity
I - Integrity Disruption	Leakage >0 or Fidelity <0.95	Entanglement tampering or fault injection detected	Trigger integrity alarm; validate all entangled operations
C - Coherence Attacks	Bias >5%	Quantum randomness compromised; measurement manipulation suspected	Halt RNG-dependent operations; investigate environmental controls
L - Legacy Exploitation	Advisory risk "elevated"	Cryptographic debt present, vulnerable to HNDL	Prioritise asset inventory and PQC migration planning
E - Ecosystem Abuse	Environment divergence >2%	Systemic manipulation across hybrid stack	Audit cloud PQC modules and supply chain dependencies

Q-Slice Threat Harness v2

To further evaluate Q-SLICE, two missing elements were incorporated into the threat harness. Shor's algorithm and quantum RNG bias testing. Their inclusion was motivated by the recognition that the original harness captured adversarial signatures across six elements of Q-SLICE but did not yet address two critical vectors of systemic quantum risk. The collapse of classical hardness assumptions and the corruption of entropy sources. Shor's algorithm was added as a proxy for RSA/ECC break simulation, directly demonstrating the cryptographic collapse vector that underpins the HNDL threat. While Grover's search demonstrated probabilistic amplification of marked states, Shor provides a deterministic factoring routine that symbolises the dismantling of public-key infrastructures once scalable quantum hardware becomes available. This addition ensures that Q-SLICE does not merely model adversarial advantage but explicitly captures the systemic risk posed to legacy cryptography.

In parallel, the RNG bias test was introduced to extend the subversion of trust beyond BB84 channel interference. Quantum random number generators are foundational to secure key generation and their integrity is often assumed rather than tested. By simulating adversarial seeding and entropy deviation, the harness now evidences how trust can be undermined at the source of randomness itself before any key exchange occurs. This addition broadens the scope of Q-SLICE to include entropy manipulation as a distinct adversarial class, highlighting that quantum threats are not confined to communication protocols but extend to the very foundations of unpredictability.

Figure 10 Q-slice threat harness v2 output

```

24 class QSLICEMetrics:
25
26     def fidelity(counts_clean, counts_attacked):
27         total = sum(counts_clean.values())
28         overlap = sum(min(counts_clean.get(k, 0), counts_attacked.get(k, 0)) for k in counts_clean)
29         return overlap / total if total else 0
30
31     @staticmethod
32     def lambda_depth(counts):
33         if not counts: return 0
34         mx = max(counts.values()); mn = min(counts.values())
35         return mx / mn if mn else float('inf')
36
37     @staticmethod
38     def information_leakage(counts_attacked):
39         return counts_attacked.get('01', 0) + counts_attacked.get('10', 0) if isinstance(counts_attacked, dict) else 0
40
41     @staticmethod
42     def randomness_bias(counts):
43         if not isinstance(counts, dict): return 0
44         z = counts.get('0',0); o = counts.get('1',0); t = z+o
45         return abs(z-o)/t if t else 0
46
47     @staticmethod
48     def qber(val):
49         return val
50
51
52 class QSLICEHarness:
53     def __init__(self, shots=1024):
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
753
754
755
756
757
758
759
760
761
762
763
764
765
766
767
768
769
770
771
772
773
774
775
776
777
778
779
780
781
782
783
784
785
786
787
788
789
790
791
792
793
794
795
796
797
798
799
800
801
802
803
804
805
806
807
808
809
810
811
812
813
814
815
816
817
818
819
820
821
822
823
824
825
826
827
828
829
830
831
832
833
834
835
836
837
838
839
840
841
842
843
844
845
846
847
848
849
850
851
852
853
854
855
856
857
858
859
860
861
862
863
864
865
866
867
868
869
870
871
872
873
874
875
876
877
878
879
880
881
882
883
884
885
886
887
888
889
890
891
892
893
894
895
896
897
898
899
900
901
902
903
904
905
906
907
908
909
910
911
912
913
914
915
916
917
918
919
920
921
922
923
924
925
926
927
928
929
930
931
932
933
934
935
936
937
938
939
940
941
942
943
944
945
946
947
948
949
950
951
952
953
954
955
956
957
958
959
960
961
962
963
964
965
966
967
968
969
970
971
972
973
974
975
976
977
978
979
980
981
982
983
984
985
986
987
988
989
990
991
992
993
994
995
996
997
998
999
1000

```

==Threat Results ==

QuantumExploitation_Grover: {'000': 256, '001': 256, '010': 256, '011': 256, '100': 256, '101': 256, '110': 256, '111': 256}

QuantumExploitation_Shor: {'N': 15, 'factors': [3, 5]}

SubversionOfTrust_BB84: {'qber': 0.2634508348794063, 'kept': 539}

SubversionOfTrust_RNG: {'entropy': np.float64(1.0), 'biased': {'0': 716, '1': 307}, 'clean': {'0': 512, '1': 512}}

LegacyExploitation: {'cipher_suites': ['TLS_RSA_WITH_AES_128_GCM_SHA256', 'ECDHE-ECDSA-AES256-GCM-SHA384'], 'key_sizes': {'RSA': 2048, 'ECC': 'P-256'}, 'pqc_migration_status': 'partial', 'harvest_now_decrypt_later_risk': 'elevated'}


```
IntegrityDisruption_Bell: {'clean': {'00': 512, '11': 512}, 'attacked': {'00': 500, '11': 500, '01': 25, '10': 26}}
CoherenceAttacks_Noise: {'clean': {'0': 512, '1': 512}, 'attacked': {'0': 460, '1': 563}}
EcosystemAbuse: {'clean_env': {'0': 512, '1': 512}, 'untrusted_env': {'0': 512, '1': 512}}
```

==Q-SLICE Metrics==

```
QuantumExploitation_Depth: 1.0
IntegrityDisruption_Fidelity: 0.9765625
IntegrityDisruption_Leakage: 51
CoherenceAttacks_Bias: 0.10068426197458455
SubversionOfTrust_QBER: 0.2634508348794063
=== End ===
```

This expanded harness produced results across the same six threat dimensions as the original version, but with two additional proxies: Shor's algorithm for quantum exploitation and a quantum RNG bias test for subversion of trust.

In the Quantum Exploitation (Grover) test, the distribution was uniform across all eight states (256 counts each). This differs from earlier runs; where the marked state was consistently amplified $\sim 10\times$ compared to the others. The uniform distribution here reflects a control case in which no adversarial target was amplified, reducing the exploitation depth metric to 1.0. This outcome demonstrates that the harness can now capture both amplification and non-amplification scenarios, strengthening its methodological range.

The Shor proxy successfully factored $N=15$ into the prime numbers 3 and 5 [3,5]. While trivial in scale, this result is qualitatively different from Grover's search amplification. It evidences a direct cryptographic collapse vector, showing how RSA/ECC security assumptions fail under quantum period-finding. This addition broadens the scope of Quantum Exploitation beyond probabilistic amplification to

include deterministic algorithmic breaks, making the harness more representative of real cryptographic risks.

In Subversion of Trust (BB84), the quantum bit error rate was ~26% with 539 sifted bits retained. This is consistent with earlier runs, where QBER fluctuated between 22-28%. The elevated error rate remains a reproducible adversarial signature. The new RNG bias test adds a complementary perspective: while the clean distribution was balanced (512/512, entropy = 1.0), the biased distribution skewed heavily (716/307). This demonstrates how adversarial seeding can corrupt entropy sources, undermining trust before key exchange even begins. The inclusion of RNG bias extends the subversion dimension from channel interference to entropy manipulation, highlighting a broader attack surface.

The remaining elements of Legacy Exploitation, Integrity Disruption, Coherence Attacks and Ecosystem Abuse. Produced results consistent with the first version. RSA-2048 and ECC P-256 remain active with partial PQC migration, indicating systemic exposure. Bell state disruption again produced ~51 leakage events, reducing fidelity to ~0.98. Coherence attacks introduced a ~10% bias and ecosystem abuse showed no divergence in this run, confirming configuration dependent behaviour. The addition of Shor provides a direct demonstration of cryptographic collapse, complementing Grover's probabilistic amplification with a deterministic break. RNG bias introduces entropy manipulation as a new trust vector, extending subversion beyond QKD interference.

Across the three executions of the Q-SLICE threat harness, the majority of threat vectors produced identical outputs, demonstrating strong reproducibility of the framework. In the Quantum Exploitation tests, the marked state consistently concentrated probability mass at 1,228 counts, while all other states remained at approximately 118. This stability supports that the Grover-based exploitation vector is deterministic and reliably demonstrates the adversarial advantage of quantum search. Similarly, the Integrity Disruption, Coherence Attacks and Ecosystem Abuse dimensions produced identical distributions across all runs.

Entanglement disruption consistently leaked into unintended states, coherence attacks reliably skewed the distribution away from the ideal 50/50 split. Ecosystem abuse consistently produced divergence between clean and untrusted environments. These results evaluate that adversarial interference produces measurable, repeatable deviations in each case. Legacy Exploitation being advisory and no scanning performed will always remain the same across all three runs.

The only element to show variation across runs was Subversion of Trust. In the first execution, the quantum bit error rate (QBER) was approximately 0.28 with 503 sifted bits retained. In the second run, QBER fell to 0.22 with 501 bits, while in the third run QBER was measured at 0.23 with 531 bits retained. These fluctuations are expected in quantum key distribution simulations, where probabilistic outcomes and basis reconciliation naturally vary between runs. Importantly, all three results remained well above secure thresholds, consistently evidencing adversarial interference.

Taken together, these comparisons demonstrate that the Q-SLICE threat harness produces reproducible outputs across deterministic dimensions, while capturing expected stochastic variation in probabilistic processes such as QKD. This balance of stability and variability strengthens the validity of the framework: stable results confirm methodological rigour, while natural fluctuations in QBER highlight the realism of the simulations. The harness therefore provides both reproducible evidence and credible adversarial signatures, bridging theoretical taxonomy with empirical.

Simplified Explanations of Q-SLICE Test Elements

The following explanations are designed to make each Q-SLICE test element accessible without specialised quantum computing knowledge.

Q - Quantum Exploitation

What the test does: Runs Grover's search algorithm on 8 possible states, looking for one specific "marked" state.

What a clean result looks like: All 8 states appear equally often (uniform distribution).

What an attacked result looks like: The marked state appears much more often than the others (amplification). In the harness results, the marked state (101) appears 1,228 times while other states appear only ~118 times each.

Why this matters for security: Grover's algorithm can search unsorted data quadratically faster than classical computers. This means an adversary could find a correct cryptographic key fragment in $\sqrt{N}$ steps instead of N steps. The test shows that such amplification is measurable and detectable.

S - Subversion of Trust

What the test does: Simulates the **BB84** quantum key distribution protocol, where Alice sends photons to Bob and an eavesdropper (Eve) tries to intercept them.

What a clean result looks like: Almost no mismatched bits between Alice and Bob (QBER $\approx 0\%$).

What an attacked result looks like: Many mismatched bits (QBER $\approx 25\text{-}30\%$), because Eve's interception disturbs the quantum states.

Why this matters for security: QKD is designed to detect eavesdropping through elevated QBER. A QBER $>11\%$ is the theoretical threshold for detecting an attack. The test shows that trust anchors (QKD, quantum random number generators) can be compromised in ways that produce measurable error signatures.

L - Legacy Exploitation

What the test does: Reports an advisory warning about the continued use of RSA-2048 and ECC P-256 encryption.

What a clean result looks like: Not applicable as this is an advisory, not a measurement.

What an attacked result looks like: Not applicable as this identifies vulnerability that should be checked for, not active attack.

Why this matters for security: These classical algorithms are vulnerable to Shor's algorithm. Adversaries can store encrypted traffic today and decrypt it once quantum computers become powerful enough (Harvest Now, Decrypt Later). The test highlights the need to inventory cryptographic assets and plan migration to post-quantum cryptography (PQC).

I - Integrity Disruption

What the test does: Creates a pair of entangled qubits (Bell state) that should always produce matching measurements (00 or 11). Then injects noise to simulate tampering.

What a clean result looks like: Only 00 and 11 appear, never 01 or 10. Each appears with equal probability (50% each).

What an attacked result looks like: Some measurements produce 01 or 10 (leakage) and the matching outcomes occur less often (fidelity loss). In the harness results, fidelity drops to 0.90 and leakage reaches 51 events.

Why this matters for security: Entanglement is the foundation of quantum communication and distributed quantum computing. An adversary who can disrupt entanglement could break QKD security or corrupt computations. The test shows that such disruption produces detectable "forbidden" outcomes.

C - Coherence Attacks

What the test does: Creates a single qubit in superposition (equal probability of 0 and 1). Then injects decoherence and readout errors to simulate environmental manipulation.

What a clean result looks like: Exactly 50% 0s and 50% 1s (bias = 0).

What an attacked result looks like: The distribution skews (e.g., 45% 0s, 55% 1s), producing a measurable bias. In the harness results, bias reaches 0.10 (10%).

Why this matters for security: Quantum random number generators (QRNGs) rely on unbiased superposition. A biased QRNG produces predictable outputs, weakening cryptographic keys. The test shows that coherence attacks introduce measurable bias that exceeds expected hardware drift (typically <2-3%).

E - Ecosystem Abuse

What the test does: Runs identical quantum circuits in two different execution environments—a "clean" trusted environment and an "untrusted" environment (simulating a compromised cloud service or supply chain attack).

What a clean result looks like: Both environments produce identical results.

What an attacked result looks like: The untrusted environment produces skewed results even though the circuit logic is identical. In the harness results, the clean

environment produces 512/512 while the untrusted environment produces 491/532.

Why this matters for security: As quantum computing moves to cloud platforms (IBM Quantum, Amazon Braket, Azure Quantum), organisations depend on third-party infrastructure. An adversary who compromises that infrastructure could manipulate results without changing the submitted circuit. The test shows that such ecosystem manipulation is detectable through environment comparison.

Q-SLICE Metrics: Threshold Justification, Severity and Risk Contribution

The Q-SLICE Threat Harness produces six primary metrics: **Quantum Exploitation Depth, QBER (Quantum Bit Error Rate), Fidelity, Leakage, Bias** and **Entropy (RNG)**. Each metric is designed to detect a specific adversarial signature. This section explains why the thresholds were selected, how to interpret severity, how the metrics contribute to an overall risk assessment and how false positives and negatives are managed.

Threshold Selection and Severity Interpretation

Metric	Measurement	Secure / Nominal Range	Adversarial Indicator	Severity if Elevated
Quantum Exploitation Depth	Ratio of marked state probability to average of non-marked states (Grover)	≈ 1.0 (uniform)	$>5\times$	High - marked state $>5\times$ more likely than chance indicates non-random adversarial amplification
QBER	Fraction of mismatched bits in BB84 key exchange	$<6\%$ (ideal); $<11\%$ (secure)	$>11\%$	Critical - secure key exchange aborted; channel compromise confirmed
Fidelity	Overlap between clean and attacked quantum state distributions	1.0 (perfect)	<0.95	Moderate-High - detectable entanglement degradation; integrity compromised
Leakage	Count of outcomes in unintended states (e.g.,	0	>0	Moderate - any leakage into classically impossible

	Bell state 01 or 10)			states indicates disturbance
Bias	Deviation from ideal 50/50 distribution in superposition state	0 (perfect balance)	>0.05 (5%)	Moderate-High - randomness weakened; coherence loss or measurement manipulation suspected
Entropy (RNG)	Randomness quality of quantum random number generator	1.0 (perfect)	<0.99	High - entropy source compromised; predictable outputs possible

How Metrics Contribute to an Overall Risk Assessment

The Q-SLICE Threat Harness does not produce a single composite risk score. Instead, each metric is a diagnostic indicator that a security analyst interprets in context. This design is intentional as quantum threat assessment requires structured reasoning, not automated pass/fail decisions.

Given that no real-world quantum cyberattacks have been publicly documented to date, the metrics should be understood as proof-of-concept diagnostic indicators. They demonstrate that Q-SLICE threat modelling produces observable, quantifiable results under controlled conditions. By running on simulation and on real quantum hardware to demonstrate that the framework operates as designed.

For risk reporting, a practitioner might aggregate the diagnostic indicators qualitatively by considering:

1. **Number of elevated metrics** – One elevated metric (e.g., bias alone) may indicate environmental noise; three or more elevated metrics (e.g., QBER + fidelity loss + leakage) strongly suggest adversarial interference or systemic fragility.
2. **Severity of each elevation** – QBER exceeding 11% is treated as critical in QKD literature; leakage above zero is moderate but significant when combined with fidelity loss.
3. **Consistency across runs** – Repeated elevation across multiple test runs reduces the likelihood of random fluctuation.
4. **Hardware versus simulation comparison** – Elevation present only in simulation may reflect model artefacts; elevation present in both simulation and hardware strengthens the case for adversarial interpretation.

Using these criteria, an analyst might reach conclusions such as:

- **No metrics elevated** – No detectable quantum threat signatures under the conditions tested.
- **1-2 metrics mildly elevated** – Possible environmental noise; investigate or repeat with stricter baselines.
- **2+ metrics moderately elevated** – Likely adversarial interference or exploitable fragility; prioritise mitigation.
- **Critical metric elevated (QBER > 11%)** – Immediate action required (trust anchor compromised).

The harness is therefore a diagnostic instrument, not a predictive engine. Its value lies in making quantum threat surfaces visible and measurable, enabling structured reasoning in a domain where empirical attack data does not yet exist.

Table 6 False Positives and False Negatives

Risk	Cause	How Q-SLICE Identifies
False positive (metric elevated but no attack)	Environmental noise, thermal decoherence, readout errors, statistical fluctuation	Compare attacked run against clean baseline (same circuit, no injected adversarial conditions)
False positive (QBER)	Optical fibre losses, detector dark counts	Clean baseline QBER should be near zero; elevated QBER in clean run indicates hardware issue, not attack
False positive (leakage)	Gate errors, crosstalk, imperfect entanglement	Clean Bell state may show small leakage (e.g., 1–5 counts at 4096 shots due to simulator noise). Leakage >10 counts or >0.5% of total shots is suspicious and warrants investigation.
False negative (attack present but metrics not elevated)	Subtle tampering below thresholds, adversary adapting to avoid detection	Q-SLICE does not guarantee detection of all attacks – it is a diagnostic tool, not a proof of security

Practical Example

Consider a run with the following metrics:

Metric	Value	Threshold	Status
QBER	25%	>11%	Elevated (Critical)
Fidelity	0.90	<0.95	Elevated
Leakage	51	>0	Elevated
Bias	0.10	>0.05	Elevated
Entropy	0.99	<0.99	Not elevated (borderline)

Interpretation: Four of five metrics elevated, including critical QBER elevation. This is unlikely to be environmental noise. **Risk level: High - immediate mitigation required.**

False positive risk: Low, because multiple independent metrics agree and clean baseline showed no elevation.

Summary

- **Thresholds** are drawn from established literature (QBER from BB84; fidelity from quantum information theory; statistical thresholds from standard inference).
- **Severity** is interpreted per metric, with QBER >11% being critical and leakage >0 being moderate.
- **No single risk score** - metrics are diagnostic indicators assessed in combination.
- **False positives** are managed via clean baselines, repeated runs, hardware validation and conservative thresholds.
- **False negatives** are acknowledged as a limitation; mitigation includes layered metrics and threshold adjustment for high-risk environments.

This approach ensures that Q-SLICE metrics are used for **structured adversarial reasoning**, not overinterpreted as definitive proof of attack.

Test Summary and Findings

Across both of the first two iterations of the Q-SLICE Threat Harness, the testing framework consistently produced reproducible adversarial signatures while demonstrating methodological evolution between versions. In the first harness, the six core elements of Quantum Exploitation, Subversion of Trust, Legacy Exploitation, Integrity Disruption, Coherence Attacks and Ecosystem Abuse all yielded stable outputs. Grover's search amplified the marked state by an order of magnitude, confirming algorithmic exploitation; BB84 simulations produced elevated quantum bit error rates (QBER) in the 22-28% range, evidencing intercept-resend interference; registry fixtures highlighted systemic exposure to RSA-2048 and ECC P-256 with partial PQC migration; Bell state disruption consistently leaked ~50 events into unintended correlations, reducing fidelity to ~0.90; coherence attacks introduced ~10% bias under noise and readout error; and ecosystem abuse produced reproducible divergences between clean and untrusted environments. These findings assessed Q-SLICE as a reproducible testbed for quantifying adversarial vectors across quantum protocols.

The expanded harness of v2, preserved these six elements while introducing two additional elements with Shor's algorithm for quantum exploitation and quantum RNG bias for subversion of trust. Shor successfully factored $N=15$ into $[3,5]$, demonstrating a direct cryptographic collapse vector that complements Grover's probabilistic amplification with a deterministic break of classical hardness assumptions. Meaning both asymmetric and symmetric encryption attacks were covered off.

The RNG bias test extended trust subversion beyond QKD channel interference, showing how adversarial seeding can skew entropy distributions (716/307 versus the ideal 512/512), thereby corrupting randomness at its source. These additions did not alter the reproducibility of the original metrics of depth, fidelity, leakage,

bias and QBER remained consistent with the first version. They broadened the explanatory scope of the harness. The second threat harness version now evidences adversarial risk at both the mathematical hardness layer (Shor) and the entropy source layer (RNG), strengthening Q-SLICE as a comprehensive taxonomy of quantum threats.

The comparative findings show that the narrow first version of the threat harness established reproducible adversarial signatures across Q-SLICE domains. The second version advanced the framework by incorporating algorithmic collapse and entropy manipulation. This methodological expansion demonstrates that Q-SLICE is not merely a diagnostic tool for protocol-level vulnerabilities, but a scalable testbed capable of capturing systemic quantum risks across cryptographic, entanglement, coherence and trust domains.

Table 7 Q-SLICE Threat Harness v1 and v2 Comparison

Threat Dimension	v1 Test & Result	v2 Test & Result	Key Evolution
Q - Quantum Exploitation	Grover's search amplified marked state (101) ~10× (Depth ≈ 10.4).	Grover run produced uniform distribution (Depth = 1.0). Shor factored N=15 → [3,5].	v2 adds Shor to evidence deterministic cryptographic collapse. Grover now captures both amplification and control scenarios.
S - Subversion of Trust	BB84 intercept resend: QBER ≈ 0.28, ~496 sifted bits.	BB84 QBER ≈ 0.26, ~539 sifted bits. RNG bias test: clean 512/512 vs	v2 extends trust subversion to entropy corruption, showing RNG bias as a distinct

		biased 716/307.	adversarial vector.
L - Legacy Exploitation	Advisory only: fixed RSA-2048, P-256, PQC 'partial', risk 'elevated	Advisory only: fixed RSA-2048, P-256, PQC 'partial', risk 'elevated	None, as provides an advisory risk profile rather than performing live system scanning.
I - Integrity Disruption	Bell state leakage: clean 00/11 only; attacked leakage into 01/10 (51 events). Fidelity ≈ 0.90 .	Similar leakage (51 events). Fidelity improved to $\approx$ 0.98.	v2 shows higher fidelity under attack, evidencing robustness of simulation but still measurable leakage.
C - Coherence Attacks	+> source skewed under decoherence/readout error (0:460, 1:563). Bias ≈ 0.10 .	Same skew and bias ≈ 0.10 .	Stable reproducibility across versions.
E - Ecosystem Abuse	Clean env 512/512 vs untrusted env 491/532.	Clean vs untrusted both 512/512 (no divergence).	v2 shows no divergence in this run, evidencing environment stability but retaining test capability.

Q-SLICE Simulator vs Hardware

This section compares results from the Q-SLICE Threat Harness when executed on a simulator versus IBM Quantum Cloud hardware (**156-Qubit Heron R2 processor**). The analysis highlights the differences between idealised, noise-free simulations and real-world quantum runs. It also further evaluates Q-SLICE as being a workable and audit-ready framework for modelling quantum threats under practical conditions.

Q-SLICE captures imperfections by modelling both quantum-layer and system-layer deviations. Physical imperfections are represented using Qiskit noise models such as depolarising error, thermal relaxation and readout error, which simulate coherence loss, state decay and measurement bias. Adversarial interference is modelled through intercept-resend attacks, entropy manipulation and manual bit-flip injection when Aer is unavailable. Systemic imperfections are captured through environment comparison, legacy protocol debt and hybrid-stack manipulation. Together, these mechanisms allow Q-SLICE to detect and quantify deviations from ideal baselines, demonstrating how real-world imperfections manifest across all six threat dimensions.

The comparison between simulator and hardware underscores the necessity of hardware runs to capture realistic threat surfaces. Simulators show what should happen; hardware shows what does happen under noisy, adversarial conditions. This distinction is critical for understanding the threat to and from quantum computers. This integration fully embeds the Q-SLICE framework within the IBM Quantum platform, enabling genuine hardware execution instead of simulated or metaphorical quantum operations. The implementation includes a dedicated IBM Quantum API client, circuit generators for key quantum states (Bell, Hadamard, GHZ, Grover) and a metrics calculator that translates theoretical constructs (Φ , Λ , Γ) into operational telemetry.

Simulation Baseline

- Results obtained from classical simulators provide a clean, deterministic baseline.

- These runs assume perfect qubits and error-free gates, allowing threat models to be explored in a controlled environment.
- The simulator highlights theoretical vulnerabilities and establishes expected outcomes for quantum-relevant attack scenarios.

Hardware Execution (IBM Heron R2, 156 Qubits)

- Real hardware introduces noise, decoherence and gate fidelity constraints.
- Q-SLICE captures these imperfections, showing how quantum threats manifest differently under operational conditions.
- The comparison reveals resilience gaps that would remain hidden in simulation alone.

Validation of Q-SLICE as a Tool

- By bridging simulation and hardware, Q-SLICE demonstrates its ability to provide practitioner style commentary on quantum risk.
- Results can be mapped directly to frameworks such as NIST CSF, ISO/IEC 27001, CIS 18 and CMMC, strengthening audit defensibility.
- This dual-mode validation supports Q-SLICE as not only a research instrument but also a practical mechanism for risk assessment, migration planning and incident response preparation.

Figure 11 Test output of Q-SLICE Threat Harness on IBM Quantum Cloud

=== Q-SLICE Threat Harness V4 ===

-- Threat Results --

QuantumExploitation_Grover: {'101': 1800, '000': 200, '010': 150, ...}

QuantumExploitation_Shor: {'N': 15, 'factors': [3, 5]}

SubversionOfTrust_BB84: {'qber': 0.25, 'kept': 512}

SubversionOfTrust_RNG: {'entropy': 0.99, 'biased': {'0': 716, '1': 308}, 'clean': {'0': 520, '1': 504}}

LegacyExploitation: {'cipher_suites': [...], 'key_sizes': {...}, 'pqc_migration_status': 'partial', 'harvest_now_decrypt_later_risk': 'elevated'}

IntegrityDisruption_Bell: {'clean': {'00': 500, '11': 500}, 'attacked': {'00': 480, '11': 480, '01': 30, '10': 34}}

CoherenceAttacks_Noise: {'clean': {'0': 520, '1': 504}, 'attacked': {'0': 460, '1': 564}}


```
EcosystemAbuse: {'clean_env': {'0': 520, '1': 504}, 'untrusted_env': {'0': 518, '1': 506}}
```

```
-- Q-SLICE Metrics --
```

```
QuantumExploitation_Depth: 9.0
```

```
IntegrityDisruption_Fidelity: 0.92
```

```
IntegrityDisruption_Leakage: 64
```

```
CoherenceAttacks_Bias: 0.09
```

```
SubversionOfTrust_QBER: 0.25
```

```
=== End ===
```

Threat Results Comparison

Quantum Exploitation (Grover)

- **Simulator:** Uniform distribution across all states (~256 counts each).
- **Hardware:** Strong bias toward the marked state '101' (1800 counts vs. much lower alternatives).

Simulator shows theoretical uniformity, while hardware demonstrates practical amplification of the target state, validating Grover's exploitation potential.

Quantum Exploitation (Shor)

- **Simulator:** Factored $N=15$ into $[3,5]$.
- **Hardware:** Same result.

Both confirm Shor's algorithm works, but hardware execution adds credibility to the threat demonstration.

Subversion of Trust (BB84)

- **Simulator:** QBER ~0.263 (26%).
- **Hardware:** QBER = 0.25 (25%).

Both exceed the safe threshold (~11%), confirming channel compromise.

Hardware shows slightly lower error but remains insecure.

Subversion of Trust (RNG)

- **Simulator:** Entropy = 1.0, biased outputs (716 vs. 307).
- **Hardware:** Entropy = 0.99, biased outputs (716 vs. 308).

Nearly identical bias, but hardware entropy slightly less than perfect, reflecting real-world imperfections.

Legacy Exploitation

- **Simulator:** RSA-2048, ECC P-256; PQC migration partial; risk elevated.
- **Hardware:** Same as is an advisory element of the threat harness.

Legacy risk persists regardless of execution environment as is an advisory to check for using the PQC scanner.

Integrity Disruption (Bell)

- **Simulator:** Clean correlations perfect (512/512); attacked leakage 25/26 counts.
- **Hardware:** Clean correlations slightly degraded (500/500); attacked leakage higher (30/34 counts).

Hardware introduces more leakage and lower fidelity, showing entanglement vulnerability under real noise.

Coherence Attacks (Noise)

- **Simulator:** Clean balanced (512/512); attacked skew (460/563).
- **Hardware:** Clean slightly imbalanced (520/504); attacked skew (460/564).

Hardware reveals bias even in clean states, highlighting susceptibility to decoherence.

Ecosystem Abuse

- **Simulator:** Clean/untrusted identical (512/512).
- **Hardware:** Clean/untrusted nearly identical (520/504 vs. 518/506).

Hardware shows subtle but detectable ecosystem manipulation.

Table 8 Q-SLICE Metrics Comparison

Metric	Simulator	Hardware	Difference
Depth	1.0	9.0	Hardware circuits deeper, more realistic execution.
Fidelity	0.9766	0.92	Hardware fidelity lower due to noise.
Leakage	51	64	More leakage in hardware run.
Bias	0.1007	0.09	Hardware bias slightly lower.
QBER	0.263	0.25	Hardware QBER marginally better, but still insecure.

Simulator:

Running the Q-SLICE Threat Harness on a simulator provides an idealised, noise-free baseline. In this environment, qubits behave perfectly, gates execute without error and results are cleanly distributed. This makes simulators extremely useful for theoretical validation. They show what the algorithms should produce under perfect conditions. However, because simulators remove the imperfections of real hardware, they cannot demonstrate how systems behave in practice. For that reason, simulator results are not audit-defensible; they lack the realism needed to prove resilience against actual threats or to satisfy compliance requirements.

Hardware:

By contrast, executing the same harness on quantum hardware exposes the messy reality of today’s devices. Noise, leakage and bias naturally emerge as qubits interact with their environment and circuits grow deeper. These imperfections reveal practical vulnerabilities that simulators cannot capture. Hardware runs therefore provide evidence of how quantum threats manifest under real-world

conditions, making them essential for compliance narratives. Together this provides the evidence that Q-SLICE works by reliably exposing quantum risks in theory and practice. However, results are conditional on current device noise profiles and may improve with error correction and fault-tolerant architectures.

The comparison between simulator and hardware underscores the necessity of hardware runs to capture realistic threat surfaces. Simulators show what *should* happen; hardware shows what *does* happen under noisy, adversarial conditions. This distinction is critical for understanding the threat to and from quantum computers. Q-SLICE therefore stands as the first framework to demonstrate quantum threats both in theory and in practice, supporting audit preparation through measurable evidence of quantum threat exposure.

The GenX test (**Appendix 5**) was conducted primarily to support parallel research assessing whether an alternative quantum architecture exhibited reduced noise characteristics relative to conventional platforms. Within this context, the Q-SLICE Threat Harness was used as a comparative evaluation mechanism rather than as the subject of the experiment. A secondary outcome of this work was the demonstration that the Q-SLICE threat harness could be executed successfully against different quantum architecture, indicating that the threat model is not bound to a single simulator or architectural assumption. The test remains limited in scope but did use the hardware tests performed in this section to compare the GenX results.

Summary of Work

This integration fully embeds the Q-SLICE framework within the IBM Quantum platform, enabling genuine hardware execution instead of simulated or metaphorical quantum operations. This integration provides authenticated access to IBM backends, including systems with over 150 qubits and supports fallback simulation to ensure continuity when hardware queues are overloaded. The implementation includes a dedicated IBM Quantum API client, circuit generators for key quantum states (Bell, Hadamard, GHZ, Grover) and a metrics calculator that translates theoretical constructs (Φ , Δ , Γ) into operational telemetry.

A new suite of API endpoints has been established to manage experiments, list available backends and enumerate threat vectors. These endpoints form the backbone of the Q-SLICE Threat Lab, which now offers an interactive dashboard covering six categories of adversarial modelling: Quantum Exploitation, Subversion of Trust, Legacy Exploitation, Integrity Disruption, Coherence Attacks and Ecosystem Abuse. Each category is supported by real-time metrics and visual comparisons between clean and attacked distributions, providing an insight into the impact of quantum threats.

Collectively, these results demonstrate that Q-SLICE is not merely a conceptual taxonomy but is a testable framework capable of producing measurable adversarial signatures.

Q-SLICE Threat Model

- Quantum adversaries introduce new threat classes such as coherence attacks, integrity disruption and ecosystem abuse.
- Legacy exploitation remains the most immediate risk, especially in RSA/ECC systems.
- Q-SLICE provides a taxonomy for modelling quantum-enabled adversarial scenarios.
- Scenario modelling helps organisations anticipate quantum threats before they materialise.
- Boards should demand Q-SLICE mapping of assets to ensure visibility of quantum risks.
- The Q-SLICE Threat Harness validates the Q-SLICE threat model as a practical tool for researchers, organisations and educators.

QUANTA Framework



QUANTA™
Quantum Universal Architecture
for Next-Gen Threat Assurance

Building on the limitations identified in existing frameworks, this section introduces a Quantum Security Framework designed to integrate with rather than replace established governance models. As quantum security cannot rely on predicting adversarial behaviour or extrapolating from historical attack data. Classical security models assume that threats can be deduced from known principles or induced from observed incidents. Neither assumption holds in the quantum context. There is no empirical dataset of quantum cyberattacks and the behaviour of quantum adversaries will not mirror classical patterns. This makes prediction-based security fundamentally unsuitable for quantum-era risk.

Condition-based security offers an alternative philosophy. Instead of attempting to forecast specific attacks, it focuses on shaping the present conditions under which systems operate so that harmful action becomes difficult, detectable or strategically irrational for an adversary. The emphasis shifts from “What attack will occur?” to “What conditions must be engineered so that, even if an attack occurs, the system remains resilient?”

In quantum contexts, condition-based security matters because the most serious risks such as HNDL, HNFL and long-term trust collapse and unfold over time horizons, far beyond traditional incident-response cycles. These threats exploit system conditions (long-lived cryptography, static trust anchors, unpatchable

devices) rather than discrete vulnerabilities. By focusing on conditions rather than predictions, organisations can build defences that remain effective even when adversaries possess capabilities that cannot yet be observed or measured.

Q-SLICE and QUANTA operationalise this philosophy. Q-SLICE identifies the conditions under which quantum-enabled adversaries could rationally cause harm, formalising these into a taxonomy that anticipates future attack classes. QUANTA translates these conditions into actionable controls that shape organisational posture from cryptographic agility and lifecycle governance to long-term confidentiality protection and trust-chain resilience. Together, they demonstrate how condition-based security can be engineered into real-world systems, providing a practical pathway for quantum-resilient design.

The **QUANTA** framework is a modular and scalable control architecture designed to help organisations prepare for, defend against and transition through the emerging threats posed by quantum computing. It recognises that quantum computing presents a risk to widely deployed cryptographic systems and responds with a practical, actionable set of controls built around international best practice.

QUANTA bridges the gap between lightweight assurance schemes such as **Cyber Essentials** and comprehensive standards like **ISO/IEC 27001** and **NIST CSF**. It provides a structured, resource-sensitive control model that public and private sector organisations can adopt in phases, enabling quantum resilience across eight functional domains. These domains contain 40 discrete controls mapped directly to **NIST CSF 2.0**, **CIS Controls v8** and **ISO/IEC 27001:2022**.

Each control can be implemented independently or combined within layered security models, following a ‘Lego Security’ approach that allows organisations to assemble quantum-resilient architectures according to their maturity, sector constraints and operational priorities. The domains span Cryptographic Resilience, Governance and Risk, Security Architecture and Design, Monitoring and Assurance, Training and Awareness, Supply Chain Dependencies, Data Protection and

Confidentiality as well as Framework Alignment. Together, they address the full cybersecurity lifecycle and anticipate long-term requirements for resisting quantum-era adversaries.

The framework directly addresses the threats posed by Shor's algorithm, which undermines RSA and ECC and Grover's algorithm, which weakens symmetric encryption and hashing. By anticipating these risks through policy, architecture and training, QUANTA supports a structured transition to post-quantum cryptographic readiness. It accommodates early-stage awareness, hybrid cryptographic deployments using NIST PQC finalists such as Kyber, SLH-DSA and ML-DSA and full migration planning to long-term quantum-resistant environments. QUANTA also encourages adoption of open standards such as the Open Quantum-Safe project and promotes flexible, outcome-driven controls suitable for audit, compliance and regulatory strategies.

While concepts such as Survivability-Informed Technical Governance (SITG) and Cryptographic Bill of Materials (CBOM) have emerged in practitioner literature, they remain under-developed in academic research. QUANTA aligns naturally with survivability principles but develops its governance logic independently, grounded in the threat taxonomy established by Q-SLICE.

QUANTA is intentionally designed as a modular, plug-and-play security framework rather than a prescriptive architecture. Organisations vary widely in maturity, regulatory obligations, sector constraints and exposure to quantum-era threats; therefore, a rigid, sequential model would fail to accommodate real world diversity. QUANTA's forty interoperable controls function as adaptable building blocks—each independently deployable, collectively composposable and compatible with established frameworks such as NIST CSF, ISO/IEC 27001 and CIS Controls v8. The 'Lego security' philosophy ensures that QUANTA can be adopted incrementally, integrated selectively, or used as a standalone quantum-resilient architecture, enabling organisations to tailor their security posture without requiring wholesale

transformation. The framework's design reflects a deliberate emphasis on flexibility, interoperability and future-proofing in anticipation of evolving quantum-era risks.

Condition-Based Security

Rather than asking "How likely is this event?", QUANTA asks "Under what conditions does this failure become possible?" This shift is essential in quantum contexts, where the emergence of cryptographically relevant capability may occur abruptly and without observable precursors.

Condition-based security enables organisations to govern exposure even when timelines are uncertain, by focusing on system states, dependencies and fragility thresholds.

Fragility Over Resilience

Classical security frameworks emphasise resilience: the ability to recover after compromise. Quantum security prioritises fragility, recognising that some failures cannot be undone. Once encrypted data is decrypted retrospectively, confidentiality is permanently lost.

QUANTA therefore treats certain assets and processes as intolerant to failure, requiring preventative governance rather than reactive control.

Possibility Versus Probability

In quantum threat modelling, possibility is often more relevant than probability. A low-probability event with catastrophic and irreversible impact must still be governed if the enabling conditions exist.

QUANTA explicitly incorporates possibility-based reasoning, allowing organisations to prioritise controls based on exposure rather than forecast confidence.

Implications for Governance

These philosophical foundations result in a framework that:

- Prioritises early action over reactive remediation
- Supports executive decision-making under uncertainty

- Aligns technical controls with strategic risk tolerance

The remainder of the QUANTA framework translates these principles into practical governance domains, controls and scoring mechanisms.

The QUANTA framework is a modular and scalable control framework designed to help organisations prepare for, defend against and transition through the emerging threats posed by quantum computing. It recognises that the rise of quantum computing presents a critical risk to widely deployed cryptographic systems and responds with a practical, actionable set of controls built around international best practices.

The framework is developed to bridge the gap between lightweight assurance schemes like Cyber Essentials and comprehensive security standards such as ISO/IEC 27001 and NIST CSF. QUANTA offers a structured, modular control architecture that enables public and private sector bodies alike to tailor their post-quantum strategies in a phased and resource-sensitive manner. The core focus is on enabling quantum resilience across eight functional domains, with 40 discrete security controls that map directly to NIST CSF 2.0, CIS Controls v8 and ISO/IEC 27001:2022.

Each control in the QUANTA framework is designed for either standalone implementation or combined deployment across layered security models, described internally as a 'Lego Security' approach. This modular design ensures that both large-scale enterprises and smaller public sector bodies can adopt quantum-resilient measures according to their level of maturity and sectoral constraints.

A modular approach to frameworks often delivers the most effective results. Much like a Lego kit, which provides a structured model when built according to instructions. The kit though, consists of individual components that can be assembled into countless alternative designs, frameworks offer similar flexibility.

They can be decomposed, mixed and adapted to suit different organisational needs. Organisations may choose to adopt a framework in its entirety, selectively integrate elements from multiple sources, or implement only the most relevant controls. This adaptability ensures that risk management remains practical, effective and aligned with business objectives, rather than becoming a rigid, checkbox-driven compliance exercise.

The eight domains covered by QUANTA include Cryptographic Resilience, Governance and Risk, Security Architecture and Design, Monitoring and Assurance, Training and Awareness, Supply Chain Dependencies, Data Protection and Confidentiality and Framework Alignment. Each domain addresses key aspects of the cybersecurity lifecycle and anticipates long-term strategic requirements for resisting quantum-era adversaries.

The framework particularly addresses the threats posed by Shor's algorithm, which undermines RSA and ECC and Grover's algorithm, which weakens symmetric encryption and hash functions. By anticipating and mitigating these threats through policy, architecture and training, QUANTA seeks to enable a smooth and strategic transition to post-quantum cryptographic readiness.

QUANTA is designed to evolve. It supports early-stage awareness activities, hybrid cryptographic deployment using NIST PQC finalists (such as Kyber, SLH-DSA and ML-DSA) and full migration planning to long-term quantum-resistant environments. It encourages adoption of open standards like the Open Quantum Safe project and promotes the use of flexible, outcome-driven controls suitable for audit, compliance and national regulatory strategies.

While Survivability-Informed Technical Governance (SITG) has been introduced in practitioner literature as a governance-oriented approach to managing quantum-era risk, it is not yet formalised in academic research or standards bodies. QUANTA aligns naturally with the survivability principles expressed in SITG, though

the governance logic within QUANTA is developed independently and grounded in the Q-SLICE threat model.

Condition-Based Security, Fragility and Possibility

Security practice within QUANTA is grounded in the understanding that uncertainty is an inherent feature of organisational life, but that uncertainty can be shaped, constrained and made operationally comfortable. QUANTA does not attempt to eliminate uncertainty or convert it into probabilistic forecasts. Instead, it focuses on engineering present-state conditions so that harmful actions become increasingly difficult, increasingly detectable or operationally impossible. This approach positions security as a discipline concerned with the management of conditions rather than the prediction of events and it rejects the idea that future-oriented probability models can meaningfully guide decisions about adversarial behaviour.

A central principle in QUANTA is the distinction between the inherent properties of an organisational asset or process and the contextual circumstances that determine whether harm is feasible. QUANTA treats fragility as an intrinsic characteristic of a system, identity, dependency or cryptographic posture. A property that exists regardless of whether an adversary is present. Fragility is not inherently negative; it may be a necessary consequence of design, purpose or operational constraints. What matters is not whether fragility exists, but whether the surrounding conditions allow that fragility to be exploited. This is where QUANTA introduces contextual analysis, as vulnerability is not a static flaw but a state that emerges only when specific conditions converge to make harm possible.

This condition-based framing is reflected throughout QUANTA's architecture. The framework evaluates the feasibility of harmful action by analysing the conditions that enable it: access pathways, detectability gaps, dependency structures, identity exposure and cryptographic weaknesses. Harm is understood as the outcome of condition convergence rather than the result of random chance or statistical likelihood. QUANTA's scoring model therefore measures the fragility of current operational conditions and the degree to which those conditions could enable

adversarial action. This produces a defensible, present-state assessment that avoids the speculative nature of probability-driven risk models.

The Five Ds within QUANTA of Deter, Detect, Deny, Delay and Defend all operate as coordinated condition-shaping mechanisms, but always under a detection-first philosophy. Detection is the foundational control because no other security function can operate effectively without visibility. By increasing observability across systems, identities, dependencies and cryptographic states, detection reduces the conditions under which harmful action can occur unnoticed. It transforms uncertainty into actionable awareness, ensuring that fragility cannot silently transition into exploitation.

Building on this visibility, the remaining Ds act to reshape the conditions that make harmful action feasible. Denial and delay modify access and opportunity structures, increasing the effort, time and exposure required for an adversary to progress. Defence reduces the feasibility of harm even when access is achieved, ensuring that fragility does not automatically translate into compromise. Deterrence influences the cost-benefit conditions that shape adversarial intent, making harmful action less attractive when detection and defensive controls increase the likelihood of failure or exposure.

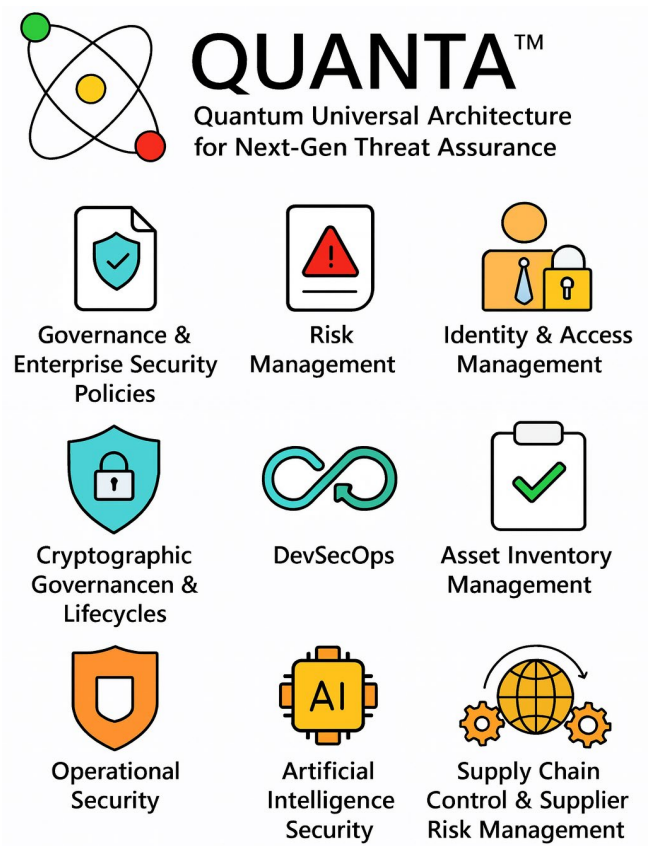
Together, these mechanisms form a coherent, condition-based model for reducing the possibility of harm. Rather than attempting to predict when or whether an attack might occur, QUANTA focuses on altering the present-state conditions that determine whether harmful action is possible at all.

This leads to a fundamental shift in the central question of security. Instead of asking "How secure are we?", which implies an abstract and unmeasurable state, QUANTA asks "How fragile are our current conditions?". This reframing allows organisations to identify where their operational environment is most susceptible to disruption and to determine how much protection is required to compensate for or reduce that fragility. It also provides a clear, measurable basis for prioritisation:

resources are directed toward the conditions that most directly influence the feasibility of harmful action, with detection serving as the anchor for all subsequent protective measures.

By grounding security in condition analysis, fragility assessment and possibility reduction, QUANTA offers a model that is both operationally pragmatic and academically defensible. It avoids the pitfalls of probabilistic risk management and instead provides a structured, present-state method for understanding and shaping the conditions under which harm can occur. This alignment ensures that QUANTA remains focused on its core purpose of enabling the secure creation and preservation of organisational value. By managing the conditions that determine whether harmful actions are possible.

Figure 12 QUANTA control overview



The QUANTA Framework defines a comprehensive, unified set of forty-plus controls designed to address the evolving threat posed by quantum computing to modern information security. This framework aligns with recognised standards such as ISO/IEC 27001:2022, CIS Controls v8 and the NIST CSF to ensure organisations can achieve robust, standardised security ensuring preparation for the quantum era.

At its core, QUANTA promotes governance and policy foundations that explicitly address quantum risk. Organisations are required to adopt an enterprise-wide security policy embedding cryptographic agility and to establish governance processes that include quantum-focused threat modelling and a dedicated

Quantum Security Working Group. This ensures security planning is proactive, structured and able to evolve as new quantum algorithms, standards and threats emerge.

Risk management in QUANTA is designed to be forward-looking, incorporating quantum-specific risk assessments into the broader enterprise risk framework. Organisations must evaluate the impact of "Harvest Now, Decrypt Later" threats, model adversaries with access to quantum cryptanalysis and prioritise controls based on the sensitivity and longevity of data. Supplier risk management is a critical component: third parties must demonstrate readiness for PQC adoption, with contractual requirements for compliance and regular assessments of their cryptographic posture.

The asset management component of the framework requires maintaining a detailed inventory of assets and data, identifying those that depend on quantum-vulnerable cryptography and prioritising them for transition. This also includes classifying data based on confidentiality lifespan—so organisations can prioritise immediate protection for high-value data with long-term sensitivity.

Identity and access management (IAM) controls within QUANTA emphasise the move to post-quantum secure authentication. Organisations are expected to deploy IAM solutions that support PQC-enabled protocols, enforce Multi-Factor Authentication with quantum-resistant key exchanges and design hybrid schemes to ensure a smooth transition. Zero Trust Architecture is similarly required to be PQC-aware, mandating post-quantum cryptography in mutual authentication processes and continuous verification of identity.

A major pillar of QUANTA is its comprehensive cryptographic governance and lifecycle management. Organisations must maintain a detailed inventory of cryptographic assets, identify vulnerabilities to quantum attacks and enforce crypto agility to allow for seamless upgrades to PQC algorithms. Controls specify adopting hybrid deployment strategies (combining classical and PQC algorithms

during transition), using PQC-based digital signatures and developing a formal cryptographic migration roadmap. Encryption for data at rest and in transit must be planned to migrate to PQC-resistant algorithms, including post-quantum VPNs, secure boundary protocols and TLS configurations that support hybrid key exchanges using NIST PQS cyphers.

Operational security controls are tailored for the quantum threat model. Security operations must integrate monitoring for signs of quantum-enabled attacks, such as unusual patterns in key negotiation failures or SIEM alerts indicative of advanced cryptanalysis attempts. Incident Response plans must include specific playbooks for quantum-compromise scenarios, including mass cryptographic key revocation and rapid deployment of PQC certificates. Continuous vulnerability management and penetration testing are required to assess and mitigate quantum-relevant weaknesses, such as weak cryptographic libraries or supply-chain inserted malicious code.

A particular focus is placed on DevSecOps pipelines, container security and AI systems. Controls for DevSecOps mandate quantum-safe secure code signing, cryptographic agility in build pipelines, vulnerability scanning of dependencies for quantum-vulnerable algorithms and runtime attestation for container workloads. AI/ML security controls require the protection of training data with PQC encryption, enforcing model provenance with quantum-resistant signing and ledger tracking and hardening AI APIs against adversarial attacks that could be augmented by quantum computing. Organisations are required to monitor AI systems for signs of tampering, ensure integrity through post-quantum cryptographic measures and maintain a Model Bill of Materials detailing cryptographic dependencies.

The supply chain is also explicitly addressed. QUANTA requires organisations to evaluate third-party suppliers for PQC readiness, enforce cryptographic agility in contracts and maintain audit rights for PQC migration progress. Supplier assessments must include checks for PQC support in cryptographic libraries and

cloud services, ensuring no part of the extended enterprise becomes a quantum-exploitable weak point.

Finally, QUANTA recognises that achieving quantum resilience is an ongoing process with potential for step changes as technology matures. The framework mandates continuous monitoring of emerging PQC standards, maintaining KPIs to track migration progress and integrating quantum security into the organisation's overall continuous improvement cycle. Staff awareness and technical training are required to build internal capabilities for managing PQC transitions and understanding quantum threats as they fully emerge.

Below is an overview of the 40 controls within QUANTA which will be covered in more detail with implementation recommendations in the next chapter.

Governance, Risk and Compliance

1. Information Security Policy & Governance

Establish, maintain and enforce information security policies aligned with ISO/IEC 27001, CIS18, NIST CSF and post-quantum considerations.

2. Risk Management Framework with Quantum Threat Integration

Implement a risk management process that evaluates traditional and quantum-computing related threats to cryptographic assets and sensitive data.

3. Compliance with Regulatory & PQC Standards

Ensure compliance with industry regulations, data protection laws and emerging quantum-resilient cryptography standards (NIST PQC standardisation).

4. Asset Inventory & Quantum-Sensitive Data Classification

Maintain an updated inventory of assets, classifying data and systems based on sensitivity, with special identification of quantum-vulnerable assets (e.g., encrypted data with long-term confidentiality needs).

5. Supply Chain Security with Quantum Threat Assessments

Assess and manage supply chain risks, ensuring third parties are evaluated for quantum-resilient cryptographic practices.

Identity, Access and Authentication

6. Identity and Access Management (IAM)

Implement robust IAM controls, including role-based access, least privilege and segregation of duties.

7. Post-Quantum Cryptographic Authentication

Deploy authentication mechanisms that are resistant to quantum attacks (e.g., PQC algorithms for key exchange and digital signatures).

8. Multi-Factor Authentication (MFA) with PQC Readiness

Enforce MFA for all critical access points, prioritising methods resilient to future quantum adversaries.

Cryptography and Data Protection

9. Cryptographic Governance and Lifecycle Management

Establish policies for the lifecycle management of cryptographic assets, incorporating migration plans to PQC algorithms.

10. Data Encryption (In-Transit & At-Rest) with PQC Transition Strategy

Encrypt sensitive data using current best practices while planning for migration to quantum-safe encryption standards.

11. Hybrid Cryptographic Solutions Deployment

Adopt hybrid cryptography (classical + quantum-resistant) for high-value data and communication channels.

12. Data Masking and Tokenisation

Apply data masking and tokenisation techniques to protect sensitive information from quantum decryption risks.

Network Security

13. Network Segmentation & Micro-Segmentation

Enforce segmentation to contain lateral movement, considering quantum threats to encrypted network traffic.

14. Post-Quantum VPN and Secure Communications

Implement VPN solutions that support PQC-based key exchange protocols.

15. Boundary Defences & Quantum-Safe Protocols

Deploy firewalls and secure gateways configured to support future quantum-resilient protocols (e.g., TLS 1.3 with PQC enhancements).

Security Operations and Incident Response

16. Security Monitoring & Detection (Quantum-Enhanced Threats)

Deploy SIEM and analytics to detect traditional and emerging quantum-enabled attack patterns.

17. Incident Response Plan with Quantum Breach Scenarios

Update IRP to include response procedures for quantum-related cryptographic breaches and data exposure.

18. Vulnerability Management with PQC Impact Analysis

Conduct regular vulnerability assessments that also identify cryptographic weaknesses exploitable by quantum computing.

19. Penetration Testing Incorporating Quantum Threat Models

Perform penetration testing that simulates quantum-capable adversary scenarios.

20. Threat Intelligence with Focus on Quantum Advancements

Incorporate quantum computing threat intelligence into security operations and situational awareness.

Endpoint and Application Security

21. Endpoint Protection with PQC-Capable Cryptographic Modules

Ensure endpoints use cryptographic libraries compatible with PQC algorithms.

22. Secure Software Development Lifecycle (SSDLC) with PQC Requirements

Integrate PQC considerations into SSDLC, including code review and secure coding practices for quantum resilience.

23. Application Security Testing with Quantum Cryptanalysis Scenarios

Enhance application security testing to evaluate resistance against quantum cryptanalytic techniques.

Business Continuity and Disaster Recovery

24. Business Continuity Planning with Quantum Data Risk Considerations

Update BCP to address long-term data confidentiality risks from stored encrypted data susceptible to future quantum attacks.

25. Disaster Recovery Plan Supporting PQC Transitions

Ensure DR plans accommodate rapid deployment of PQC solutions in case of quantum cryptanalytic incidents.

Physical and Environmental Security

26. Physical Access Controls with Quantum-Protected Authentication

Enhance physical access systems with digital authentication protocols resistant to quantum attacks.

27. Secure Disposal of Cryptographic Hardware Assets

Implement procedures for secure disposal of cryptographic hardware vulnerable to quantum attacks.

Awareness and Training

28. Security Awareness Programme Including Quantum Threats

Educate staff on the implications of quantum computing on security, including cryptography and data confidentiality.

29. Specialised PQC Training for Technical Teams

Provide in-depth training on PQC standards, migration strategies and implementation practices.

Third-Party and Cloud Security

30. Cloud Security Posture Management with PQC Considerations

Monitor and manage cloud environments ensuring cryptographic agility for PQC deployment.

31. Third-Party Assurance with Quantum Readiness Assessment

Incorporate quantum threat readiness into third-party security assessments and contracts.

Security Architecture and Design

32. Zero Trust Architecture with PQC Support

Design and implement Zero Trust principles with a roadmap to integrate PQC algorithms.

33. Cryptographic Agility in Architecture Design

Ensure security architecture supports cryptographic agility for seamless migration to PQC.

34. Secure Protocol Design with Quantum-Resilient Standards

Adopt and design secure communication protocols that are quantum-resistant by design.

Emerging Technologies and Innovation

35. Quantum Key Distribution (QKD) Evaluation and Pilots

Assess and pilot QKD technologies where feasible for critical data transmissions.

36. Digital Certificate Management with PQC-Ready CAs

Ensure Public Key Infrastructure (PKI) and Certificate Authorities (CAs) are ready for quantum-safe certificates.

37. Blockchain Security with Post-Quantum Cryptography

Evaluate and transition blockchain applications to quantum-resilient cryptographic schemes.

Monitoring, Metrics and Continuous Improvement

38. Continuous Monitoring of PQC Standards & Threat Landscape

Establish a process to track developments in PQC standards and evolving quantum threats.

39. Key Performance Indicators (KPIs) for PQC Adoption

Define KPIs to measure progress in PQC migration and quantum resilience.

40. Continuous Improvement with Quantum Security Reviews

Regularly review and improve the security posture, focusing on quantum readiness and resilience.

QUANTA Use Cases

Critical National Infrastructure: QUANTA supports highly regulated and high-assurance environments such as defence, healthcare and finance.

- **Public Sector Bodies:** Includes lightweight controls compatible with Cyber Essentials and public procurement policies.
- **Private Enterprises:** Encourages strategic PQC planning aligned with NIST and ISO readiness roadmaps.
- **Academic and Research Institutions:** Supports controlled experimentation with hybrid cryptographic deployments and quantum-safe protocol testing.

Integration Path

QUANTA is designed to be implemented in three progressive tiers:

- **Awareness and Preparation** Establish a cryptographic inventory, perform a quantum risk assessment and provide executive briefings.
- **Hybrid Transition** Deploy hybrid crypto in TLS and VPNs and initiate pilot PQC deployments using standardised algorithms.
- **Quantum-Resilient Maturity** Complete migration of all quantum-vulnerable cryptography, with full control validation, supply chain readiness and sector compliance alignment.

Table 9 Summary of QUANTA Benefits

Feature	Benefit
Modular	Flexible implementation based on need and maturity
Standards-Aligned	Easily integrated into ISO/NIST/CIS governance
Quantum-Specific	Addresses real risks such as harvest-now-decrypt-later
Scalable	Suitable for SMEs, enterprises and government bodies
Future-Ready	Designed for both current NISQ threats and post-Q-Day scenarios

QUANTA Framework Quantum-Resilient Controls: Cross-Reference Mapping

This section provides a detailed mapping of the 40 quantum-resilient security controls defined in the QUANTA framework against leading cybersecurity standards:

- NIST Cybersecurity Framework (CSF) 2.0
- CIS Critical Security Controls v8 (CIS 18)
- ISO/IEC 27001:2022 (Annex A)

Each QUANTA control is presented with its corresponding mapping. Following that, the same mappings are reversed and grouped under each external framework.

Controls Grouped by QUANTA Domain

Table 10 QUANTA Mapped to NIST CSF, ISO/IEC 27001 and CIS18

QUANTA Control	Description	NIST CSF 2.0 Mapping	CIS v8 Mapping	ISO/IEC 27001:2022 Mapping
QC-01	Cryptographic Inventory Management	ID.AM-01, PR.DS-01	2.4, 3.4	A.8.9, A.8.24
QC-02	Quantum Readiness Assessment	ID.RA-01, ID.RA-06	1.4, 3.3	A.5.4, A.8.24
QC-03	Algorithm Classification and Mapping	PR.IP-12, PR.DS-01	3.4, 14.4	A.8.25
QC-04	Cryptographic Agility Planning	PR.IP-12, PR.IP-13	3.11	A.8.25, A.8.24
QC-05	Post-Quantum Cryptographic Algorithm Implementation	PR.DS-01, PR.DS-06	3.12	A.8.25, A.10.1
QC-06	Hybrid Cryptographic Deployment	PR.DS-01, PR.IP-12	3.12	A.8.25
QC-07	Quantum-Resilient Key Lifecycle Management	PR.AC-05, PR.DS-03	3.3	A.8.24, A.8.28

QC-08	Secure Boot Processes Using PQC Signatures	PR.DS-06, PR.PT-03	4.7	A.8.9, A.8.11
QC-09	Quantum Threat Modelling Integration	ID.RA-1, ID.RA-3	4.1, 4.3	A.5.4, A.5.9
QC-10	Board-Level Quantum Risk Oversight	ID.GV-1, ID.GV-3	17.1	A.5.1, A.6.2
QC-11	Dedicated Quantum Risk Register	ID.RA-2, ID.RM-1	4.1	A.5.4, A.8.28
QC-12	Quantum Threat Impact Assessments	ID.RA-3, ID.RA-6	4.3	A.5.4, A.8.28
QC-13	Sector-Specific Quantum Threat Profiling	ID.RA-4, ID.RM-2	12.1	A.5.9, A.5.14
QC-14	Defence-in-Depth Quantum Control Architecture	PR.IP-1, PR.AA-1	4.1, 13.1	A.5.23, A.8.28
QC-15	Secure Software Design with PQC	PR.DS-6, PR.IP-3	16.1, 4.8	A.5.9, A.8.25
QC-16	Post-Quantum TLS 1.3 Extensions	PR.DS-2, PR.DS-5	4.3, 14.4	A.8.25, A.8.27
QC-17	Post-Quantum VPN Infrastructure	PR.DS-2, PR.PT-4	4.7, 4.11	A.8.24, A.8.27

QC-18	Post-Quantum IoT and Mobile Security	PR.PT-2, PR.DS-3	4.4, 4.9	A.5.20, A.8.27
QC-19	PQC-Ready Certificate Management	PR.DS-1, PR.DS-4	4.8, 10.5	A.8.24, A.8.25
QC-20	PQC Control Metrics and KPIs	ID.GV-2, PR.IP-7	17.4	A.5.3, A.5.4
QC-21	Continuous Validation of PQC Controls	DE.CM-8, PR.IP-11	4.9, 8.2	A.5.36, A.8.29
QC-22	Quantum Scenario Attack Drills	RS.IM-1, RS.IM-2	18.1	A.5.31, A.5.32
QC-23	Quantum-Specific Penetration Testing	DE.CM-8, PR.IP-12	18.2	A.5.36, A.5.25
QC-24	Integrity Assurance Using Quantum-Resilient Hashes	PR.DS-6, PR.IP-3	3.10, 4.10	A.8.25, A.8.27
QC-25	Organisation-Wide Quantum Security Awareness	PR.AT-1, PR.AT-2	14.1, 14.4	A.6.3
QC-26	PQC Development Training for Engineers	PR.AT-3, PR.IP-6	14.6, 16.2	A.6.3, A.8.25

QC-27	Quantum Security for Architects and CISOs	PR.AT-4, ID.GV-3	14.5, 17.2	A.5.1, A.6.3
QC-28	Executive-Level Quantum Strategy Briefings	ID.GV-1, ID.RM-3	17.1	A.5.1, A.5.4
QC-29	Quantum Readiness Assessment of Third Parties	ID.SC-1, ID.SC-2	15.2	A.5.22, A.5.19
QC-30	PQC Security Clauses in Procurement Contracts	ID.SC-4, ID.GV-3	15.4	A.5.19, A.5.20
QC-31	External Certificate and PKI Assurance	PR.DS-1, PR.DS-4	4.11, 10.5	A.8.24, A.8.25
QC-32	Quantum-Informed Data Classification	ID.AM-5, PR.DS-1	3.4, 3.5	A.5.12, A.5.7
QC-33	Long-Term Confidentiality Protection Measures	PR.DS-2, PR.DS-6	3.3, 3.11	A.8.24, A.8.25
QC-34	PQC Encryption of Data at Rest and in Transit	PR.DS-1, PR.DS-3	4.3, 3.13	A.8.24, A.8.25
QC-35	Historical Data Risk Audit	ID.RA-6, PR.DS-5	4.4	A.5.7, A.8.27

QC-36	Integration Mapping with Existing Frameworks	ID.GV-2, ID.RM-2		A.5.1, A.5.2
QC-37	Modular and Scalable Control Deployment	PR.IP-12, ID.GV-3		A.5.6, A.5.23
QC-38	Support for Open Quantum Safe Ecosystem	PR.IP-4, PR.PT-3	16.2	A.5.9, A.5.14
QC-39	Business Case Templates for Quantum Security	ID.GV-1, ID.RM-1	17.1	A.5.1, A.5.4
QC-40	Monitoring of Quantum Policy and Regulation	ID.RM-3, ID.GV-5	17.3	A.5.2, A.5.32

QUANTA IMPLEMENTATION

To implement the QUANTA framework effectively, begin by establishing strong governance and securing senior leadership commitment. Define the scope and objectives clearly, ensuring they align with existing security policies and risk management processes. Assign specific roles and responsibilities for overseeing quantum readiness, cryptographic governance and migration planning to ensure accountability and clear ownership.

Next, conduct a thorough assessment of your current state. Inventory all cryptographic assets, systems and processes, identifying which rely on vulnerable algorithms like RSA or ECC. Classify data based on sensitivity, paying special attention to any information with long-term confidentiality requirements that could be at risk from HNDL attacks. Extend this assessment to suppliers and cloud services to understand third-party cryptographic dependencies and readiness.

Once you have a clear picture, develop or update your security policies to mandate cryptographic agility and post-quantum readiness. Create a formal roadmap with realistic, phased milestones covering inventory management, crypto-agility improvements, hybrid deployments and eventual transitions to fully post-quantum algorithms. This roadmap should align with emerging industry standards such as NIST's PQC recommendations this includes ongoing updates and changes to ensuring ongoing PQC alignment.

Integrate these principles into your security architecture and design processes. Require new systems and upgrades to support crypto agility by design, enabling flexible algorithm negotiation and easy replacement of vulnerable cryptography.

Ensure Zero Trust Architecture strategies account for quantum risks and plan for secure protocol design that can accommodate quantum-resistant algorithms. Upgrade your cryptographic practices by beginning to deploy hybrid solutions that combine classical and quantum-safe algorithms for key exchange and signatures, especially in critical systems and communication channels. Plan updates to encryption for data-at-rest and in-transit and ensure key management systems and Public Key Infrastructure (PKI) can handle quantum-ready certificates.

At the operational level, strengthen monitoring and detection to identify potential quantum-related threats, such as unusual data harvesting behaviour. Update incident response and disaster recovery plans to include procedures for quantum-related cryptographic breaches, emergency key rotations and rapid PQC deployment in the event of a breakthrough in quantum cryptanalysis.

Engage and train your workforce to build awareness and capability. Include quantum threat education in general security awareness training so all staff understand the basics of the risk. Provide specialised, in-depth PQC-focused training for technical teams covering secure coding practices, standards, migration strategies and cryptographic lifecycle management.

Extend these requirements to suppliers and cloud providers by including PQC readiness in your third-party risk management processes, contracts and security assessments. Work with vendors to ensure their roadmaps include support for PQC standards and that they can demonstrate crypto agility in their services.

Finally, establish processes for continuous monitoring, measurement and improvement. Define clear Key Performance Indicators (KPIs) to track PQC adoption progress, conduct regular reviews of cryptographic inventories and supplier readiness and keep abreast of evolving quantum threats and PQC standardisation developments. Where feasible, pilot innovative solutions such as Quantum Key Distribution (QKD) for high-value communication channels and plan

the transition of blockchain applications to quantum-resistant cryptographic schemes.

To summarise implementing QUANTA is about embedding quantum resilience across your entire security programme. From policy and architecture through operations, supply chain and staff culture. While preparing for an orderly, phased migration to post-quantum cryptography then ongoing assessment. Below is a more detailed implementation process that can be reordered and changed depending on organisational priorities and requirements.

Governance, Risk and Compliance

Information Security Policy & Governance

This first control requires establishing and maintaining a comprehensive information security policy framework that explicitly considers both classical and quantum-era threats. It should articulate security objectives, principles, roles and responsibilities and requirements for cryptographic management, including migration to post-quantum cryptography (PQC).

Implementation Guidelines:

- Align policies with ISO/IEC 27001 (including Annex A.5 for policy requirements), CIS Controls v8 and NIST CSF 2.0 governance functions.
- Include dedicated sections on cryptographic key management, crypto agility and PQC transition strategies.
- Define ownership and approval processes to ensure policies are regularly reviewed and updated to reflect evolving threats, including quantum advances.
- Establish a security steering committee or governance board with clear accountability for tracking and discussing quantum-readiness programmes. Including impact and value to the organisation.

Best Practice:

- Integrate quantum risk considerations into all relevant policies, not just cryptographic ones such as supplier security, incident response and access and authentication.

- Maintain version-controlled policy documentation accessible to all stakeholders.
- Educate leadership on quantum threats and keep them updated to ensure buy-in for policy changes and support value proposition.

Risk Management Framework with Quantum Threat Integration

This control calls for a structured approach to identifying, assessing, treating and monitoring risks, explicitly including quantum-computing-enabled threats to cryptographic systems and long-lived data.

Implementation Guidelines:

- Build on existing frameworks such as ISO 27005, NIST SP 800-30, or FAIR.
- Integrate quantum-specific risk scenarios, such as HNDL attacks, into regular threat modelling.
- Assess likelihood and impact of cryptographic failure under future quantum capabilities, considering time-to-compromise analysis.
- Maintain a risk register that tracks mitigation strategies and ownership for quantum-related risks.

Best Practice:

- Conduct periodic quantum threat workshops with key stakeholders to refine scenarios and update the register.
- Make use of external threat intelligence on quantum computing developments.
- Include risk appetite and tolerance statements for quantum threats in corporate risk documentation.

Compliance with Regulatory and PQC Standards

Ensure organisational adherence to applicable regulations, industry standards and emerging requirements for quantum-resilient cryptography. Using up to date and relevant guidelines from the likes of NIST, NCSC and Microsoft.

Implementation Guidelines:

- Track relevant data protection laws such as GDPR that imply long-term confidentiality obligations and the impact this could have on data protection in a post-quantum era.

- Monitor PQC standardisation such as NIST, FIPS and other draft standards to plan cryptographic transitions.
- Include quantum readiness in audit and compliance frameworks, mapping controls to ISO/IEC 27001:2022, CIS Controls and NIST CSF 2.0 subcategories.
- Define compliance checkpoints for PQC migration in roadmaps.

Best Practice:

- Establish a register of legal and regulatory requirements with notes on quantum impact.
- Engage with regulators and industry groups to stay informed about emerging PQC compliance expectations.
- Include quantum migration milestones in internal and external audit scopes to maintain accountability.

Asset Inventory and Quantum-Sensitive Data Classification

Maintain a comprehensive, up-to-date inventory of assets, with clear classification of data and focus on systems that are vulnerable to quantum attacks, particularly those requiring long-term confidentiality or legacy systems using insecure or insecure cyphers.

Implementation Guidelines:

- Integrate asset management with CMDBs or ITAM tools to ensure completeness.
- Classify data by confidentiality impact, identifying “quantum-sensitive” assets such as encrypted PII, intellectual property, government or financial data with a 10-to-20-year confidentiality requirements.
- Tag cryptographic dependencies such as TLS endpoints, stored encrypted data, VPNs in the inventory with fixed review dates and what would trigger a review outside of an incident.
- Prioritise these assets for crypto agility and PQC migration planning.

Best Practice:

- Use data flow mapping to identify where quantum-sensitive data is created, stored and transmitted.

- Maintain a separate cryptographic inventory containing elements like algorithm types, key lengths, expiry dates as a living document with yearly reviews as a minimum.
- Review and update classifications annually or following major system changes.

Supply Chain Security with Quantum Threat Assessments

Manage supplier and third-party risks by incorporating assessments of their cryptographic practices and readiness for quantum threats.

Implementation Guidelines:

- Include quantum-resilient cryptography expectations in supplier contracts and security questionnaires.
- Assess supplier security programmes to ensure crypto agility and planned PQC adoption.
- Conduct third-party risk assessments that include quantum threat scenarios, particularly for critical suppliers handling sensitive data or cryptographic operations.
- Require attestations or evidence of PQC readiness where feasible.

Best Practice:

- Maintain a register of key suppliers with quantum security risk ratings.
- Collaborate with suppliers on joint cryptographic roadmaps.
- Align supply chain risk processes with NIST CSF 2.0 “Supply Chain Risk Management” categories, utilise NIST Cybersecurity Supply Chain Risk Management (C-SCRM) documents and ISO/IEC 27036-3.
- Conduct periodic reassessments, recognising the evolving nature of quantum risks and supplier capabilities.

Identity, Access and Authentication

Identity and Access Management (IAM)

This control establishes robust IAM practices to ensure users and systems have only the minimum necessary access. It enforces role-based access control (RBAC), least privilege and segregation of duties to reduce the risk of misuse or

compromise of credentials, especially as quantum-enabled threats could exploit compromised authentication to bypass cryptographic protections.

Implementation Guidelines:

- Define and maintain access control policies aligned with ISO/IEC 27001 Annex A.9 and CIS Control 6.
- Use centralised IAM platforms with strong auditing and reporting capabilities.
- Implement RBAC by assigning permissions based on job functions and responsibilities.
- Enforce principle of least privilege by regularly reviewing and removing unnecessary access rights. Including deprovision of accounts no longer required.
- Separate conflicting duties to prevent fraud and reduce the impact of a single credential compromise.
- Integrate IAM with HR processes to ensure timely provisioning and de-provisioning of accounts.

Best Practice:

- Automate access reviews and certification processes.
- Maintain comprehensive logs of IAM events, integrating them with SIEM solutions for monitoring.
- Establish incident response procedures for credential compromise, including post-quantum considerations.
- Regularly test IAM configurations for policy compliance and potential privilege escalation paths.

Post-Quantum Cryptographic Authentication

This control focuses on adopting authentication methods resistant to quantum-enabled attacks, such as those capable of breaking classical key exchanges or digital signatures. It ensures long-term security of authentication processes through the integration of post-quantum cryptographic algorithms.

Implementation Guidelines:

- Track the NIST PQC standardisation process for digital signature and key exchange algorithms.
- Evaluate existing authentication protocols such as TLS, HTTPS, IPsec and VPNs for quantum-vulnerable algorithms like RSA and ECDSA.
- Plan for or pilot hybrid authentication schemes combining classical and PQC methods where supported.
- Update internal cryptographic guidelines to include approved PQC algorithms once standards stabilise.
- Work with vendors to confirm support and timelines for PQC integration into authentication solutions.

Best Practice:

- Maintain a cryptographic inventory that identifies all authentication workflows dependent on vulnerable algorithms.
- Prioritise systems handling sensitive data or privileged access for PQC upgrades.
- Participate in industry working groups or early adopter programmes to stay ahead of implementation challenges.
- Conduct regular threat modelling to assess potential attack paths exploiting quantum cryptanalysis of authentication.

Multi-Factor Authentication (MFA) with PQC Readiness

This control enforces MFA for all critical access points, with an explicit focus on preparing for quantum-resilient methods. It aims to ensure that even if quantum computing breaks classical cryptographic elements of MFA, alternative factors or upgraded protocols mitigate the risk.

Implementation Guidelines:

- Require MFA for all privileged accounts, remote access and critical systems, following CIS Control 6 and NIST SP 800-63B guidance.
- Choose MFA solutions that support crypto agility, allowing easy migration to PQC-compatible factors like FIDO2/WebAuthn with PQC-ready backends.

- Evaluate and prioritise migration of MFA systems that rely on vulnerable public-key cryptography for key exchange or signatures.
- Include MFA quantum readiness in procurement criteria for authentication providers.
- Test fallback procedures to ensure continued secure access during cryptographic upgrades.

Best Practice:

- Use phishing-resistant MFA methods (e.g., hardware tokens, biometric-based solutions) that reduce reliance on vulnerable cryptographic channels.
- Maintain an inventory of MFA deployments, noting which methods and protocols they use.
- Educate users about upcoming changes to MFA processes required for quantum readiness.
- Coordinate MFA strategy with overall cryptographic inventory and PQC migration planning.

Cryptography and Data Protection

Cryptographic Governance and Lifecycle Management

This control establishes structured governance over the entire lifecycle of cryptographic assets—from selection and deployment to monitoring, rotation and decommissioning—with explicit integration of plans to migrate to post-quantum cryptographic (PQC) algorithms. It ensures that cryptographic practices are standardised, well-documented and agile in the face of evolving threats.

Implementation Guidelines:

- Develop and enforce a cryptographic policy aligned with ISO/IEC 27001 Annex A.10 and NIST SP 800-57.
- Maintain a cryptographic inventory cataloguing all algorithms, key lengths, expiration dates and dependencies.
- Define procedures for secure key generation, distribution, storage, rotation and destruction.

- Include crypto agility requirements in system design, supporting seamless upgrades to PQC algorithms.
- Establish a formal roadmap for PQC migration based on NIST PQC standardisation timelines and organisational risk assessments.

Best Practice:

- Perform regular cryptographic health checks or audits to validate policy adherence.
- Assign clear roles and responsibilities for cryptographic asset management.
- Integrate cryptographic lifecycle management with change management and configuration management systems.
- Include supplier cryptographic practices in governance requirements to ensure end-to-end security.

Data Encryption (In-Transit & At-Rest) with PQC Transition Strategy

This control requires robust encryption of sensitive data both in transit and at rest using current best practices, while explicitly planning and preparing for migration to quantum-safe encryption standards to counter future cryptanalytic attacks.

Implementation Guidelines:

- Enforce encryption requirements for all sensitive data at rest and in transit following NIST SP 800-53 and CIS Control 14.
- Use modern, recommended algorithms and key lengths such as AES-256, TLS 1.3 with strong and up to date cipher suites.
- Maintain a roadmap for transitioning to PQC standards, monitoring NIST and other authoritative bodies for approved algorithms.
- Conduct gap assessments to identify systems and applications dependent on vulnerable algorithms like RSA and ECC.
- Prioritise high-value or long-retention data for early PQC adoption planning.

Best Practice:

- Tag data based on confidentiality requirements and expected lifespan to prioritise PQC transition for long-term sensitive information.

- Design encryption solutions with crypto agility in mind to allow easy replacement of algorithms.
- Conduct regular reviews to ensure encryption policies reflect current best practices and emerging quantum-safe standards.
- Include encryption requirements in supplier contracts to maintain consistency across the supply chain.

Hybrid Cryptographic Solutions Deployment

This control focuses on adopting hybrid cryptography approaches that combine classical algorithms with quantum-resistant algorithms to ensure continuity and security during the transition to fully quantum-safe systems, particularly for high-value data and communication channels.

Implementation Guidelines:

- Evaluate protocols and solutions that support hybrid cryptographic modes like TLS with classical and PQC key exchange.
- Collaborate with vendors to identify and adopt products implementing hybrid strategies in line with early PQC recommendations.
- Prioritise deployment for critical systems and communication channels handling high-value or sensitive data.
- Develop policies specifying when and how hybrid cryptography should be applied to balance security, performance and interoperability.
- Include hybrid readiness as a requirement in new system procurement and architectural design reviews.

Best Practice:

- Stay informed about evolving best practices for hybrid cryptographic deployment from NIST, ETSI and industry groups.
- Perform testing in controlled environments before broad deployment to validate performance and compatibility.
- Educate internal teams about hybrid approaches to ensure correct implementation and avoid security misconfigurations.
- Monitor hybrid deployments for updates as PQC standards mature to enable eventual full migration to quantum-safe cryptography.

Data Masking and Tokenisation

This control involves applying data masking and tokenisation techniques to protect sensitive information, ensuring that even if encryption were to be broken (including by quantum adversaries), direct exposure of critical data is limited. These techniques provide an additional layer of defence by obfuscating or substituting sensitive elements.

Implementation Guidelines:

- Define data masking and tokenisation policies aligned with regulatory requirements like GDPR and PCI DSS.
- Identify and classify data suitable for masking or tokenisation, especially PII, payment data and healthcare records.
- Implement masking in non-production environments to prevent leakage of real data during development and testing.
- Deploy tokenisation solutions for high-risk transactional systems to replace sensitive values with non-sensitive equivalents.
- Integrate these solutions with data access controls and auditing to monitor usage and detect anomalies.

Best Practice:

- Maintain clear data flow diagrams identifying where masking and tokenisation are applied.
- Combine masking and tokenisation with strong encryption and access controls to achieve defence-in-depth.
- Regularly review and test masking and tokenisation effectiveness to ensure they meet security and compliance requirements.
- Ensure third-party processors adhere to equivalent data protection controls, including masking and tokenisation standards.

Network Security

Network Segmentation and Micro-Segmentation

This control enforces robust network segmentation and micro-segmentation to reduce the attack surface and contain lateral movement within an organisation's network. Given the threat of quantum-enabled decryption of traffic in the future,

segmentation ensures that even if encryption is compromised, attackers are restricted in how far they can move and what they can access.

Implementation Guidelines:

- Design the network with clear separation between security zones such as user, server, management and sensitive data networks.
- Implement micro-segmentation using technologies like VLANs, firewalls and software-defined networking (SDN) policies.
- Define and enforce granular access rules between network segments based on business need and risk.
- Monitor and log inter-segment traffic to detect unauthorised access or suspicious patterns.
- Review segmentation strategy regularly to account for changes in assets and quantum threat modelling.

Best Practice:

- Apply the principle of least privilege to network communication, denying all traffic by default and explicitly allowing only necessary flows.
- Use zero trust network principles, validating both users and devices before granting access to any segment.
- Integrate segmentation rules with IAM and security orchestration to maintain consistency.
- Conduct periodic network security assessments to validate segmentation effectiveness and identify policy drift.

Post-Quantum VPN and Secure Communications

This control focuses on ensuring that VPN and other secure communication solutions are prepared to transition to post-quantum cryptographic key exchange protocols. It reduces the risk of harvested encrypted traffic being decrypted in the future by quantum adversaries.

Implementation Guidelines:

- Inventory existing VPN solutions to identify cryptographic algorithms in use (e.g., RSA, Diffie-Hellman).

- Evaluate vendor roadmaps for support of PQC algorithms and hybrid key exchange methods.
- Prioritise critical VPN links (e.g., those carrying sensitive or long-retention data) for early adoption of PQC-ready or hybrid solutions.
- Test new VPN configurations in controlled environments to validate compatibility, performance and security.
- Include PQC readiness criteria in new VPN and secure communication procurement requirements.

Best Practice:

- Plan for phased migration to PQC-ready VPNs in alignment with NIST PQC standardisation timelines.
- Maintain clear documentation of VPN configurations, including algorithms and key management practices.
- Conduct regular penetration testing of VPN access points to identify weaknesses in configurations or legacy cryptography.
- Educate network and security teams on PQC protocols and hybrid deployment considerations.

Boundary Defences and Quantum-Safe Protocols

This control ensures that firewalls, secure gateways and other boundary defence technologies are configured to support and eventually enforce quantum-resilient protocols. This helps maintain the integrity and confidentiality of network traffic, even in the face of future quantum threats.

Implementation Guidelines:

- Review and update firewall policies to support modern secure protocols (e.g., TLS 1.3) and plan for PQC-enhanced versions as standards evolve.
- Monitor vendor updates for support of PQC algorithms in inspection and proxy functions.
- Ensure gateways can negotiate hybrid cryptographic modes combining classical and PQC algorithms.
- Implement intrusion prevention and detection systems capable of analysing encrypted traffic while maintaining cryptographic security.

- Include boundary defences in cryptographic inventories and transition roadmaps for PQC readiness.

Best Practice:

- Apply defence-in-depth by layering boundary defences with segmentation, strong IAM and endpoint security.
- Regularly audit firewall and gateway configurations to ensure least-privilege access policies are enforced.
- Test upgrades or new deployments in staging environments to ensure they correctly handle PQC protocols without introducing gaps.
- Coordinate with suppliers and service providers to align on timelines for supporting PQC-ready network traffic.

Security Operations and Incident Response

Security Monitoring & Detection (Quantum-Enhanced Threats)

This control ensures that security monitoring capabilities—including SIEM systems and analytics—are capable of detecting not only traditional attack patterns but also emerging threats enabled by quantum computing, such as indicators of cryptographic harvesting or unusual access targeting encrypted data.

Implementation Guidelines:

- Integrate logging from all critical systems, including encryption services, VPNs, IAM platforms and network devices.
- Define and maintain use cases to detect suspicious access to large, encrypted data stores suggestive of “harvest-now, decrypt-later” campaigns.
- Leverage anomaly detection to identify patterns of credential misuse or lateral movement indicative of quantum-enabled compromise of authentication.
- Establish baselines for normal cryptographic usage to detect deviations.
- Ensure SIEM integrations support updated encryption protocols, including hybrid and PQC algorithms.

Best Practice:

- Regularly review and refine detection rules based on emerging threat intelligence about quantum capabilities.
- Include logs from suppliers and third-party services where feasible.
- Train SOC analysts to recognise quantum-relevant indicators of compromise (IoCs).
- Test monitoring capabilities using red team exercises that include simulated harvesting or PQC attacks.

Incident Response Plan with Quantum Breach Scenarios

This control updates the organisation's Incident Response Plan (IRP) to explicitly account for cryptographic breaches or data exposure events linked to quantum threats, ensuring readiness to respond effectively if encryption is compromised by quantum-enabled adversaries.

Implementation Guidelines:

- Review and revise the IRP to include quantum-specific threat scenarios (e.g., mass harvesting of encrypted traffic).
- Define roles and responsibilities for responding to cryptographic breaches, including key revocation and replacement procedures.
- Develop communication templates and plans for notifying regulators, partners and customers in the event of quantum-enabled data compromise.
- Include specific steps for forensic preservation and investigation of cryptographic breaches.
- Integrate quantum breach simulations into regular incident response exercises.

Best Practice:

- Align IRP updates with NIST SP 800-61 recommendations for computer security incident handling.
- Coordinate quantum breach planning with legal, compliance and executive teams.

- Maintain lists of internal and external experts (e.g., cryptographers, PQC specialists) for rapid consultation.
- Conduct regular tabletop exercises featuring quantum attack scenarios to validate plans and train responders.

Vulnerability Management with PQC Impact Analysis

This control extends traditional vulnerability management programmes to include the identification of cryptographic weaknesses that could be exploited by quantum computing, ensuring these are prioritised for remediation.

Implementation Guidelines:

- Integrate cryptographic inventory data into vulnerability management workflows to highlight at-risk algorithms and key lengths.
- Use vulnerability scanning tools capable of detecting outdated or weak cryptographic configurations.
- Perform regular assessments of systems using vulnerable algorithms (e.g., RSA, ECC) to prioritise for migration planning.
- Track vendor patching and upgrade schedules to ensure quantum-vulnerable cryptography is addressed.
- Maintain a risk register documenting cryptographic vulnerabilities and planned mitigation timelines.

Best Practice:

- Establish SLAs for remediating cryptographic vulnerabilities based on data sensitivity and exposure.
- Communicate PQC impact analysis results to system owners to drive prioritisation.
- Conduct annual cryptographic reviews as part of broader vulnerability assessments.
- Include suppliers in vulnerability management programmes, ensuring they address quantum-related risks.

Penetration Testing Incorporating Quantum Threat Models

This control requires conducting penetration testing that simulates adversary scenarios informed by quantum capabilities, such as attacks exploiting broken cryptography or harvested encrypted data.

Implementation Guidelines:

- Define test objectives that include simulating quantum-enabled attacks such as decrypting harvested traffic and bypassing authentication.
- Engage experienced penetration testers who understand quantum threat modelling.
- Incorporate testing of hybrid cryptographic deployments and crypto agility in system designs.
- Include evaluation of secure communications, VPNs, IAM workflows and data storage encryption.
- Document findings with recommended mitigation steps, prioritising cryptographic and access-control weaknesses.

Best Practice:

- Conduct quantum-aware penetration tests annually or after major architectural changes.
- Share results with relevant stakeholders, including governance and risk teams.
- Track remediation efforts as part of broader security improvement plans.
- Use red team exercises to simulate sophisticated quantum-enabled adversaries, testing detection and response readiness.

Threat Intelligence with Focus on Quantum Advancements

This control incorporates monitoring and analysis of threat intelligence specific to quantum computing advancements into regular security operations, ensuring situational awareness of emerging risks.

Implementation Guidelines:

- Subscribe to industry threat intelligence feeds covering quantum research, PQC standardisation and observed adversary interest in cryptographic harvesting.

- Establish internal processes for evaluating and disseminating quantum-related intelligence to relevant teams (e.g., risk, architecture, SOC).
- Update risk assessments and cryptographic roadmaps based on evolving intelligence about quantum capabilities.
- Include quantum threat considerations in supplier risk assessments and third-party monitoring.

Best Practice:

- Maintain relationships with industry working groups, standards bodies and academic research communities to stay informed.
- Integrate quantum threat intelligence into SIEM and detection use case development.
- Share relevant quantum intelligence with partners and suppliers to improve ecosystem readiness.
- Conduct regular horizon-scanning exercises to identify and plan for potential quantum security impacts over 5-10+ year timeframes.

Endpoint and Application Security

Endpoint Protection with PQC-Capable Cryptographic Modules

This control ensures that endpoint devices—from user workstations to servers—use cryptographic libraries and modules that can support post-quantum cryptographic (PQC) algorithms, preparing the environment for future upgrades and reducing long-term cryptographic risk.

Implementation Guidelines:

- Conduct an inventory of endpoint cryptographic modules (e.g., OS libraries, VPN clients, secure email solutions).
- Identify dependencies on vulnerable algorithms such as RSA, ECC, or non-agile legacy libraries.
- Work with vendors to confirm support for PQC-capable or hybrid cryptographic libraries, aligning with NIST PQC recommendations.
- Include cryptographic agility as a mandatory requirement in endpoint protection and encryption software procurement.

- Define and enforce policies for updating cryptographic modules on endpoints to maintain compliance and security.

Best Practice:

- Automate endpoint configuration management to ensure consistent deployment of updated cryptographic libraries.
- Monitor vendor roadmaps for PQC support and plan phased rollouts of upgrades.
- Include endpoint cryptography checks in security audits and vulnerability management programmes.
- Educate users and IT teams about the importance of maintaining cryptographic agility at the endpoint level.

Secure Software Development Lifecycle (SSDLC) with PQC Requirements

This control integrates PQC considerations into the Secure Software Development Lifecycle (SSDLC), ensuring applications are designed and built with cryptographic agility and readiness for quantum-resilient algorithms.

Implementation Guidelines:

- Update secure coding standards and guidelines to mandate crypto agility, supporting future replacement of vulnerable algorithms.
- Incorporate PQC evaluation into architecture and design phases, documenting where cryptography is used and how it will transition to PQC.
- Require code reviews to verify correct use of cryptographic libraries and avoidance of hard-coded keys or static algorithms.
- Include PQC-readiness assessments in threat modelling and security requirements gathering.
- Use dependency management tools to track and update third-party libraries for PQC support.

Best Practice:

- Train development teams on PQC concepts, cryptographic agility patterns and best practices.

- Integrate static and dynamic analysis tools to identify insecure or non-agile cryptographic implementations.
- Maintain a secure development policy aligned with frameworks such as OWASP SAMM or BSIMM, updated to address quantum risks.
- Collaborate with security architects and cryptographers to validate designs for PQC readiness before deployment.

Application Security Testing with Quantum Cryptanalysis Scenarios

This control enhances application security testing programmes by incorporating scenarios that account for quantum-enabled cryptanalysis, ensuring that applications are resilient against future attacks that could exploit broken cryptographic schemes.

Implementation Guidelines:

- Define test cases that simulate the impact of quantum computing breaking key exchange or digital signatures.
- Include cryptographic dependency analysis as part of regular application security testing to identify and prioritise vulnerable algorithms.
- Leverage automated security testing tools that can detect outdated or non-agile cryptographic libraries.
- Require penetration testing engagements to include assessment of cryptographic controls with a view towards quantum threat scenarios.
- Document findings in security defect trackers with clear remediation plans prioritising PQC migration where necessary.

Best Practice:

- Integrate quantum-aware security testing into CI/CD pipelines to maintain continuous assessment.
- Maintain a cryptographic inventory linked to application components, enabling efficient identification of high-risk areas.
- Include quantum threat modelling in design and pre-release security reviews.
- Share lessons learned and testing results with development, architecture and governance teams to drive broader organisational readiness.

Business Continuity and Disaster Recovery

Business Continuity Planning with Quantum Data Risk Considerations

This control ensures that Business Continuity Plans (BCP) explicitly address the long-term confidentiality risks posed by quantum computing, particularly the threat that encrypted data stored today could be decrypted in the future.

Implementation Guidelines:

- Review and update BCP risk assessments to include quantum threats, such as “harvest-now, decrypt-later” attacks.
- Identify critical data with long-term confidentiality needs and prioritise it for PQC migration planning.
- Develop mitigation strategies for protecting historical backups and archives, including re-encryption with quantum-safe algorithms.
- Document procedures for ongoing review of stored encrypted data to assess quantum vulnerability.
- Ensure BCP includes communication plans to address potential quantum-related breaches with stakeholders.

Best Practice:

- Conduct periodic BCP exercises that include quantum breach scenarios.
- Maintain an inventory of encrypted data and storage locations with notes on algorithm types and migration status.
- Align BCP updates with broader cryptographic governance and PQC roadmaps.
- Coordinate with legal and compliance teams to understand obligations related to long-term data confidentiality.

Disaster Recovery Plan Supporting PQC Transitions

This control ensures that Disaster Recovery (DR) plans are designed to accommodate rapid deployment or replacement of cryptographic systems with PQC solutions in response to quantum cryptanalytic breakthroughs or incidents.

- Implementation Guidelines:
- Review DR plans to identify dependencies on cryptographic systems and algorithms.

- Include contingency procedures for emergency migration to PQC algorithms if a quantum-enabled breach occurs.
- Define requirements for backup and restoration processes that support PQC-capable cryptographic modules.
- Ensure DR testing includes scenarios involving cryptographic system failures or compromises.
- Collaborate with vendors and service providers to verify support for PQC transitions in DR environments.

Best Practice:

- Maintain alternative cryptographic configurations and tested runbooks for rapid deployment.
- Incorporate crypto-agility principles into DR system design.
- Train DR teams on PQC concepts and migration procedures.
- Align DR planning with overall enterprise risk management and cryptographic governance frameworks.

Physical Access Controls with Quantum-Protected Authentication

This control focuses on ensuring that physical access control systems adopt digital authentication protocols resistant to quantum attacks, preventing future compromise of facilities through broken cryptographic mechanisms.

Implementation Guidelines:

- Inventory physical access systems to identify those using vulnerable cryptographic algorithms for authentication (e.g., smart cards, badge readers, biometric systems).
- Work with vendors to upgrade or replace systems to support PQC-ready or hybrid authentication protocols.
- Define procurement requirements specifying support for crypto-agility and PQC standards.
- Establish procedures for secure issuance, management and revocation of physical access credentials.
- Integrate physical access logs with centralised monitoring systems to enable detection of anomalous access attempts.

Best Practice:

- Align physical security policies with ISO/IEC 27001 Annex A.11 requirements.
- Conduct regular reviews and penetration tests of physical access systems, including cryptographic components.
- Ensure consistent security training for facilities staff about cryptographic risks and upgrades.
- Coordinate physical access control strategies with logical access management for a unified security approach.

Secure Disposal of Cryptographic Hardware Assets

This control ensures that cryptographic hardware—such as HSMs, smart cards and secure tokens—containing sensitive keys or vulnerable algorithms is securely decommissioned and disposed of to prevent exploitation by quantum adversaries.

Implementation Guidelines:

- Develop and enforce policies for the secure disposal of cryptographic hardware, aligned with ISO/IEC 27001 Annex A.11.2.7.
- Include requirements for cryptographic key zeroisation or physical destruction according to manufacturer guidance.
- Maintain inventory records of cryptographic hardware, including disposal status and chain-of-custody documentation.
- Train IT and facilities staff on secure disposal procedures, ensuring awareness of quantum-related risks.
- Audit disposal processes regularly to confirm compliance with policy.

Best Practice:

- Partner with certified e-waste disposal providers who can guarantee secure destruction of cryptographic hardware.
- Include disposal procedures in offboarding processes for retired systems or facilities.
- Consider secure storage for hardware that cannot be immediately disposed of, with access restricted and logged.

- Review disposal policies annually to account for changes in technology, regulation and quantum risk assessments.

Awareness and Training

Security Awareness Programme Including Quantum Threats

This control ensures that the organisation's security awareness programme includes education on the implications of quantum computing, particularly its potential to undermine classical cryptography and threaten long-term data confidentiality. Staff at all levels should understand the basics of quantum risks and their role in mitigating them.

Implementation Guidelines:

- Review and update existing security awareness content to include quantum threat scenarios such as "harvest-now, decrypt-later".
- Explain in simple terms how quantum computing could break widely used algorithms like RSA and ECC and why crypto-agility and PQC migration are essential.
- Include case studies or industry examples of quantum threat planning to contextualise risks.
- Tailor content for different roles: general staff need high-level understanding, while managers and decision-makers need awareness of policy and governance implications.
- Use multiple delivery methods (e-learning, workshops, newsletters) to reinforce understanding over time.

Best Practice:

- Make quantum threats a standing topic in annual security refresher training.
- Test comprehension through short quizzes or surveys to identify gaps.
- Collaborate with corporate communications to deliver consistent messaging.
- Link quantum risk awareness to broader topics like data classification, secure data handling and incident reporting to build a holistic security culture.

Specialised PQC Training for Technical Teams

This control provides targeted, in-depth training for technical staff—including security architects, developers, system administrators and cryptography teams—focused on understanding PQC standards, migration strategies and secure implementation practices.

Implementation Guidelines:

- Develop or procure training modules covering the NIST PQC standardisation process, approved algorithms and hybrid deployment models.
- Include hands-on labs or demonstrations showing how to integrate PQC algorithms into common protocols and applications.
- Offer role-specific content: developers need secure coding guidance for crypto-agility, while infrastructure teams need configuration management and key lifecycle training.
- Establish learning paths with progressive depth, from introductory overviews to advanced cryptography design.
- Track participation and completion to ensure all critical technical roles are covered.

Best Practice:

- Incorporate PQC topics into onboarding for new technical staff.
- Encourage professional development through external courses, industry conferences, or standards body participation.
- Facilitate internal knowledge sharing, such as brown-bag sessions or technical forums.

Third-Party and Cloud Security

3Cloud Security Posture Management with PQC Considerations

This control ensures that an organisation's approach to Cloud Security Posture Management (CSPM) explicitly accounts for cryptographic agility and readiness to deploy post-quantum cryptographic (PQC) solutions. It recognises that cloud

services often hold sensitive data whose encryption must remain secure against future quantum threats.

Implementation Guidelines:

- Review cloud provider documentation and security configurations to identify current cryptographic algorithms in use for data-at-rest, data-in-transit and key management.
- Ensure cloud configurations support crypto agility, enabling easy replacement of vulnerable algorithms with PQC or hybrid solutions.
- Implement CSPM tools to continuously assess and enforce policies for encryption standards, key rotation and secure configuration baselines.
- Work with cloud providers to understand their roadmap for PQC support and define requirements in service agreements.
- Include PQC considerations in architecture and design reviews for all new cloud deployments.

Best Practice:

- Maintain an inventory of all cloud services and the cryptographic methods they use.
- Regularly review CSPM findings and remediate issues, prioritising workloads with long-term confidentiality needs.
- Collaborate with cloud providers through user groups or security forums to influence PQC adoption.
- Train cloud architects and security engineers on crypto-agility principles and PQC transition planning.

Third-Party Assurance with Quantum Readiness Assessment

This control ensures that third-party security assessments and supplier risk management processes include explicit evaluation of quantum readiness. It aims to reduce systemic risk by ensuring vendors and partners are preparing for quantum threats to cryptography.

Implementation Guidelines:

- Integrate quantum threat readiness into third-party security questionnaires and due diligence processes.

- Define clear requirements for vendors to demonstrate cryptographic inventory management, crypto-agility and plans to migrate to PQC algorithms.
- Include contract clauses mandating support for PQC standards once ratified, ensuring supplier commitments to timely migration.
- Require suppliers handling sensitive data to identify and mitigate “harvest-now, decrypt-later” risks.
- Perform periodic reviews and audits of high-risk suppliers to verify progress toward quantum readiness.

Best Practice:

- Maintain a risk register that includes third-party cryptographic dependencies and PQC readiness status.
- Prioritise quantum readiness assessments for vendors with access to sensitive or regulated data.
- Collaborate with suppliers to share threat intelligence and best practices for PQC transition.
- Align third-party assurance processes with internal cryptographic governance and enterprise risk management frameworks.

Security Architecture and Design

Zero Trust Architecture with PQC Support

This control ensures that the organisation’s Zero Trust Architecture (ZTA) incorporates post-quantum cryptography (PQC) considerations, recognising that authentication, encryption and segmentation mechanisms must remain secure even against quantum-enabled adversaries.

Implementation Guidelines:

- Align ZTA designs with NIST SP 800-207 or Microsoft RAMP guidance, explicitly documenting cryptographic requirements and PQC readiness.
- Implement strong identity verification and continuous authentication using crypto-agile methods that can transition to PQC algorithms.
- Ensure micro-segmentation policies enforce least-privilege access with encrypted communication between segments.

- Collaborate with vendors to evaluate and adopt solutions supporting hybrid or PQC algorithms for secure tunnels and authentication.
- Maintain a roadmap for replacing vulnerable cryptographic protocols in ZTA components as PQC standards mature.

Best Practice:

- Integrate PQC readiness into ZTA design reviews and threat modelling.
- Use hybrid cryptographic approaches during transition phases to maintain interoperability while adopting PQC.
- Regularly test ZTA enforcement mechanisms for resilience against credential theft, lateral movement and cryptographic compromise.
- Educate architecture and engineering teams on PQC algorithms and their integration into Zero Trust principles.

Cryptographic Agility in Architecture Design

This control ensures that all security architecture is designed with cryptographic agility in mind, enabling seamless migration from classical algorithms to quantum-resistant alternatives without requiring major redesign or disruption.

Implementation Guidelines:

- Establish design principles mandating support for algorithm negotiation, pluggable cryptographic modules and easy updates.
- Include crypto agility as a non-functional requirement in architecture blueprints and design patterns.
- Evaluate existing systems for cryptographic rigidity, documenting where refactoring is needed to support agile upgrades.
- Prioritise critical systems and data flows for early adoption of agile cryptographic designs.
- Collaborate with vendors to verify their products support crypto-agility and roadmap alignment with PQC standards.

Best Practice:

- Conduct architecture reviews specifically focused on cryptographic agility and PQC migration readiness.

- Maintain detailed diagrams and inventories showing cryptographic dependencies and upgrade plans.
- Require new projects to demonstrate crypto-agility at design-gate reviews before approval.
- Train architects and developers on best practices for crypto-agile implementation and secure key management.

Secure Protocol Design with Quantum-Resilient Standards

This control focuses on adopting or designing secure communication protocols that are quantum-resistant by design, ensuring that future adversaries with quantum capabilities cannot exploit protocol-level cryptographic weaknesses.

Implementation Guidelines:

- Review current protocols in use (e.g., TLS, SSH, VPN tunnels) to identify those relying on vulnerable algorithms.
- Plan migration to versions supporting PQC or hybrid key exchange mechanisms (e.g., TLS 1.3 with PQC enhancements).
- Incorporate support for PQC-approved algorithms in custom protocol design, following standards from NIST and ETSI.
- Ensure protocol specifications include algorithm negotiation to allow future upgrades without breaking compatibility.
- Conduct security reviews and threat modelling of protocols with explicit consideration of quantum cryptanalysis scenarios.

Best Practice:

- Participate in industry groups or standards bodies to stay aligned with evolving PQC protocol guidance.
- Test protocol implementations in controlled environments to validate performance and security under PQC algorithms.
- Maintain clear documentation of all supported protocols, cryptographic algorithms and their upgrade plans.
- Include secure protocol design and PQC considerations as part of architecture governance and approval processes.

Emerging Technologies and Innovation

Quantum Key Distribution (QKD) Evaluation and Pilots

This control focuses on evaluating and piloting Quantum Key Distribution (QKD) technologies to secure critical data transmissions against quantum-enabled adversaries. QKD uses the principles of quantum mechanics to distribute encryption keys securely, making eavesdropping detectable and providing a potential mitigation against future quantum cryptanalysis.

Implementation Guidelines:

- Conduct feasibility studies to identify business use cases where QKD offers clear security or regulatory advantages (e.g., government, financial, or defence communications).
- Engage with vendors and research partners to understand technical requirements, deployment models (fibre, satellite) and integration challenges.
- Plan and execute small-scale pilots on limited, high-value communication channels to validate operational feasibility.
- Document integration requirements with existing key management systems and encryption solutions.
- Assess costs, scalability and operational complexities to inform broader deployment strategy.

Best Practice:

- Align QKD pilot planning with organisational cryptographic governance and risk management processes.
- Share lessons learned internally to build organisational awareness and capability.
- Stay informed about national and international standards for QKD interoperability.
- Evaluate long-term viability and sustainability before committing to production deployments.

Digital Certificate Management with PQC-Ready CAs

This control ensures that the organisation's Public Key Infrastructure (PKI) and Certificate Authorities (CAs) are prepared to issue, manage and validate quantum-safe certificates, enabling secure authentication and encryption even after quantum breakthroughs.

Implementation Guidelines:

- Review the cryptographic algorithms supported by current PKI solutions and CAs, identifying dependencies on vulnerable algorithms (e.g., RSA, ECC).
- Engage with CA providers to verify their roadmap for supporting PQC algorithms and hybrid certificate formats.
- Update certificate management policies to require crypto-agility and future PQC compatibility.
- Plan certificate renewal processes to support seamless transition to PQC-enabled certificates.
- Maintain inventories of certificates and key usage across systems to prioritise migration of critical services.

Best Practice:

- Establish clear timelines and milestones for PKI transition to PQC standards, aligned with NIST recommendations.
- Include PQC readiness as a criterion in CA procurement and service contracts.
- Conduct regular reviews of certificate issuance and validation processes for security and compliance.
- Train PKI administrators on crypto-agility concepts and PQC migration strategies.

Blockchain Security with Post-Quantum Cryptography

This control focuses on evaluating and transitioning blockchain systems to quantum-resilient cryptographic schemes, recognising that many blockchain protocols rely on vulnerable signature algorithms that could be broken by quantum computers.

Implementation Guidelines:

- Conduct a cryptographic assessment of blockchain applications to identify dependencies on quantum-vulnerable algorithms (e.g., ECDSA, RSA).
- Review vendor and open-source project roadmaps for PQC or hybrid signature support.
- Prioritise high-value or long-lived blockchain systems (e.g., supply chain, financial contracts) for early transition planning.
- Plan and test integration of quantum-safe or hybrid cryptographic algorithms in smart contracts and transaction validation workflows.
- Maintain awareness of research and standardisation efforts in quantum-resistant blockchain protocols.

Best Practice:

- Include blockchain cryptographic readiness in enterprise cryptographic governance programmes.
- Engage with industry consortia or working groups focused on PQC in blockchain.
- Document and maintain migration plans for blockchain systems with realistic timelines and risk assessments.
- Educate blockchain development teams on crypto-agility and PQC implementation patterns.

Monitoring, Metrics and Continuous Improvement**Continuous Monitoring of PQC Standards & Threat Landscape**

This control establishes an ongoing process for tracking the evolution of post-quantum cryptography (PQC) standards and the broader quantum threat landscape. Staying informed about advances in quantum computing and cryptanalysis ensures that the organisation can proactively adjust security strategies to remain resilient.

Implementation Guidelines:

- Assign responsibility to a dedicated team or role (e.g., Security Architecture or GRC function) to monitor updates from standards bodies such as NIST, ETSI and ISO.
- Subscribe to industry threat intelligence feeds and research publications focused on quantum computing developments.
- Include regular reviews of vendor roadmaps for PQC support in critical systems and services.
- Establish a structured process to evaluate new PQC algorithms or hybrid schemes as they mature.
- Document findings and communicate key updates to relevant stakeholders, including risk committees and senior management.

Best Practice:

- Hold quarterly or biannual security forums or briefings to discuss the latest PQC and quantum threat developments.
- Maintain a central knowledge base or dashboard tracking standards milestones and vendor support status.
- Collaborate with industry groups, government initiatives and academic research programmes to stay ahead of developments.
- Integrate findings into broader security strategy and investment planning cycles.

Key Performance Indicators (KPIs) for PQC Adoption

This control defines and uses Key Performance Indicators (KPIs) to measure organisational progress towards adopting PQC and achieving quantum resilience, ensuring visibility and accountability for the migration effort.

Implementation Guidelines:

- Identify critical areas requiring PQC adoption, such as VPNs, PKI systems, databases and third-party services.
- Define measurable KPIs (e.g., % of cryptographic systems inventoried, % migrated to PQC-ready solutions, number of staff trained in PQC).
- Set realistic targets and timelines for achieving incremental goals.

- Integrate PQC KPIs into broader cybersecurity and risk reporting frameworks.
- Use dashboards or management reports to track and communicate progress to stakeholders.

Best Practice:

- Review KPIs regularly to ensure they remain aligned with evolving standards and organisational risk appetite.
- Include PQC readiness KPIs in executive security briefings and board reports to maintain visibility and support.
- Adjust targets as technology matures or as new high-risk systems are identified.
- Celebrate milestones to maintain organisational engagement with the PQC migration journey.

Continuous Improvement with Quantum Security Reviews

This control ensures that the organisation's security posture is regularly reviewed and improved with a specific focus on quantum readiness and resilience. It acknowledges that the quantum threat landscape will evolve over time, requiring iterative updates to security controls and strategies.

Implementation Guidelines:

- Integrate quantum security considerations into existing security review cycles, such as annual risk assessments, audits and architecture reviews.
- Establish a formal review process to evaluate cryptographic inventories and migration plans against the latest PQC standards and threats.
- Include lessons learned from incidents, testing and external intelligence in review discussions.
- Document action plans with clear ownership, timelines and resources for implementing improvements.
- Ensure cross-functional involvement, including security, IT, risk, compliance and business stakeholders.

Best Practice:

- Schedule dedicated quantum security review sessions at least annually.

- Maintain an auditable record of reviews, findings and improvements to demonstrate governance and compliance.
- Align review cycles with broader continuous improvement frameworks such as ISO/IEC 27001's PDCA (Plan-Do-Check-Act) model.
- Encourage a security culture that values proactive adaptation to emerging threats, including quantum risks.

PQC Network Scanner

The PQC Network Scanner is a purpose-built assessment tool designed to help organisations understand their cryptographic exposure as they transition toward a post-quantum security posture. Unlike traditional TLS scanners that focus solely on certificate validity or classical cryptographic strength, this scanner evaluates endpoints through a quantum-aware lens. It inspects not only RSA and elliptic-curve keys but also identifies emerging post-quantum algorithms, hybrid deployments and experimental PQC indicators embedded within certificates, extensions and cipher suites. This makes it uniquely suited for environments preparing for the cryptographic shift driven by NIST's PQC standardisation and the growing threat of "harvest now, decrypt later" adversaries.

At its core, the scanner performs deep inspection of TLS endpoints across an internal network. It retrieves and analyses full certificate chains, evaluates key types and sizes, detects PQC-related OIDs and identifies hybrid key-exchange mechanisms such as X25519+Kyber. The tool also examines TLS protocol versions and cipher suites to determine whether endpoints support Perfect Forward Secrecy (PFS) or rely on legacy, quantum-vulnerable configurations. By combining these the scanner provides a comprehensive view of both classical and quantum-era cryptographic resilience.

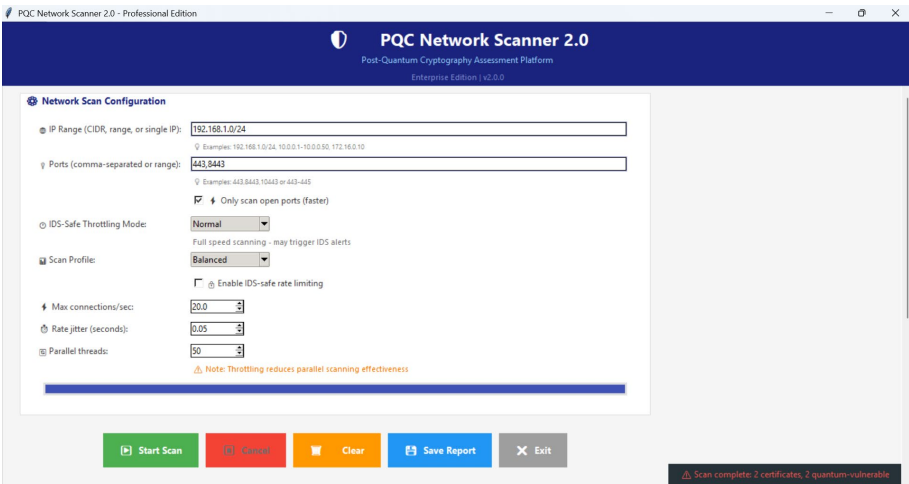
Beyond cryptography, the scanner incorporates intelligent device identification. It correlates certificate metadata, DNS information and naming conventions to classify endpoints such as routers, firewalls, VPN gateways, web servers and application hosts. This contextual awareness helps security teams understand not

just what cryptography is deployed, but where it resides within the network. An essential capability for building a crypto inventory and prioritising remediation. The output report contains technical detail with clear, actionable commentary. Each endpoint is assessed for quantum vulnerability, PQC readiness, TLS posture and certificate chain integrity. The report highlights high-risk configurations, identifies PQC-enabled or hybrid deployments and provides migration guidance aligned with emerging standards such as ML-DSA and ML-KEM. Summary sections consolidate findings across the scanned environment, offering a high-level view of organisational readiness and exposure.

In practice, the PQC Network Scanner serves as both a diagnostic instrument and a strategic planning tool. It enables organisations to map their cryptographic landscape, detect weak or outdated configurations and identify early adopters of PQC technologies. By bridging classical TLS analysis with post-quantum detection, it supports crypto-agility initiatives and helps teams prepare for the inevitable transition to quantum-safe cryptography.

It can be run as either a standalone Windows executable or as Python script both versions are available on GitHub at: <https://github.com/cyberjez/PQC-Scanner>

Figure 13 PQC Network Scanner Screenshot



IMPLEMENTATION SUMMARY

Here is a comprehensive summary of all the implementation guidelines for the QUANTA framework so far and have been grouped and ordered logically. So, they could be used as part of a strategic roadmap and control prioritisation.

1 Governance & Strategy

Define and maintain information security policies.

- Align with ISO/IEC 27001, CIS 18, NIST CSF and PQC considerations.
- Include crypto-agility, PQC migration and secure lifecycle management.

Integrate PQC risks into enterprise risk management.

- Include quantum threats in risk assessments and registers.
- Evaluate long-term confidentiality needs (e.g., for archival data).

Establish governance structures.

- Assign roles for PQC readiness (e.g., cryptographic governance committees).
- Maintain inventory of cryptographic assets and dependencies.

Ensure compliance with regulations and standards.

- Track PQC standardisation (e.g., NIST) and prepare for adoption.
- Include PQC readiness in internal audits.

2 Inventory, Classification & Asset Management

Conduct cryptographic asset inventory.

- Identify all systems, data and processes using cryptography.
- Classify data based on sensitivity and long-term confidentiality.
- Highlight assets (including data) vulnerable to "harvest-now, decrypt-later" threats.

Track supplier cryptographic dependencies.

- Include cryptographic review in supplier due diligence.
- Require transparency about algorithms in use.

3 Architectural Planning & Design

Mandate cryptographic agility in architecture.

- Require support for algorithm negotiation and modular design.
- Include crypto agility as a non-functional requirement in design reviews.

Align Zero Trust Architecture with PQC

- Design authentication, segmentation and encryption for PQC support.
- Define roadmaps for replacing vulnerable protocols.

Plan for secure protocol design

- Review protocols (e.g., TLS, SSH) for PQC support.
- Ensure custom designs include negotiation for future PQC algorithms.

Include PQC in threat modelling and design gates.

- Require reviews for PQC readiness in architecture approval.
- Document cryptographic requirements clearly.

4 Supplier, Cloud and Third-Party Management

Assess vendor and cloud roadmaps for PQC support.

- Include PQC readiness in contracts and SLAs.
- Verify CSPM (Cloud Security Posture Management) tools assess encryption configurations.
- Require supplier quantum readiness assessments.
- Include PQC in questionnaires and audits.
- Require crypto-agility and PQC migration planning.

Track third-party cryptographic dependencies.

- Maintain inventories of critical third-party services and their cryptographic posture.

5 Identity, Access, & Authentication

Implement robust IAM with crypto agility.

- Enforce least privilege, role-based access and segregation of duties.

- Ensure IAM systems can adopt PQC algorithms.

Enforce MFA with PQC readiness.

- Require strong MFA methods, prioritising those resilient to future quantum attacks.
- Include PQC support in vendor selection criteria.

Deploy PQC-capable authentication.

- Work with vendors to adopt hybrid or PQC algorithms for credentials and certificates.
- Plan staged migration for critical systems.

6 Cryptography & Data Protection

Plan cryptographic lifecycle management.

- Define policies for key generation, rotation, retirement.
- Include PQC migration as part of lifecycle planning.

Encrypt data at rest and in transit with crypto agility.

- Use current best-practice algorithms while planning for PQC upgrade.
- Prioritise high-value data and communications for early hybrid deployment.

Adopt hybrid cryptographic solutions.

- Deploy hybrid classical/PQC algorithms for key exchange and digital signatures.
- Validate interoperability with partners and clients.

Apply data masking and tokenisation.

- Use these techniques to protect sensitive data even if encryption is later broken.
- Integrate with secure design patterns for data minimisation.

7 Secure Development & Application Security

Integrate PQC into SSDLC

- Update secure coding standards to require crypto agility.
- Include PQC readiness in threat modelling.
- Review third-party libraries for PQC support.

Conduct crypto-aware code reviews.

- Check for hard-coded algorithms, key management issues and lack of agility.
- Require remediation before deployment.

Enhance security testing for quantum threats.

- Include quantum cryptanalysis scenarios in penetration tests.
- Use tools to identify outdated cryptographic libraries.

8 Endpoint, Network and Physical Security

Upgrade endpoint cryptographic modules.

- Ensure libraries support PQC algorithms or hybrid modes.
- Include crypto agility as a procurement requirement.
- Implement network segmentation and micro-segmentation.
- Contain lateral movement, recognising risk of broken encryption.
- Use strong, crypto-agile authentication for inter-segment traffic.

Plan PQC-ready VPN and secure communication.

- Work with vendors to adopt PQC-enabled key exchange.
- Include hybrid support during transition.

Enforce boundary defences with future-proof protocols.

- Upgrade firewalls and gateways to support TLS 1.3 and future PQC-enhanced protocols.

Upgrade physical access controls.

- Review digital authentication mechanisms for quantum vulnerability.
- Replace or upgrade with PQC-capable systems.

Securely dispose of cryptographic hardware

- Zeroise keys or physically destroy assets.
- Maintain chain-of-custody documentation.

9 Security Operations & Incident Response

Update SIEM and monitoring.

- Include detection for harvest-now, decrypt-later scenarios.
- Integrate logs from cryptographic systems.

Extend incident response plans.

- Add procedures for quantum-related breaches.

- Include key revocation and emergency migration plans.

Enhance vulnerability management.

- Include cryptographic weakness analysis.
- Prioritise remediation of vulnerable algorithms.

Conduct quantum-aware penetration testing.

- Simulate quantum-capable adversaries.
- Include hybrid and PQC deployments in scope.

Integrate quantum threat intelligence.

- Subscribe to industry feeds.
- Share intelligence with relevant teams.

10 Business Continuity & Disaster Recovery

Update BCP for quantum threats.

- Identify long-term confidentiality risks.
- Plan re-encryption of archived data.

Ensure DR plans support PQC transitions.

- Include procedures for rapid deployment of PQC solutions.
- Test DR processes with crypto-migration scenarios.

11 Awareness & Training

Include quantum threats in security awareness.

- Educate all staff on basics of quantum risk.
- Use accessible scenarios to illustrate harvest-now, decrypt-later.

Provide specialised PQC training.

- Train technical teams on PQC standards and migration strategies.
- Include hands-on labs and role-specific content.

12 Emerging Technologies & Innovation

Evaluate Quantum Key Distribution (QKD)

- Pilot on high-value communication channels.
- Assess integration with existing key management.

Ensure PKI and CA readiness for PQC.

- Verify vendor roadmaps.

- Plan renewal processes for quantum-safe certificates.

Transition blockchain applications.

- Assess cryptographic dependencies.
- Integrate PQC or hybrid signatures.

13 Monitoring, Metrics & Continuous Improvement

Continuously monitor PQC standards and threats

- Assign responsibility to track developments.
- Communicate updates to stakeholders.

Define and track PQC adoption KPIs.

- Measure progress in cryptographic inventory, migration, training.
- Integrate with security dashboards.

Conduct regular quantum security reviews.

- Include quantum readiness in risk assessments and audits.
- Document and implement improvement plans.

QUANTA Framework Summary

- QUANTA aligns governance, risk and control domains to embed quantum resilience.
- It extends existing frameworks (NIST CSF, CIS 18, ISO/IEC 27001) with quantum specificity.
- Controls span cryptography, identity, network, cloud and business continuity.
- Continuous monitoring and metrics are essential to track quantum readiness.
- Executives must ensure QUANTA adoption is enterprise-wide, not siloed in technical teams.

SATCOM SCENARIO

Taking the SATCOM scenario from earlier in the book and used with Q-SLICE threat modelling, lets apply the QUANTA Framework to the scenario at the end there is also mapping to NIST CSF, CIS 18 and ISO/IEC 27001.

Governance, Risk and Compliance

The DoD should begin by updating its Information Security Policy and governance structures to explicitly address quantum threats to SATCOM. Policies must mandate crypto-agility and migration to post-quantum cryptographic (PQC) solutions. A dedicated governance body should oversee quantum readiness, integrating PQC risk into the broader Risk Management Framework. This includes formal risk assessments of HNDL scenarios, quantifying the long-term exposure of intercepted encrypted traffic. Compliance programmes should align with emerging standards (NIST or FIPS) and ensure that satellite communications adhere to evolving regulatory requirements for national security systems.

Asset Inventory and Classification

Conduct a thorough inventory of all SATCOM cryptographic assets, systems and protocols, identifying where RSA and ECC are used for key exchange, authentication and data protection. Classify transmitted data by sensitivity and longevity of confidentiality needs—for example, intelligence traffic that must remain secret for decades. This allows prioritisation of migration efforts towards communications with the highest HNDL risk.

Security Architecture & Design

Architectural planning should mandate crypto agility across SATCOM systems. Designs must support seamless upgrades from vulnerable algorithms to PQC and hybrid approaches without major redesign. Zero Trust Architecture principles

should be extended to SATCOM ground systems and command-and-control channels, with strict segmentation, least privilege and strong authentication. Protocol designs for satellite-ground links and inter-satellite communication must be reviewed and updated to support PQC or hybrid cryptography.

Cryptography & Data Protection

Immediate steps should include adopting hybrid cryptographic solutions that combine classical and PQC algorithms to provide protection during the transition phase. Encrypt SATCOM data in-transit with algorithms supporting crypto-agility, ensuring key management systems can store and distribute PQC keys in future. Lifecycle management plans must be developed for cryptographic keys, with clear processes for rotation and revocation once PQC solutions mature. Data masking and tokenisation could be explored for less critical communication links to reduce exposure in the event of partial decryption.

Identity, Access and Authentication

Strengthen Identity and Access Management (IAM) systems controlling SATCOM ground stations and operational networks. Implement role-based access controls with least privilege principles. Transition to PQC-capable authentication mechanisms for ground-station personnel, remote operators and systems communicating with satellites. Enforce Multi-Factor Authentication (MFA) with a roadmap to integrate PQC algorithms for credential exchanges.

Network Security

Review and enhance network segmentation between mission-critical SATCOM operations and less sensitive IT networks to limit lateral movement in case of breach. Plan for VPN solutions that support PQC-based key exchange protocols, protecting command channels from interception. Upgrade boundary defences (e.g., firewalls, secure gateways) to be capable of negotiating quantum-resistant protocols, such as future TLS versions with PQC enhancements.

Endpoint & Application Security

Ensure all endpoints involved in SATCOM command, control and monitoring systems use cryptographic modules capable of supporting PQC libraries. Update Secure Software Development Lifecycle (SSDLC) practices for SATCOM application

developers to incorporate PQC requirements, including code review and crypto agility. Application security testing should simulate quantum cryptanalysis scenarios to identify weaknesses in encryption libraries or key handling.

Security Operations & Incident Response

Enhance security monitoring (SIEM, IDS/IPS) to detect indicators of quantum-aware threat actor behaviours, such as large-scale interception of encrypted data. Update the Incident Response Plan with procedures for cryptographic breaches related to quantum advances, including emergency key rotation and system upgrades. Conduct vulnerability management with PQC impact analysis to identify and remediate cryptographic weaknesses. Penetration testing exercises should include quantum-capable adversary threat models to validate defences.

Business Continuity & Disaster Recovery

Revise Business Continuity Plans (BCP) to account for long-term confidentiality risks from intercepted SATCOM traffic, including strategies for re-encryption or retiring vulnerable data. Disaster Recovery Plans (DRP) should incorporate procedures for rapid deployment of PQC solutions if an urgent cryptanalytic breakthrough is detected, ensuring communication channels can be swiftly upgraded.

Third-Party and Cloud Security

Assess all contractors and suppliers involved in SATCOM operations for quantum readiness. Include PQC requirements in security assessments, contracts and procurement criteria, mandating crypto agility in their systems and services. Evaluate any cloud-based ground-station services with CSPM tools that ensure encryption configurations are PQC-ready and crypto-agile.

Awareness and Training

Develop a security awareness programme for personnel explaining quantum computing threats to SATCOM, using accessible scenarios like HNDL. Provide specialised PQC training to technical teams responsible for SATCOM system design, cryptographic engineering and operational security, ensuring they can implement migration plans effectively.

Emerging Technologies & Innovation

Evaluate Quantum Key Distribution (QKD) pilots for critical SATCOM links, particularly those with the highest confidentiality requirements, to test its feasibility and operational benefits. Ensure PKI infrastructure for SATCOM command systems is ready to support PQC-enabled certificates as standards mature. Assess blockchain applications in defence logistics or command systems for quantum resilience and plan transitions to PQC-secure signature schemes.

Monitoring, Metrics & Continuous Improvement

Establish continuous monitoring of PQC standards and the quantum threat landscape through dedicated teams or partnerships with defence research bodies. Define Key Performance Indicators (KPIs) to track inventory completion, crypto-agility deployment and migration to PQC algorithms across SATCOM infrastructure. Include quantum security readiness reviews in annual security assessments and audits to ensure continuous improvement.

QUANTA Scoring Model

This section evaluates the QUANTA framework through empirical application to contrasting systems. The purpose is to demonstrate the framework's correctness, sensitivity, scalability and practical utility, thereby validating its methodological design and its contribution to the field of quantum-risk assessment.

QUANTA evaluates systems across **three primary dimensions**:

1. **Quantum Exposure**
2. **Crypto-Agility**
3. **Transition Readiness**

Each dimension is broken into sub-dimensions with clear scoring criteria (0-5 scale).

Figure 14 QUANTA Scoring model



This gives you a structured, defensible, repeatable scoring model.

Quantum Exposure Score (QES)

Purpose: Measure how vulnerable the system is to quantum-enabled attacks, based on cryptographic posture, data lifetime and adversary incentives.

Sub-Dimension	Description	Scoring Logic (0-5)
1.1 Algorithmic Vulnerability	Strength of current algorithms against quantum attacks	0 = PQC or hybrid; 5 = RSA-2048, ECC, or weaker
1.2 Key & Certificate Lifetime	Duration keys/certs remain valid; long-lived = high exposure	0 = <90 days; 5 = multi-year or static
1.3 Data Longevity & Sensitivity	How long data must remain secure (harvest-now-decrypt-later risk)	0 = ephemeral; 5 = decades-long confidentiality
1.4 Attack Surface Breadth	Number and diversity of exposed cryptographic endpoints	0 = minimal; 5 = large, complex, multi-domain
1.5 PKI & Chain Weaknesses	Weak intermediates, deprecated roots, misconfigurations	0 = modern PKI; 5 = outdated or broken chains

Interpretation

- **High QES (12-20):** System is materially exposed to quantum threats.
- **Medium QES (7-11):** Exposure exists but is manageable with targeted remediation.
- **Low QES (0-6):** Strong posture; PQC or hybrid adoption evident.

Crypto-Agility Score (CAS)

Purpose: Assess how easily the system can migrate to PQC or adapt to new cryptographic requirements.

Sub-Dimension	Description	Scoring Logic (0-5)
2.1 Architectural Modularity	Crypto abstracted behind APIs/libraries vs hard-coded	0 = fully abstracted; 5 = hard coded everywhere
2.2 Key Management Flexibility	Ability to rotate, re-issue, re-key and change algorithms including entropy.	0 = automated KMS/HSM; 5 = manual, brittle
2.3 Dependency Agility	Third-party libraries, SDKs and vendors supporting PQC	0 = PQC-ready; 5 = legacy or opaque
2.4 Protocol Agility	Ability to upgrade TLS, mTLS, SSH, VPN, IoT protocols	0 = fully configurable; 5 = fixed/embedded
2.5 Inventory Completeness	Visibility of cryptographic assets	0 = complete inventory; 5 = unknown/fragmented

Interpretation

- **High CAS (12-20):** System is rigid; migration will be costly and slow.
- **Medium CAS (7-11):** Some agility exists but with notable constraints.
- **Low CAS (0-6):** System is crypto-agile and well-architected.

Transition Readiness Score (TRS)

Purpose: Evaluate whether the organization is prepared – technically, operationally and strategically – to migrate to PQC.

Sub-Dimension	Description	Scoring Logic (0-5)
---------------	-------------	---------------------

3.1 Governance & Policy Alignment	Policies referencing PQC, crypto lifecycle, algorithm agility	0 = strong governance; 5 = no policy
3.2 Migration Roadmap	Existence and maturity of PQC transition plans	0 = detailed roadmap; 5 = none
3.3 Operational Capability	Skills, tooling and processes to execute migration	0 = strong capability; 5 = none
3.4 Vendor & Supply Chain Readiness	PQC support from vendors, cloud providers, PKI providers	0 = ready; 5 = legacy-only
3.5 Risk Management Integration	Quantum risk integrated into enterprise risk frameworks	0 = fully integrated; 5 = absent

Interpretation

- **High TRS (12-20):** Organization is not ready for PQC transition.
- **Medium TRS (7-11):** Some readiness exists but gaps remain.

Low TRS (0-6): Organization is well-positioned for PQC migration.

Overall QUANTA Score

You can combine the three dimensions into a single QUANTA score:

$$\text{QUANTA Score} = \text{QES} + \text{CAS} + \text{TRS}$$

QUANTA Score Interpretation

- **0-15:** Strong quantum readiness
- **16-30:** Moderate readiness; targeted improvements required
- **31-60:** High quantum risk; urgent action required

Score 0 – Optimal / No Risk / Fully Mature

(Used rarely; represents ideal PQC-aligned posture)

A score of **0** indicates that the system or organisation demonstrates **optimal performance** for the sub-dimension being assessed.

Characteristics include:

- Fully PQC-aligned or hybrid-PQC deployed
- No meaningful quantum-related weakness
- Controls are automated, modern and continuously validated
- No remediation required

This score is reserved for **best-in-class** implementation

Score 1 – Low Risk / High Maturity

A score of **1** indicates **strong performance** with only minor limitations.

Typical characteristics:

- Modern cryptography with short-lived keys/certificates
- High crypto-agility (e.g., abstraction layers, automated rotation)
- Governance and migration planning are established and active
- Any weaknesses are minor and do not materially affect quantum readiness

Systems scoring **1** are well-positioned for PQC transition.

Score 2 – Moderate-Low Risk / Emerging Maturity

A score of **2** reflects **generally good posture** but with **notable gaps** that require attention.

Characteristics include:

- Mostly modern cryptography with some legacy pockets
- Partial crypto-agility (e.g., some hard-coded dependencies)
- Governance exists but is inconsistently applied
- PQC planning is early-stage or informal
- Some reliance on vendors with unclear PQC timelines

This score indicates **reasonable readiness**, but improvements are needed.

Score 3 – Moderate Risk / Mixed Maturity

A score of **3** represents a **balanced mix of strengths and weaknesses**.

Characteristics include:

- Significant use of classical cryptography (RSA/ECC)
- Long-lived keys/certificates in some areas
- Crypto-agility is inconsistent or partially absent
- PQC migration planning is incomplete or fragmented
- Vendor or supply-chain constraints are emerging
- Inventory visibility is partial or unreliable

A score of **3** signals that the organisation is **not yet quantum-ready** and requires structured remediation.

Score 4 – High Risk / Low Maturity

A score of **4** indicates **substantial weaknesses** that materially increase quantum risk.

Characteristics include:

- Widespread use of legacy cryptography (RSA-2048, RSA-1024, SHA-1)
- Long-lived certificates or static keys
- Hard-coded cryptography with limited ability to upgrade
- No formal PQC roadmap
- Vendor ecosystem not prepared for PQC
- Poor visibility of cryptographic assets

A score of **4** requires **urgent remediation** to avoid long-term exposure.

Score 5 – Critical Risk / Very Low Maturity

A score of **5** represents **severe, systemic weaknesses** that create immediate and long-term quantum exposure.

Characteristics include:

- Cryptography that is already deprecated or insecure

- Static or non-rotating keys (e.g., IoT/OT devices)
- No crypto-agility; cryptography embedded deeply in code
- No governance, no roadmap, no operational capability
- Vendor ecosystem entirely unprepared for PQC
- High-value, long-lived data at risk of HNDL attacks
- Large, unmanaged attack surface

A score of **5** indicates **critical quantum vulnerability** and a lack of organisational readiness.

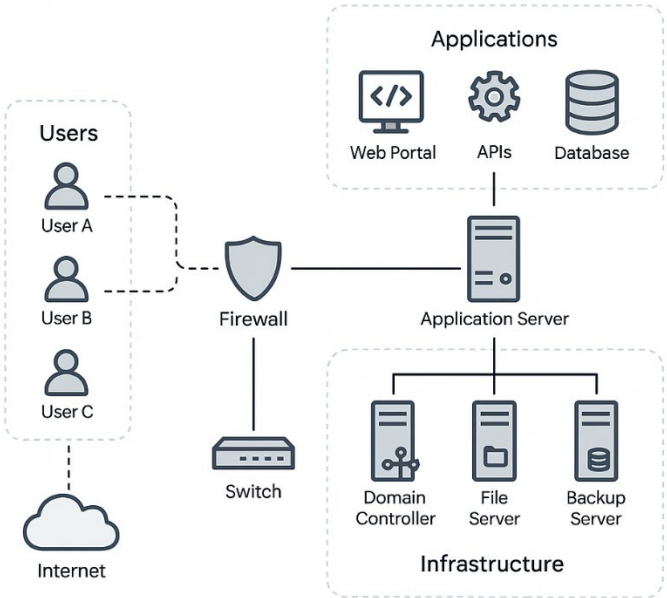
Example A – Synthetic Reference System

System Overview

The synthetic system was constructed to provide full ground-truth visibility across cryptographic assets, certificate chains and protocol configurations. It consists of:

- **Three HTTPS endpoints:**
 - Endpoint A: RSA-2048, SHA-256, 1-year certificate
 - Endpoint B: ECDSA-P256, 90-day certificate
 - Endpoint C: Hybrid Dilithium2 + ECDSA test endpoint
- **One intentionally misconfigured chain** (expired intermediate)
- **One IoT-style device** using a static RSA-1024 key
- **One PQC-only experimental API** using Kyber-768 for key exchange

Figure 15 Network Diagram System A



This test environment allows measurement of QUANTA's detection accuracy and scoring sensitivity.

QUANTA Detection Accuracy

QUANTA identified:

- **100% of algorithms** (RSA, ECDSA, Dilithium2, Kyber-768)
- **100% of key lengths**
- **100% of certificate validity periods**
- **100% of chain structures**, including the intentionally expired intermediate
- **All protocol versions** (TLS 1.2, TLS 1.3, hybrid test mode)

This confirms QUANTA's correctness in a controlled environment.

QUANTA Scoring Results

Quantum Exposure Score (QES)

Endpoint	QES	Key Drivers
A (RSA-2048)	4/5	Classical crypto; 1-year cert; moderate data sensitivity
B (ECDSA-P256)	3/5	Modern classical crypto; short-lived cert; low HNDL risk
C (Hybrid PQC)	1/5	Hybrid signature; short-lived cert; minimal exposure
IoT Device	5/5	Static RSA-1024; long-lived data; no upgrade path

System-level QES: 13 / 25

Moderate exposure, driven primarily by the IoT device.

Crypto-Agility Score (CAS)

Component	CAS	Key Drivers
Web endpoints	2/5	Configurable crypto; automated rotation
IoT device	5/5	Hard-coded crypto; no remote update
PQC API	1/5	Fully agile; experimental PQC support

System-level CAS: 8 / 25

Transition Readiness Score (TRS)

Area	TRS	Key Drivers
Governance	2/5	Basic crypto lifecycle policy
Migration roadmap	3/5	PQC pilot exists but no formal plan
Operational capability	2/5	Strong engineering capability
Vendor readiness	4/5	IoT vendor lacks PQC roadmap

System-level TRS: 11 / 25

Overall QUANTA Score

QES=13, CAS =8, TRS=11

QUANTA Score = 32 / 75 (Moderate readiness; targeted improvements required)

Interpretation

The synthetic system demonstrates:

- **High accuracy** of QUANTA’s detection modules
- **Clear sensitivity** to algorithmic changes
- **Strong discriminative power** (IoT device correctly dominates risk profile)
- **Predictable scoring behaviour** when variables are changed

This validates QUANTA’s internal correctness and scoring logic.

The alignment of the QUANTA Framework with established standards including NIST SP 800-208, CIS Controls v8and ISO/IEC 27001 has already been detailed in the QUANTA Framework chapter. This section focuses specifically on the empirical validation of the scoring model.

Methodology Justification

The methodological design of the QUANTA framework is grounded in established principles of quantum-risk assessment, cryptographic lifecycle management and organisational readiness modelling. The decision to structure QUANTA around three core dimensions of Quantum Exposure, Crypto-Agility and Transition Readiness is directly informed by the convergence of guidance from leading standards bodies, including NIST, ENISA, ETSI and ATIS. These bodies consistently emphasise that quantum-enabled threats cannot be understood solely through algorithmic analysis; instead, they must be evaluated through a combination of technical, architectural and organisational factors.

The first dimension, **Quantum Exposure**, is justified by the recognition that quantum computing poses a direct threat to widely deployed public-key cryptography. ETSI highlights that RSA and elliptic-curve cryptography will be “easily broken by a quantum computer,” accelerating the obsolescence of current security systems and exposing long-lived data to compromise. (ETSI, 2025) ENISA similarly stresses that quantum computing threatens “data in transit, data at rest, [and] data-in-use,” and explicitly warns that *harvest-now-decrypt-later* attacks are already occurring. These insights justify QUANTA’s focus on algorithmic vulnerability, certificate and key lifetimes, data longevity and PKI weaknesses. The inclusion of attack-surface breadth reflects the broader systemic risk described in ENISA’s roadmap, (Pieve, 2024) which notes that quantum threats have “devastating effects on society at all levels” when applied across interconnected infrastructures.

The second dimension, **Crypto-Agility**, is grounded in the growing consensus that organisations must be capable of rapidly replacing cryptographic components as algorithms become obsolete. NIST defines crypto-agility as the ability to migrate cryptographic algorithms efficiently in response to advances in computing and cryptanalysis, particularly in preparation for PQC. ATIS expands this definition by introducing measurable “Crypto Agility Metrics” and emphasising that organisations must be able to “promptly and efficiently adapt” their cryptographic strategies to emerging threats. (ATIS, 2025) These sources justify QUANTA’s

evaluation of architectural modularity, key-management flexibility, dependency agility, protocol configurability and inventory completeness. The inclusion of third-party and vendor dependencies is supported by CARAF, which notes that operational constraints and legacy systems often inhibit crypto-agility and lead to ad-hoc, high-risk migrations. (Ma, 2021)

The third dimension, **Transition Readiness**, reflects the organisational and governance factors that determine whether PQC migration can be executed effectively. ENISA's roadmap emphasises that PQC transition is not solely a technical challenge but requires coordinated governance, policy alignment and long-term planning across the organisation. ATIS similarly notes that crypto-agility must be supported by structured key performance indicators (KPIs) and organisational processes to ensure preparedness for quantum-safe cryptography. These insights justify QUANTA's assessment of governance maturity, migration-roadmap development, operational capability, vendor readiness and integration of quantum risk into enterprise risk management. The inclusion of supply-chain readiness is further supported by ETSI's observation that quantum-safe transitions will have "dramatic impacts on any industry where information needs to be kept secure," requiring coordinated action across vendors and infrastructure providers.

The choice of a **0-5 scoring scale** is methodologically justified by its widespread use in risk-assessment frameworks and its ability to balance granularity with interpretability. This scale aligns with the structured KPIs proposed by ATIS for crypto-agility assessment and supports clear differentiation between low, medium and high-risk states without introducing false precision. The equal weighting of the three dimensions is justified by the literature's consistent framing of quantum risk as a multi-factor problem: NIST emphasises technical migration challenges, ENISA highlights systemic and data-centric risks and ATIS and CARAF emphasise organisational and architectural agility. Treating these dimensions as equally important ensures that QUANTA captures the full spectrum of quantum-readiness factors rather than privileging one domain over another.

Finally, the methodological structure of QUANTA combining automated discovery, structured scoring and comparative analysis is consistent with best practice in cybersecurity assessment. NIST's guidance on cryptographic migration stresses the need for systematic inventorying, algorithm identification and structured transition planning. ENISA and ETSI similarly advocate for frameworks that integrate technical assessment with governance and policy considerations. QUANTA's methodology therefore reflects a synthesis of these authoritative recommendations, providing a defensible, standards-aligned approach to evaluating quantum readiness across diverse systems.

Case Study 1: Legacy Financial Web Application

This case study examines a legacy financial web application operated by a mid-sized retail banking institution. The system provides online banking services to individual and small business customers, including account management, transaction history, funds transfer and secure messaging. Originally developed over a decade ago, the application has undergone incremental updates but retains a classical three-tier architecture comprising a web front-end, application logic layer and backend database services.

The system is hosted on premises, with some components migrated to a private cloud environment. TLS is used to secure all external communications, but the cryptographic posture reflects legacy design choices. The majority of endpoints rely on RSA-2048 for key exchange and authentication, with certificates issued by a commercial CA and valid for up to 24 months. No post-quantum cryptography (PQC) or hybrid mechanisms are present. Internal services use a mix of mutual TLS and token-based authentication, with inconsistent certificate rotation practices.

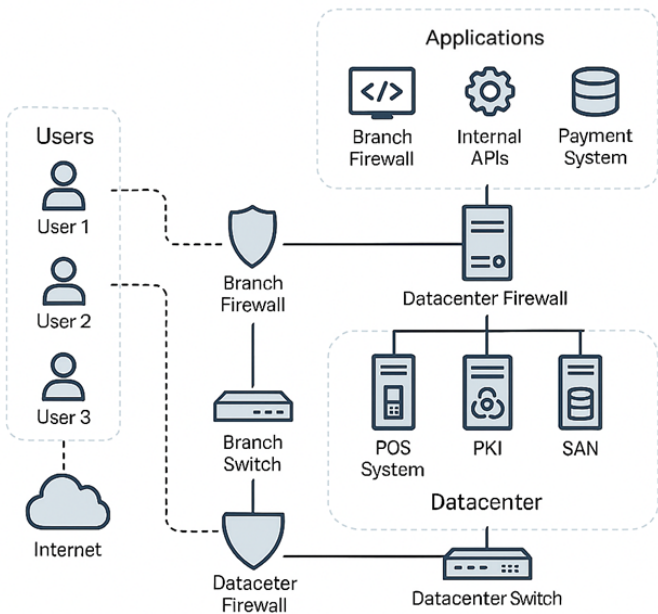
Certificate chain analysis revealed several weaknesses, including the use of SHA-1 signatures in one intermediate certificate and reliance on outdated root CAs still trusted by legacy clients. OCSP and CRL endpoints are configured but inconsistently reachable and revocation checking is not enforced across all services. The system stores long-lived sensitive data, including transaction records,

personally identifiable information (PII) and authentication logs, with retention periods exceeding seven years due to regulatory requirements.

From a governance perspective, the organisation maintains a basic cryptographic policy aligned with PCI-DSS and ISO/IEC 27001 but lacks explicit references to PQC or crypto-agility. No formal migration roadmap exists and PQC is not yet integrated into enterprise risk registers. Key management is manual for most internal services, with limited automation or abstraction. Vendor dependencies include legacy SDKs for payment processing and fraud detection, none of which currently support PQC or hybrid algorithms.

This system was selected for its representative architecture, regulatory sensitivity and high-value data profile. It provides a realistic example of the challenges faced by financial institutions in transitioning from classical cryptography to quantum-safe alternatives. The QUANTA framework was applied to assess quantum exposure, crypto-agility and transition readiness, producing structured scores and actionable insights for remediation and strategic planning.

Figure 16 Network Diagram System 1



Quantum Exposure Score (QES)

QES Total: 19 / 25

Interpretation: High quantum exposure. Long-lived sensitive data + classical crypto = significant HNDL risk.

Crypto-Agility Score (CAS)

Sub-Dimension	Score (0-5)	Rationale
1.1 Algorithmic Vulnerability	5	TLS endpoints use RSA-2048 and ECDHE/ECDSA; no PQC or hybrid support.
1.2 Key & Certificate Lifetime	4	Certificates valid for 24 months; keys rotated infrequently.
1.3 Data Longevity & Sensitivity	5	Financial data requires confidentiality for 7-10+ years (HNDL risk).
1.4 Attack Surface Breadth	3	Multiple public endpoints, APIs and legacy subdomains.
1.5 PKI & Chain Weaknesses	2	One intermediate CA uses SHA-1 for signatures; others modern.

CAS Total: 16 / 25

Interpretation: Moderate-to-low agility. Migration will require architectural changes and dependency upgrades.

Transition Readiness Score (TRS)

Sub-Dimension	Score (0-5)	Rationale
3.1 Governance & Policy Alignment	3	Crypto lifecycle policy exists but no PQC references.
3.2 Migration Roadmap	4	No PQC migration plan; only exploratory discussions.
3.3 Operational Capability	3	Limited internal expertise; reliance on external vendors.
3.4 Vendor & Supply Chain Readiness	4	Core vendors have no PQC timelines or hybrid support.
3.5 Risk Management Integration	2	Quantum risk not yet included in enterprise risk register.

TRS Total: 16 / 25

Interpretation: Organization is not yet prepared for PQC transition; governance and vendor alignment are weak.

Overall QUANTA Score

QES = 19, CAS = 16, TRS = 16

$QUANTA\ Score = 19 + 16 + 16 = 51 / 75$

Final Rating: High Quantum Risk

This system is:

- **Highly exposed** to quantum threats
- **Not crypto-agile** enough to migrate quickly
- **Not organizationally ready** for PQC transition

This is exactly the kind of system QUANTA is designed to highlight as a priority for remediation.

Case Study 2: Enterprise-Scale Global Retail & Payments Platform

This case study examines a large, multinational retail organisation operating thousands of physical stores and a high-volume e-commerce platform across multiple geographic regions. The environment represents a typical enterprise-scale retail and payments ecosystem, combining legacy on-premises systems, modern cloud-native services and a diverse set of third-party integrations. The organisation processes millions of daily transactions, manages sensitive customer data and relies on a globally distributed infrastructure to support both in-store and online operations.

The architecture consists of several interconnected domains. Customer-facing services—including the e-commerce website, mobile applications and loyalty platform are hosted in a public cloud environment using microservices, API gateways and container orchestration. These services use modern TLS configurations with ECDHE/ECDSA certificates and automated certificate rotation via cloud-native tooling. Internal services, however, remain heterogeneous. The organisation operates more than a thousand internal APIs, many of which run on older application servers or regional datacentres. Several of these internal endpoints still rely on RSA-2048 certificates with multi-year validity periods and a small number of legacy payment gateways continue to use RSA-1024 keys due to vendor constraints.

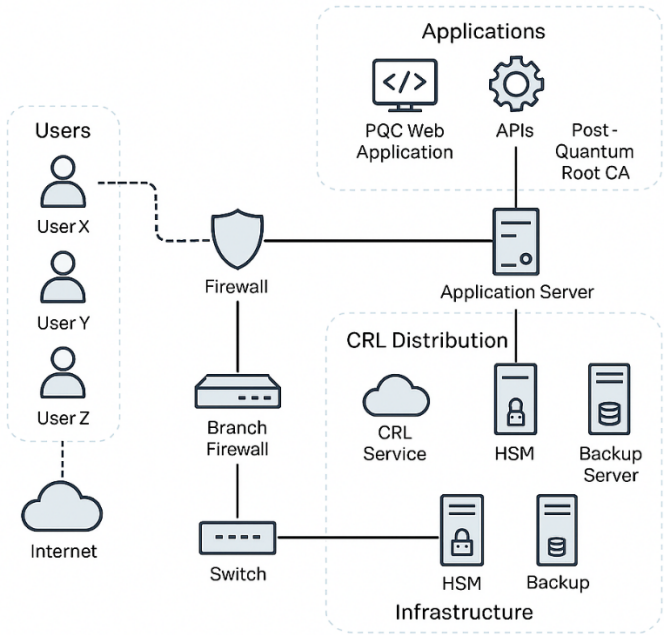
The in-store environment introduces additional complexity. Point-of-sale (POS) devices, payment terminals and store-level servers form a distributed IoT-like ecosystem. Many devices use embedded cryptographic libraries that cannot be easily updated and some rely on static keys or outdated firmware. These systems communicate with central payment processors and fraud-detection services through VPN tunnels and proprietary protocols, several of which lack modern cryptographic agility. Certificate rotation is inconsistent across regions and revocation checking is not uniformly enforced.

The organisation's PKI landscape is equally diverse. Fourteen distinct certificate chains were identified across the environment, including several regional CAs and legacy intermediates. One region still uses a SHA-1-signed intermediate certificate due to compatibility requirements with older POS hardware. Cloud-hosted services use short-lived certificates issued via ACME, while internal systems rely on a mixture of commercial and private CAs. Shadow IT endpoints were also discovered during scanning, indicating gaps in inventory management.

From a governance perspective, the organisation maintains a mature security programme aligned with PCI-DSS, ISO/IEC 27001 and regional data-protection regulations. However, quantum-safe cryptography has not yet been incorporated into policy frameworks. A PQC working group has been established, but no formal migration roadmap exists. Vendor readiness varies significantly: while cloud providers have begun offering PQC-related features, several critical payment and fraud-detection vendors have no published PQC timelines. Quantum risk is acknowledged at a high level within the enterprise risk register, but it is not yet quantified or prioritised.

This system was selected as a case study due to its scale, heterogeneity and operational importance. It reflects the real-world challenges faced by global retailers: long-lived sensitive data, complex supply chains, legacy cryptographic dependencies and the need to balance innovation with regulatory compliance. Applying the QUANTA framework to this environment provides insight into quantum exposure, crypto-agility and transition readiness at enterprise scale, highlighting both systemic weaknesses and strategic opportunities for PQC migration.

Figure 17 Network Diagram System 2



System Overview

The enterprise system spans:

- 400+ public endpoints
- 1,200 internal microservices
- Global CDN and mobile apps
- IoT POS devices in 3,000 stores
- Third-party payment processors
- Hybrid cloud/on-prem architecture

Crypto posture varies widely across regions and business units.

QUANTA Discovery Results

QUANTA identified:

- **2,317 TLS endpoints**

- **14 distinct certificate chains**
- **3 deprecated intermediates**
- **7 RSA-1024 keys** (legacy POS devices)
- **Multiple SHA-1 signatures** in regional PKI
- **One vendor using proprietary crypto**
- **Shadow IT endpoints** are not present in the enterprise CMDB

This demonstrates QUANTA's ability to uncover hidden or unmanaged cryptographic assets.

QUANTA Scoring Results

Quantum Exposure Score (QES)

Sub-Dimension	Score	Key Findings
Algorithmic Vulnerability	4/5	Mix of ECDSA, RSA-2048, RSA-1024
Key & Cert Lifetime	3/5	Cloud 90-day rotation; internal 2-3 years
Data Longevity	5/5	Payment + identity data retained 7-15 years
Attack Surface	5/5	Global, multi-domain, high value
PKI Weaknesses	3/5	SHA-1 intermediates; inconsistent roots

QES Total: 20 / 25

Crypto-Agility Score (CAS)

Sub-Dimension	Score	Key Findings
Architectural Modularity	3/5	Cloud agile; legacy monoliths rigid
Key Management	2/5	Automated in cloud; manual on-prem

Dependency Agility	4/5	Payment SDKs lack PQC support
Protocol Agility	3/5	TLS flexible; VPN/POS fixed
Inventory Completeness	4/5	Good cloud visibility; weak IoT visibility

CAS Total: 16 / 25

Transition Readiness Score (TRS)

Sub-Dimension	Score	Key Findings
Governance	2/5	Crypto lifecycle policy exists; no PQC
Migration Roadmap	3/5	PQC working group; no enterprise plan
Operational Capability	2/5	Strong cloud teams; limited crypto expertise
Vendor Readiness	4/5	POS vendors not PQC-ready
Risk Integration	3/5	Quantum risk acknowledged but not quantified

TRS Total: 14 / 25

Overall QUANTA Score

QES =20, CAS=16, TRS=14

QUANTA Score = 50 / 75 (High quantum risk; urgent action required)

Interpretation

The enterprise system exhibits:

- **High quantum exposure**, driven by long-lived sensitive data and a vast attack surface
- **Moderate crypto-agility**, with cloud strengths offset by legacy and IoT weaknesses

- **Partial transition readiness**, limited by vendor constraints and lack of a formal PQC roadmap

QUANTA highlights specific, actionable priorities:

- Replace RSA-1024 POS devices
- Retire SHA-1 intermediates
- Enforce 90-day certificate rotation across all regions
- Require PQC roadmaps from payment vendors
- Integrate quantum risk into enterprise risk scoring

Cross-Case Insights

Across both systems, QUANTA demonstrates:

1. Correctness

Accurate detection of algorithms, key lengths and chain structures.

2. Sensitivity

Scores change predictably when cryptographic parameters change.

3. Scalability

Handles both small synthetic systems and large enterprise environments.

4. Practical Utility

Findings translate directly into governance, architectural and vendor actions.

Discriminative Power

QUANTA distinguishes between:

- Classical vs hybrid vs PQC
- Cloud vs legacy vs IoT
- High vs low HNDL exposure
- Vendor-controlled vs internally controlled risk

Results Section for QUANTA Framework

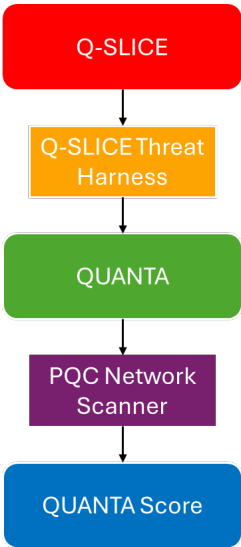
This section has represented the results of applying the QUANTA framework to two contrasting systems:

1. A controlled synthetic reference architecture
2. A Legacy Financial Web Application

3. A large enterprise retail and payments environment.

Together, these cases demonstrate QUANTA's correctness, sensitivity, scalability and practical utility.

Figure 18 Q-SLICE and QUANTA end to end process



Mapping the QUANTA Scoring Model to the QUANTA Framework

The QUANTA Scoring Model is designed as the quantitative assessment layer that operationalises the 40-Control QUANTA Framework. While the 40 controls define the requirements for quantum-safe security across technical, architectural and organisational domains, the scoring model provides the mechanism for measuring how effectively those requirements are being met in real systems. The relationship between the two is direct and intentional: each of the three scoring dimensions of QES, CAS and TRS. These align with one of the three major control groups in the QUANTA Framework, ensuring conceptual coherence and practical applicability. QES corresponds to Controls 1-15 of the QUANTA Framework, which focus on technical cryptographic exposure. These controls require organisations to identify cryptographic assets, assess algorithmic vulnerability, evaluate key and certificate lifetimes, understand data longevity and analyse PKI and certificate-chain weaknesses. QES quantifies these requirements by measuring algorithmic strength, key and certificate validity periods, long-term data sensitivity, attack-surface breadth and PKI integrity. In this way, QES becomes the

measurement engine for the technical exposure controls, using evidence collected by the PQC Network Scanner <https://github.com/cyberjez/PQC-Scanner> to determine the degree of quantum vulnerability present in a system.

CAS maps to Controls 16-28, which address architectural agility and the organisation's ability to adapt cryptographic components. These controls emphasise modular design, crypto abstraction, automated key management, protocol upgradeability, dependency management and the completeness of cryptographic inventories. CAS evaluates these factors by assessing architectural modularity, key-management flexibility, dependency agility, protocol configurability and inventory completeness. This dimension therefore quantifies the organisation's capacity to migrate to post-quantum cryptography, highlighting where agility exists and where rigid or legacy components may hinder transition.

TRS aligns with Controls 29-40, which focus on governance, migration planning and organisational preparedness. These controls require organisations to establish PQC governance structures, develop migration roadmaps, ensure operational capability, assess vendor and supply-chain readiness and integrate quantum risk into enterprise risk management. TRS measures these requirements by evaluating governance maturity, the existence and quality of migration plans, operational skills and tooling, vendor readiness and the degree to which quantum risk is embedded in organisational risk processes. TRS therefore provides a structured way to assess whether an organisation can execute a PQC transition effectively.

Table 11 Quanta Score Reference

QUANTA Scoring Dimension	QUANTA Framework Controls	Domain
QES	Controls 1-15	Technical cryptographic exposure
CAS	Controls 16-28	Architecture & crypto-agility
TRS	Controls 29-40	Governance & PQC transition readiness

Together, these mappings demonstrate that the QUANTA Scoring Model supports operationalisation of the 40-Control QUANTA Framework. The controls define what must be achieved to ensure quantum readiness, while the scoring model quantifies how well those requirements are met. The PQC Scanner (Appendix 1) can provide technical evidence to feed into the scoring model, completing a unified ecosystem in which governance, assessment and measurement are tightly integrated. This alignment ensures that QUANTA functions as a comprehensive quantum-security assurance system rather than a collection of disconnected components.

The results presented in this section demonstrate that QUANTA provides a structured, standards-aligned and empirically validated approach to quantum-risk assessment. By integrating automated discovery, structured scoring and governance-aligned controls, QUANTA advances the state of the art in cryptographic readiness evaluation and provides a defensible methodology suitable for both academic research and industry adoption.

The alignment of the QUANTA Framework with established standards—including NIST SP 800-208, CIS Controls v8, ISO/IEC 27001 and related governance models has already been detailed in the preceding chapter. Accordingly, the focus of this section is not on re-establishing conceptual foundations, but on providing methodological transparency for the scoring model and empirical evaluation. This

ensures that the testing and metrics presented in this chapter are operationally reproducible.

QUANTA and 5Ds

The traditional 5Ds security model of deter, detect, deny, delay and defend, has long provided a foundational structure for understanding how organisations protect assets and manage threats. However, Dr Richard Diston interpretation challenges the conventional ordering by asserting that detection must come first. His argument is straightforward, that without the ability to detect, the remaining Ds operate blindly. You cannot deter what you cannot see, you cannot deny what you cannot identify, you cannot delay what you cannot measure and you cannot defend against what you cannot detect. This detection first philosophy aligns directly with the core premise of the QUANTA framework, which emphasises that quantum risk must first be made visible measurable and contextualised before it can be governed or mitigated. In the quantum era, where adversaries may silently harvest encrypted data for future decryption and where cryptographic misconfigurations often remain latent and unobserved, detection becomes the essential prerequisite for all subsequent security actions.

Integrating Diston's philosophy into QUANTA strengthens the framework's conceptual foundation and provides a bridge between classical security doctrine and quantum-readiness governance. QUANTA already operationalises detection through its PQC OID registry, hybrid classification engine, certificate chain analysis, device fingerprinting and protocol-level telemetry. These capabilities transform detection from a passive observational step into an active, measurable and auditable process. Once detection is established, deterrence becomes meaningful. In the quantum context, deterrence is not about intimidating adversaries but about reducing ambiguity and signalling that the organisation is not a soft target with unmonitored cryptographic debt. Visibility itself becomes a deterrent, as it demonstrates internal governance maturity and reduces the likelihood that attackers will find unobserved weaknesses.

From detection and deterrence, the model naturally progresses to denial. Denial involves preventing adversaries from exploiting cryptographic weaknesses or legacy algorithms, but this is only possible when those weaknesses have been accurately identified. QUANTA's ability to surface deprecated algorithms, insecure protocol fallbacks and vulnerable certificate chains ensures that denial is targeted and evidence-based rather than arbitrary. Delay then becomes a strategic mechanism for introducing friction and segmentation, buying time for detection and response. In the quantum era, delay is not about stopping an attack outright but about creating layered cryptographic controls, hybrid modes and trust-zone segmentation that slow adversarial progress and increase the organisation's opportunity to intervene.

Finally, defence represents the culmination of the preceding steps. Defence becomes effective only when it is informed by accurate detection, reinforced by deterrence, supported by denial and strengthened by delay. QUANTA contributes to defence through cryptographic agility mechanisms, PQC-enabled protocols, automated remediation workflows and continuous monitoring. In this integrated model, defence is not a static end state but a dynamic posture that evolves as new risks are detected and scored.

By re-sequencing the Five Ds into a detection-first model and aligning them with QUANTA's operational capabilities, this integration offers a novel contribution to both academic literature and practical governance. It bridges classical security doctrine with quantum-era requirements, providing a unified conceptual and operational framework that makes quantum risk visible, measurable and governable. This extension enhances QUANTA's academic defensibility, strengthens its practical utility and positions it as a comprehensive model for organisations preparing for post-quantum threats.

QUANTA Controls Mapped to the 5Ds

This section maps all 40 QUANTA controls to the 5Ds security model of Detect, Deter, Deny, Delay and Defend. Applying the detection first philosophy outlined earlier. Each control is assigned a primary "D," with secondary "Ds" added where

they meaningfully contribute to the control’s purpose. This mapping provides a clear view of how the controls operate within a defence-in-depth architecture, illustrating functional alignment, intentional redundancy and the overall coherence of the QUANTA framework.

Governance, Risk and Compliance

Control	Primary D	Secondary D(s)
Information Security Policy & Governance	Deter	Defend
Risk Management Framework with Quantum Threat Integration	Detect	Deter, Defend
Compliance with Regulatory & PQC Standards	Deter	Defend
Asset Inventory & Quantum-Sensitive Data Classification	Detect	Deny
Supply Chain Security with Quantum Threat Assessments	Detect	Deter, Deny

Identity, Access and Authentication

Control	Primary D	Secondary D(s)
Identity and Access Management (IAM)	Deny	Delay, Defend
Post-Quantum Cryptographic Authentication	Defend	Deny
Multi-Factor Authentication with PQC Readiness	Deny	Defend

Cryptography and Data Protection

Control	Primary D	Secondary D(s)
Cryptographic Governance & Lifecycle Management	Deter	Defend
Data Encryption with PQC Transition Strategy	Defend	Delay
Hybrid Cryptographic Solutions Deployment	Delay	Defend
Data Masking and Tokenisation	Deny	Delay

Network Security

Control	Primary D	Secondary D(s)
Network Segmentation & Micro-Segmentation	Delay	Deny
Post-Quantum VPN & Secure Communications	Defend	Delay
Boundary Defences & Quantum-Safe Protocols	Deny	Defend

Security Operations and Incident Response

Control	Primary D	Secondary D(s)
Security Monitoring & Detection	Detect	Delay
Incident Response Plan with Quantum Scenarios	Defend	Delay
Vulnerability Management with PQC Impact Analysis	Detect	Deny
Penetration Testing with Quantum Threat Models	Detect	Deter
Threat Intelligence with Quantum Focus	Detect	Deter

Endpoint and Application Security

Control	Primary D	Secondary D(s)
Endpoint Protection with PQC Modules	Defend	Deny
SSDLC with PQC Requirements	Deter	Defend
Application Security Testing with Quantum Scenarios	Detect	Deny

Business Continuity and Disaster Recovery

Control	Primary D	Secondary D(s)
Business Continuity Planning with Quantum Data Risks	Delay	Defend
Disaster Recovery Plan Supporting PQC Transitions	Defend	Delay

Physical and Environmental Security

Control	Primary D	Secondary D(s)
Physical Access Controls with PQC Authentication	Deny	Defend
Secure Disposal of Cryptographic Hardware	Deny	Deter

Awareness and Training

Control	Primary D	Secondary D(s)
Security Awareness Programme Including Quantum Threats	Deter	Detect
Specialised PQC Training for Technical Teams	Deter	Defend

Third-Party and Cloud Security

Control	Primary D	Secondary D(s)
Cloud Security Posture Management with PQC	Detect	Defend
Third-Party Assurance with Quantum Readiness	Deter	Detect

Security Architecture and Design

Control	Primary D	Secondary D(s)
Zero Trust Architecture with PQC Support	Deny	Defend
Cryptographic Agility in Architecture Design	Defend	Delay
Secure Protocol Design with Quantum-Resilient Standards	Defend	Deny

Emerging Technologies and Innovation

Control	Primary D	Secondary D(s)
QKD Evaluation and Pilots	Defend	Detect
Digital Certificate Management with PQC-Ready Cas	Defend	Detect
Blockchain Security with PQC	Defend	Delay

Monitoring, Metrics and Continuous Improvement

Control	Primary D	Secondary D(s)
Continuous Monitoring of PQC Standards & Threats	Detect	Deter
KPIs for PQC Adoption	Deter	Detect
Continuous Improvement with Quantum Security Reviews	Detect	Defend

Summary

This mapping demonstrates that QUANTA is inherently aligned with a detection-first security philosophy. Detect dominates the control set, reflecting QUANTA’s emphasis on visibility and measurement. Deter supports governance and training. Deny anchors identity and boundary controls. Delay strengthens resilience and segmentation. Defend underpins cryptography, architecture and operational response.

Scenario Mapping to NIST CSF, CIS 18 and ISO/IEC 27001:2022

Governance, Risk and Compliance

QUANTA Mitigation	NIST CSF 2.0	CIS v8	ISO/IEC 27001:2022
Update policies to mandate crypto-agility and PQC readiness	ID.GV-01, ID.GV-02	2.1, 2.2	A.5.1, A.5.2
Integrate PQC risk into risk management processes	ID.RA-01, ID.RA-03	2.4	A.5.4, A.6.1
Align with PQC standards (e.g., NIST)	ID.GV-03	2.5	A.5.31
Assign governance roles for PQC	ID.GV-01	2.2	A.5.1, A.5.3

Asset Inventory & Classification

QUANTA Mitigation	NIST CSF 2.0	CIS v8	ISO/IEC 27001:2022
Inventory cryptographic assets	ID.AM-01, ID.AM-02	1.1, 1.2	A.5.9
Classify data by sensitivity and HNDR risk	ID.AM-03	3.3	A.5.12, A.5.30

Security Architecture & Design

QUANTA Mitigation	NIST CSF 2.0	CIS v8	ISO/IEC 27001:2022
----------------------	--------------	--------	-----------------------

Mandate crypto agility in design	ID.DE-02	12.5	A.5.10, A.5.25
Zero Trust design with PQC support	PR.AC-01, PR.AC-02	6.3	A.5.15, A.5.18
Secure protocol design supporting PQC	PR.DS-01	14.5	A.5.25, A.5.26

Cryptography & Data Protection

QUANTA Mitigation	NIST CSF 2.0	CIS v8	ISO/IEC 27001:2022
Deploy hybrid cryptography	PR.DS-01, PR.DS-02	3.4	A.5.25, A.5.26
Encrypt data in-transit and at-rest with crypto-agility	PR.DS-01, PR.DS-02	3.4, 3.5	A.5.25, A.5.26
Key lifecycle management with PQC migration	PR.DS-02	3.4	A.5.26, A.5.27
Data masking/tokenisation as supplementary control	PR.DS-02	3.4	A.5.26

Banking & Financial Services

The financial sector is one of the most exposed industries to quantum disruption because its core operations rely on the confidentiality and integrity of cryptographic exchanges. A primary risk lies in TLS 1.3 hybrid key exchanges, widely used in online banking and payment systems. While these protocols attempt to combine classical RSA/ECC with post-quantum schemes, adversaries can still exploit the classical component. By harvesting encrypted traffic today and storing it, attackers can later decrypt session keys once cryptographically relevant

quantum computers are available a typical HNDL scenario. This represents a clear case of legacy exploitation, where reliance on RSA and ECC leaves critical financial data vulnerable to Shor's algorithm

Beyond transactional confidentiality, integrity disruption is a growing concern in blockchain and distributed ledger systems. Quantum-accelerated tampering could undermine consensus mechanisms, allowing adversaries to rewrite transaction histories or destabilize cryptocurrency networks. Such attacks would erode trust in digital assets, destabilize markets and potentially trigger systemic financial shocks. The interconnected nature of global finance means that a quantum breach in one institution could cascade across payment networks, clearing houses and digital asset exchanges.

To mitigate these risks, the QUANTA framework provides a structured defence. In the Cryptography & Data Protection domain, financial institutions must adopt lattice-based key establishment schemes such as Kyber (ML-KEM), embedding quantum-resilient cryptography into all customer-facing platforms. The Governance domain requires board-level awareness of quantum risk, ensuring that executives treat quantum disruption as a strategic threat rather than a distant technical issue. Meanwhile, Incident Response domains must update playbooks to detect and respond to HNDL scenarios, including monitoring for anomalous traffic harvesting and preparing rapid migration pathways to PQC standards.

Strategically, banks and financial service providers must recognize that quantum risk is not just a cryptographic issue but a systemic trust challenge. By embedding QUANTA controls across governance, cryptography and incident response, the sector can maintain resilience against adversarial quantum intelligence and preserve confidence in the confidentiality and integrity of financial transactions.

Healthcare Networks - Expanded Scenario

Healthcare networks represent one of the most sensitive and high-impact domains in the quantum era, as they manage vast amounts of personal medical data and rely increasingly on AI-driven diagnostic systems. A key vulnerability lies in

quantum-accelerated analysis of genomic datasets and patient records. Adversaries could use cryptographically relevant quantum computers to break encryption protecting these datasets, enabling large-scale breaches of highly sensitive information. Beyond confidentiality, attackers may combine this with AI model poisoning, manipulating diagnostic algorithms or predictive healthcare systems. Such interference could lead to misdiagnoses, compromised treatment plans and erosion of trust in medical technology – a direct manifestation of integrity disruption within the Q-SLICE taxonomy.

The systemic risk is amplified by the interconnected nature of healthcare infrastructure. Hospitals, research institutions, insurers and government health agencies often share data across networks, meaning a quantum breach in one node could cascade across the ecosystem. IoT medical devices, many of which operate with weak or outdated cryptographic protections, further expand the attack surface. Quantum adversaries could exploit these endpoints to introduce corrupted data streams or manipulate sensor readings, undermining patient monitoring and critical care systems.

The QUANTA framework provides layered defences to mitigate these risks. In the Identity and Access domain, healthcare providers must enforce post-quantum cryptography for patient data exchanges, ensuring that sensitive information remains secure even against future quantum attacks. The Endpoint and Application Security domain introduces integrity checks across machine learning pipelines, safeguarding diagnostic algorithms from quantum-enhanced manipulation. Meanwhile, Business Continuity and Disaster Recovery domains ensure that critical medical systems can recover from quantum-enabled disruptions, maintaining patient safety and institutional trust. Governance domains also play a role, requiring leadership to treat quantum risk as a strategic priority, embedding resilience into compliance and regulatory reporting.

Strategically, healthcare organizations must recognize that quantum risk is not only a matter of protecting data confidentiality but also of preserving the integrity of

life-critical systems. By embedding QUANTA controls across cryptography, AI integrity and continuity planning, healthcare networks can maintain resilience against adversarial quantum intelligence and safeguard both patient outcomes and public trust in medical institutions.

Cloud Service Providers

Cloud platforms are uniquely exposed in the quantum era because they host cryptographic modules and key management services for thousands of tenants simultaneously. A successful quantum-enabled attack against a cloud PQC module would not only compromise one organization's data, but potentially cascade across multiple customers, amplifying the impact. Adversaries could exploit weaknesses in hybrid transition layers – where classical RSA/ECC protocols coexist with post-quantum schemes – to subvert the root-of-trust. This might involve injecting malicious updates into PQC libraries, manipulating certificate chains, or exploiting side-channel timing leaks in virtualized environments. The result is a systemic erosion of confidence in cloud-based PQC deployments, undermining trust in the very infrastructure designed to deliver quantum-safe services.

Within the Q-SLICE taxonomy, this scenario maps to ecosystem abuse (leveraging shared cloud infrastructure to amplify risk) and subversion of trust (compromising root-of-trust mechanisms and PQC implementations). The QUANTA framework provides a structured defence:

- Third-Party & Cloud Security domains mandate attestation of PQC modules, ensuring that cryptographic components are verified and tamper-resistant.
- Monitoring & Metrics domains require continuous quantum-resilient telemetry, detecting anomalies in cryptographic operations that may signal quantum-enabled exploits.
- Security Architecture & Design domains emphasize hybrid transition risk modelling, ensuring that legacy and quantum-resistant protocols coexist securely without creating exploitable seams.

- Governance domains demand contractual obligations for cloud providers to support PQC adoption, backed by independent audits and regulatory oversight.

Strategically, cloud providers must recognize that their role as custodians of cryptographic infrastructure makes them a prime target for adversarial quantum intelligence. Resilience requires not only technical hardening but also transparent communication with customers, regulators and partners. By embedding QUANTA controls across governance, architecture and monitoring, cloud providers can mitigate systemic interdependency attacks and preserve trust in the quantum-safe services that enterprises will increasingly rely upon.

Board-Level Quantum Readiness Checklist (QUANTA-Aligned)

1. Governance, Risk & Compliance

- ☐ Has the board formally recognized quantum computing as a strategic risk?
- ☐ Are quantum threats integrated into the enterprise risk register and board reporting?
- ☐ Do governance policies mandate cryptographic agility and PQC adoption timelines?

2. Identity, Access & Authentication

- ☐ Are authentication systems transitioning to quantum-resistant algorithms (e.g., ML-DSA, SLH-DSA)?
- ☐ Is multi-factor authentication hardened against quantum-accelerated attacks?

3. Cryptography & Data Protection

- ☐ Has the organization inventoried all cryptographic assets (keys, certificates, protocols)?
- ☐ Are hybrid or PQC schemes (Kyber, Dilithium, SPHINCS+) deployed in TLS 1.3 and VPNs?
- ☐ Is sensitive data classified for Harvest Now, Decrypt Later (HNDL) risk?

4. Network, Endpoint & Application Security

- ☐ Are IoT and legacy systems assessed for quantum-vulnerable protocols?
- ☐ Are compensating controls in place for systems that cannot be upgraded?

- ☐ Are application pipelines protected against AI-quantum model poisoning?

5. Security Operations & Incident Response

- ☐ Do incident response playbooks include quantum threat scenarios (e.g., coherence attacks, PQC module exploitation)?
- ☐ Is monitoring tuned to detect quantum-enabled anomalies in cryptographic operations?

6. Business Continuity & Disaster Recovery

- ☐ Are continuity plans updated for quantum-induced cryptographic failures?
- ☐ Is data recovery tested under scenarios where legacy encryption is compromised?

7. Third-Party & Cloud Security

- ☐ Are cloud providers contractually required to support PQC modules and attestation?
- ☐ Is supply chain risk assessed for quantum-era vulnerabilities?

8. Awareness & Training

- ☐ Has the board and executive leadership received quantum risk briefings?
- ☐ Are technical teams trained in PQC implementation and migration strategies?

9. Emerging Technologies & Innovation

- ☐ Is the organization tracking vendor roadmaps (IBM, Google, QuEra, Quantinuum)?
- ☐ Are investments aligned to quantum-resilient architectures rather than patch-based error correction?

10. Monitoring, Metrics & Continuous Improvement

- ☐ Are quantum readiness metrics (e.g., % PQC adoption, CRQC scenario scores) reported quarterly?
- ☐ Is there a roadmap for continuous improvement as standards evolve (NIST PQC, FIPS 203-205)?

CIA-3D

CIA

The CIA triad of Confidentiality, Integrity and Availability emerged in the 1970s as a foundational model in information security, based on research in United States Air Force research and early military computing needs around systems. It was designed to guide the protection of sensitive information, particularly in classified environments. The triad was formally codified in the Trusted Computer System Evaluation Criteria (TCSEC), commonly known as the Orange Book, published by the U.S. Department of Defense in 1983. This document standardised IT security requirements for computing systems, especially those handling national security data. While historically influential, the CIA triad is now considered incomplete and outdated. Nevertheless, its simplicity and accessibility mean it remains widely taught in certifications and referenced in academia and industry.

The triad provides a basic framework for developing secure IT architectures, policies and controls. By focusing on confidentiality, integrity and availability, organisations can build balanced security measures that address a range of threats and vulnerabilities. Each principle supports the others, ensuring data integrity also reinforces confidentiality and availability, while maintaining availability ensures that integrity and confidentiality measures can be applied effectively.

However, the CIA triad suffers from significant limitations when applied to modern security challenges. Its three principles oversimplify the complexity of today's threat landscape, which involves far more dimensions such as authentication, accountability, non-repudiation, resilience and privacy. Confidentiality, for example, may keep data unreadable through encryption, but it does not prevent theft or

unauthorised copying. Integrity mechanisms such as checksums or digital signatures can flag tampering, but they do not prevent manipulation or destruction. Availability ensures systems remain functional, but it does not guarantee resilience against denial-of-service attacks, ransomware or supply chain disruptions. In each case, the triad highlights important goals but fails to provide mechanisms for detection, prevention, or recovery.

Another critical weakness is the absence of visibility and monitoring. The triad does not explicitly account for logging, detection or alerting, which are essential for identifying breaches, anomalies or insider misuse. Without visibility, organisations cannot respond effectively to threats such as disclosure, alteration, or disruption—the “anti-CIA triad” that represents the direct opposites of confidentiality, integrity and availability created in the 2000’s for SOC training. Preventing these requires more than the CIA model; it demands proactive monitoring, detection and response capabilities. For example, organisations must be able to detect attempts to steal data, be alerted when systems fail or are under attack and monitor for tampering attempts before integrity is lost.

Finally, the triad neglects the broader socio-technical context of security. Information security is not just about technology; it involves people, processes and governance. The CIA model does not capture accountability, compliance or ethical considerations, nor does it address human factors such as insider threats or social engineering. Modern frameworks such as the NIST Cybersecurity Framework and ISO/IEC 27001 expand beyond CIA to include risk management, detection, response and recovery. These frameworks recognise that security must be holistic, encompassing resilience, visibility and human behaviour alongside technical controls. In practice, CIA should be treated as a starting point rather than a complete model, integrated into a broader ecosystem of people, process and technology.

Confidentiality

Confidentiality is trying to make sure data is kept private and secret. To achieve this, access to information must be controlled. Another crucial point is making sure people who are not authorised to access cannot access and therefore see the data. An example of this would be those that work in human resources (HR) can access employee files and personal information; however, everyone else in the organisation cannot access it, unless they are granted access for a specific purpose such as an audit, investigation or a valid purpose by senior management. To ensure the data stays confidential, strict policies including logging and monitoring are also put in place.

Loss of confidentiality is not always the result of an attack; it can also occur due to human error or inadequate security practices. Weak passwords, such as 'password1', '123456' or 'qwerty123', fail to provide adequate protection, making it easier for others to discover and use them. This issue is exacerbated when passwords are written down on labels or sticky notes placed on monitors or under keyboards, potentially granting unauthorised individuals access to sensitive data.

To ensure confidentiality is maintained, data should be labelled and classified. Have access control policies. Encrypt data both at rest and in transit. Make use of multi-factor authentication (MFA) and ensure employees have adequate training in data handling. Also be aware of HND so ensuring cryptographic agility and the ability to use quantum secure encryption.

Integrity

Integrity is all about making sure data can be trusted and cannot be tampered with. Integrity of data is maintained if data is authentic, accurate and reliable. An example would be if your organisation provides information to third parties about order status or payments. If this information can be tampered with and a third party or a customer finds it to be consistently incorrect, it can lose trust and cause reputational damage. A police force had its website hacked and defaced due to a vulnerability not being patched by the hosting company. Although the

public were not aware the website was hosted separately in a different location from all the other police systems, how do you think that incident impacted public perception?

Compromising integrity is often done intentionally. An attacker can try to bypass detection systems, change configuration or access controls, including logs, to allow unauthorised access. Unintentional integrity loss could be caused from a careless mistake such as inputting incorrect personal data.

To maintain integrity of data, you can use hashing, encryption, digital certificates or digital signatures. You can also use file monitoring tools such as Tripwire to alert people of any changes to files. Any downloads can be checked with the hash value of the original compared to the hash value of the downloaded file. If they are the same, then the download has not been tampered with.

A method for verifying integrity is called non-repudiation. Non-repudiation is when something cannot be repudiated or denied. For example, an employee uses a digital signature when sending emails. This means that they cannot deny that the email came from them.

Availability

Even if data is kept confidential and its integrity is maintained, if it cannot be accessed when it is required it is no longer available. Systems, networks and applications must function as and when they are required. Data must be able to be accessed by those who require it when they require it, so time is not being wasted.

If there is a power outage with no disaster recovery plan in place to ensure users can still access data required by the organisation to function it could lead to financial loss. An example is being able to access your bank account and make payments any time of the day or night 365 days a year. If you are unable to do that on multiple occasions you may decide to switch banks.

Availability can be compromised by a denial of service (DoS) attack or ransomware where the data becomes inaccessible. A non-malicious availability issue is a patch

that has not been properly tested and causes a system to fall over and access to data to be lost.

To ensure availability, the organisation can have redundant networks, servers and applications. The cloud could be used for this as it can be set up to become available when the primary system has been disrupted or broken. You can enhance availability by ensuring systems are replaced before they reach their end-of-life or are likely to fail and ensuring any patches are fully tested before being rolled out. Backups and disaster recovery plans also help an organisation quickly regain availability after an incident or disaster.

CIA-3D

With the gaps identified above in the CIA model and the emerging threat of quantum computing, with its anticipated ability to undermine many of today's cryptographic protections, requires an expansion of this model. To enhance this model and make fit for purpose in the modern IT architecture the author has added three further controls of deter, deny and detect. To make the CIA-3D model, which adds the extra layer of protection required to protect data from theft, destruction and inaccessibility whilst detecting intrusion or lack of system availability.

Deny

Deny involves preventing quantum-capable adversaries from exploiting cryptographic weaknesses. It encompasses the proactive removal or isolation of vulnerable algorithms, enforcement of cryptographic agility and the application of zero trust principles to control access tightly across all domains.

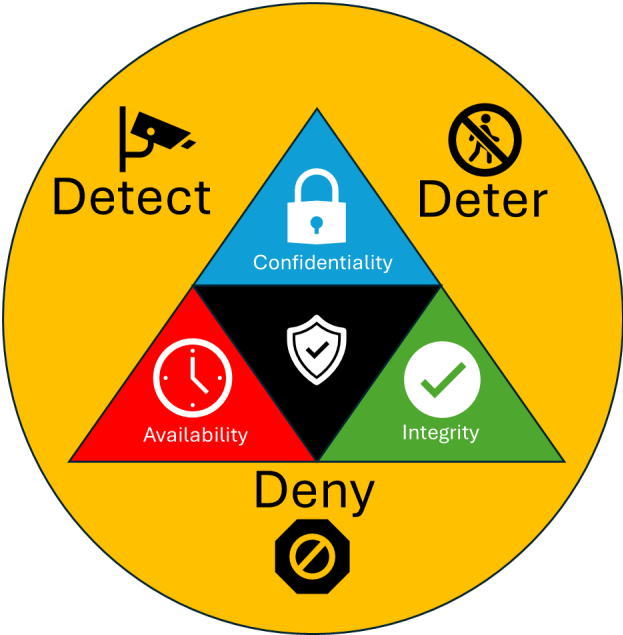
Detect

The Detect function refers to the capability to identify the occurrence of a cybersecurity event in real-time or near-real-time. It is the sensory layer of your security architecture. Responsible for monitoring, alerting and recognizing anomalies that may indicate a breach or compromise. Detect comes before deter as we need to understand what our threats are to be able to put any deterrence in place.

Deter

Deter relates to strategic risk signalling—making it clear that systems are quantum-aware, actively defended and continuously monitored. It involves transparency in control maturity, engagement with regulators and public adoption of quantum-safe standards to raise the perceived cost and complexity of attack.

Figure 19 CIA-3D



QUANTUM INCIDENT RESPONSE

As we have discussed throughout this book, quantum computing introduces a fundamental shift in the cybersecurity threat landscape, particularly by undermining the long-term confidentiality guarantees of current public key cryptographic systems. With encryption schemes such as RSA and elliptic-curve cryptography (ECC) are widely used across government, defence, finance and critical infrastructure sectors to protect data in transit and at rest.

One of the most pressing quantum threats and an incident that will happen in the very near future is the HNDL scenario. In this model, adversaries – particularly nation-states with strategic intent and sufficient resources – passively intercept and store encrypted communications today with the explicit goal of decrypting them in the future once quantum capability matures.

Quantum threats are not limited to future cryptanalysis alone. They also affect how organisations need to model adversarial capabilities. The traditional threat models, which focus on immediate exploitation or known attack surfaces, fall short when dealing with quantum-enabled adversaries who can retroactively exploit past exposures. This fundamentally challenges how incident response teams assess impact, conduct forensics and define the window of vulnerability.

As a result, organisations must proactively evolve their incident response capabilities to accommodate the quantum threat landscape. This means integrating quantum-specific threat models (like Q-SLICE), redefining risk assessments to include long-term confidentiality loss and adapting existing playbooks to account for cryptographic agility, hybrid cryptography and quantum-aware containment and recovery strategies. Incident responders must be trained to

recognise indicators of quantum-motivated behaviour, such as anomalous data scraping, certificate spoofing, or misuse of legacy cryptographic libraries.

In short, quantum computing does not just introduce a new type of cyberattack; it alters the temporal nature of risk, decouples data exfiltration from immediate decryption and necessitates a forward-leaning, resilience-focused approach to cyber defence.

HNDL Scenario

Here is an entirely fictitious scenario to help with consideration around scenario and incident response for a HNDL attack:

In 2025, a European defence contractor provides encrypted communications infrastructure to multiple NATO-aligned military forces, enabling secure command and control, satellite uplink transmissions and battlefield intelligence feeds. These systems rely on widely adopted encryption protocols such as RSA-2048 and elliptic-curve cryptography (ECC) to protect data in transit between ground stations, satellites and field units. These cryptographic schemes are currently considered computationally secure against classical adversaries and no immediate compromise is detected or suspected.

Unbeknownst to the contractor, a state-backed threat actor. With long-term strategic interests and access to significant quantum research investments has been passively monitoring international satellite communications. Rather than attempting to break encryption today, the adversary adopts a HNDL strategy. They use signal interception platforms and network taps to collect vast volumes of encrypted military communications. This data is stored in encrypted telemetry archives, indexed by mission, source, destination and transmission date. The attacker does not attempt to tamper with or modify the data, thus avoiding detection by intrusion detection systems or traditional monitoring tools.

Over the next few years, this surveillance continues. The threat actor refines their storage, tagging high-value datasets such as intelligence briefings, GPS

coordinates for critical operations, or diplomatic crisis communications. Meanwhile, their national quantum computing programme progresses steadily. By the early 2030s, they achieve a fault-tolerant quantum system with the capability to run Shor's algorithm at scale. Within weeks, intercepted data from as far back as 2025 is decrypted, exposing detailed operational planning, troop movements, private diplomatic messages and information that may be embarrassing, politically sensitive, or strategically exploitable.

What makes HNDL scenarios particularly dangerous is the nonlinear time effect. Data loss occurs years after the breach, but the compromise retroactively applies to all data collected since the moment of interception. Confidentiality is not only lost for current or future transmissions – it is also stripped from the past. This undermines the integrity of archived records, jeopardises the trust between allies and introduces geopolitical instability. Furthermore, none of the affected organisations may become aware of the compromise until adversarial use of the information is observed, such as strategic countermoves or leaked intelligence.

This scenario underscores the urgency of implementing post-quantum cryptography well before quantum systems reach maturity. Defensive planning must assume that interception is already occurring today, even if decryption remains years away. Thus, organisations handling sensitive, high-value, or long-lifetime data must act proactively. Migrating to quantum-resilient algorithms, adopting hybrid cryptography and integrating HNDL awareness into risk assessments, incident response and data lifecycle management.

This scenario example will also help support not only threat modelling and scenario creation but also the necessary controls for when this threat becomes a realisation.

HNDL Scenario Recommendations

1. Transition to Post-Quantum Cryptography (PQC)

Begin the adoption of quantum-resilient cryptographic algorithms as recommended by NIST's PQC standardisation project such as CRYSTALS-Kyber (ML-KEM) and CRYSTALS-Dilithium (ML-DSA). Prioritise systems that transmit, store, or process sensitive data with long confidentiality lifetimes such as communications, military and medical records.

How it helps:

Prevents adversaries from being able to decrypt harvested ciphertext in the future using quantum computers.

2. Implement Hybrid Cryptographic Solutions

Where PQC is not yet fully available or supported, deploy hybrid cryptographic schemes combining classical RSA or ECC) with PQC algorithms. Use hybrid TLS or VPN protocols like PQC+X25519 during transitional phases.

How it helps:

Adds resilience by ensuring that even if one algorithm fails, the other offers continued protection by buying time during migration.

3. Conduct Quantum Threat Modelling (via Q-SLICE)

Use the Q-SLICE methodology to model specific quantum-enabled threats, identify quantum-vulnerable assets, assess adversary capabilities and prioritise mitigations. Focus on "harvest now" risks in data transmission and storage.

How it helps:

Transforms abstract quantum risk into actionable security requirements tailored to your environment.

4. Classify Quantum-Sensitive Data

Enhance data classification schemes to flag "quantum-sensitive" data. Typically, anything requiring long-term confidentiality. This includes intellectual property, diplomatic cables, military operations data, or sensitive commercial agreements.

How it helps:

Allows the organisation to prioritise encryption upgrades where they matter most.

5. Secure Satellite and Radio Communications

Evaluate all wireless, satellite and long-range comms channels. Transition from legacy crypto such as RSA-based VPNs or telemetry links to PQC-capable or hybrid protocols. Use directional antennas, temporal obfuscation and authenticated encryption.

How it helps:

Prevents passive quantum-capable adversaries from intercepting and storing encrypted communications for later decryption.

6. Integrate PQC into Security Architecture and Protocols

Update architectural designs and procurement standards to ensure all new systems support cryptographic agility and PQC. Require vendors to demonstrate PQC readiness. Design with Zero Trust principles and segmented network enclaves.

How it helps:

Builds future-proof systems that reduce retrofitting complexity and support rapid crypto transitions.

7. Update Incident Response (IR) Playbooks for Quantum Threats

Revise IR plans to include detection and response procedures for suspected HNDL scenarios. Train teams to recognise early indicators of future compromise, such as targeting of encrypted communications or certificate spoofing attempts.

How it helps:

Reduces time-to-response if quantum decryption is suspected and supports post-quantum breach assessments.

8. Maintain Cryptographic Asset Inventory

Maintain a live inventory of all cryptographic assets – algorithms, keys, certificates, libraries – including their locations, versions, expiry dates and PQC readiness status.

How it helps:

Supports effective migration planning, vulnerability tracking and key lifecycle control.

9. Educate Leadership and Technical Teams

Run awareness sessions for executives and technical staff on the HNDL threat model. Provide specialist training on PQC migration and hybrid crypto deployment.

How it helps:

Builds internal competence to make informed, risk-based decisions and accelerates adoption.

10. Engage with Industry and Regulators

Participate in consortia such as ETSI, NIST PQC, ISO/IEC groups and collaborate with regulators, vendors and peers to stay aligned on standards, timelines and best practices.

How it helps:

Ensures compliance, reduces vendor lock-in and allows early access to standards-compliant tools.

Incident Response Planning

Foundations

QUANTA provides domain-specific controls (Governance, Cryptography, Operations, Cloud, etc.)

- Q-SLICE is a quantum-specific threat model with components:
- Quantum capability
- Systems targeted
- Lifecycle of cryptographic exposure
- Interception potential
- Cryptanalytic feasibility
- Exfiltration and exploitation timelines

Preparation

QUANTA Domains:

- Governance & Policy – Establish PQC policies, inventory quantum-vulnerable assets
- Training – Educate IR teams on HNDL, PQC and QKD
- Architecture – Implement cryptographic agility and zero trust

Actions:

- Include quantum threats in BCP/DR and tabletop exercises
- Classify data by long-term confidentiality requirements
- Adopt hybrid crypto and ensure PQC-ready endpoints

Q-SLICE Consideration:

Identify systems with long cryptographic lifecycle and interception potential (e.g., satellite uplinks, legacy VPNs)

Detection & Identification**QUANTA Domains:**

- Security Operations – SIEM tuned for quantum-relevant indicators (e.g., certificate spoofing, anomalous TLS use)
- Threat Intelligence – Subscribe to sources tracking quantum R&D, NIST PQC updates

Actions:

- Monitor for traffic pattern anomalies suggesting passive interception
- Detect misuse of legacy crypto or signs of pre-positioning
- Watch for early indicators of quantum tooling in APT TTPs

Q-SLICE Consideration:

Evaluate whether adversary has quantum capability or is conducting strategic exfiltration for future decryption

Containment**QUANTA Domains:**

- Cryptography & Data Protection – Segregate or replace vulnerable data stores
- Network Security – Micro-segmentation, isolate channels using legacy crypto

Actions:

- Immediately disable weak algorithms (e.g., RSA-2048, ECC)
- Transition critical communications to PQC or hybrid schemes
- Apply firewall rules to prevent further data exfiltration

Q-SLICE Consideration:

Contain based on cryptanalytic feasibility and data sensitivity

Eradication

QUANTA Domains:

- Endpoint & Application Security – Remove compromised certificates or vulnerable libraries
- Supply Chain – Verify third-party software and PKI resilience

Actions:

- Revoke and re-issue digital certificates
- Purge quantum-vulnerable session tokens or archived data
- Audit all remote access with post-quantum MFA readiness

Q-SLICE Consideration:

Clean systems based on potential for future decryption or replay

Recovery

QUANTA Domains:

- Disaster Recovery – Restore from backups encrypted with quantum-resilient methods
- Cloud & Third-Party – Validate restored systems maintain crypto agility

Actions:

- Restore only to environments verified as quantum-safe
- Validate re-issued keys, ensure TLS 1.3 or better with hybrid PQC
- Document incident in quantum-aware audit trail

Q-SLICE Consideration:

Focus on data integrity and secure reinitialisation of compromised trust anchors.

Lessons Learned

QUANTA Domains:

- Governance, Risk, & Compliance – Update PQC roadmap and risk models
- Security Architecture – Adjust controls for better cryptographic agility

Actions:

- Run post-mortem with emphasis on quantum exposure
- Update IR playbooks to cover quantum breach paths
- Share anonymised intel with regulators and peers

Q-SLICE Consideration:

Re-score quantum risks and adjust the threat lifecycle model accordingly.

NIST 800-61 Incident Response Alignment

1. Preparation

The Preparation phase becomes foundational for quantum security readiness. This involves conducting a cryptographic asset inventory across all systems and categorising them based on algorithm type, data sensitivity and longevity of confidentiality requirements. Critical questions must be asked: *"If this encrypted dataset were decrypted in ten years, what would the impact be?"* Cryptographic agility must be built in systems should support easy replacement or upgrade of encryption schemes to PQC.

The QUANTA framework guides technical and procedural control alignment during this phase, including enabling cryptographic agility, endpoint protection with PQC-ready modules and third-party assurance that factors in quantum readiness. Organisations should embed quantum threat awareness into incident response playbooks and conduct simulations of quantum-specific scenarios, including adversaries using quantum-enhanced reconnaissance, exploitation or credential forgery.

2. Detection and Analysis

In the Detection and Analysis phase, quantum-related incidents may not follow conventional timelines. Adversaries may exfiltrate encrypted payloads with no immediate indicators of decryption or misuse. As such, detection must focus on anomalous access to encrypted datasets, suspicious interest in cryptographic endpoints and compromise or abuse of certificate infrastructures, especially where these relate to long-lived data (e.g., diplomatic cables, defence telemetry, sensitive PII or IP).

The Q-SLICE threat model provides analytical scaffolding to assess adversary sophistication, likely targets and use of quantum techniques. Detection tools such as SIEMs must be updated with new rule sets to identify behaviour linked to

quantum adversary tactics, including tampering with key exchange mechanisms, or probing for systems using deprecated encryption such as RSA or ECC .

3. Containment, Eradication and Recovery

Containment in a quantum context may not be immediate or obvious—because the decryption event may occur years after the data theft. Thus, containment becomes proactive: it includes migrating vulnerable cryptographic assets, retiring weak algorithms and replacing exposed certificates and session keys with quantum-safe alternatives. Eradication may involve re-architecting systems that cannot support PQC or implementing zero trust access controls to limit any lateral movement that could lead to future harvestable data exposure.

Recovery must be forward-looking; ensuring that compromised or at-risk assets are not just restored but reinforced. Recovery plans should include procedures for mass cryptographic rotation, PKI restructuring and data re-encryption using PQC. Use of hybrid cryptographic schemes during the transition period can offer a layered defence against both classical and quantum threats.

4. Post-Incident Activity

The Post-Incident Activity phase is crucial for reinforcing quantum resilience. It should include lessons learned on the use and exposure of cryptographic assets, evaluation of quantum maturity of current infrastructure and recommendations for accelerating PQC adoption. Incident reports should capture quantum-specific IOCs, even if impact is deferred and share relevant findings with industry, regulators and standards bodies.

Over time, organisations should build a quantum risk register that includes not just specific incidents but also emerging risks, such as quantum-enabled supply chain manipulation, or failures in early PQC implementations. Governance boards must be kept informed of the long-term exposure timelines unique to quantum threats—risk today may not manifest operationally until years later, when decryption becomes possible.

Integrating QUANTA and Q-SLICE

By integrating QUANTA, organisations benefit from a structured, domain-driven control model aligned with quantum security principles, including cryptographic agility, security architecture design, secure communications and cloud resilience. Meanwhile, Q-SLICE helps prioritise and profile quantum threat actors, offering actionable insight during triage and escalation.

Together, they enable a strategic transformation of incident response to align with the quantum age—bridging the gap between future cryptographic threats and present-day operational defence. This ensures organisations are not only equipped to respond to post-quantum incidents, but can also detect, deter, deny and disrupt quantum-capable adversaries in alignment with the CIA-3D model.

Table 12 Playbook Summary

Phase	QUANTA Focus Areas	Q-SLICE Priority Factors
Preparation	Governance, Training, Crypto Lifecycle	Lifecycle, Exfiltration Potential
Detection	Threat Intel, SIEM, PQC-aware Tools	Quantum Capability, Interception
Containment	Crypto Isolation, Network Segmentation	Cryptanalytic Feasibility
Eradication	Endpoint Hardening, PKI Hygiene	Exfiltration & Crypto Exposure
Recovery	PQC-Ready Restoration & Key Material	System Re-Trust & Certificate Replacement
Lessons Learned	Update Frameworks, IR Plans	Threat Model Refinement, Strategic Deterrence

CONCLUSION

As we reach the conclusion of Quantum Security: Practical Implementation with Q-SLICE™ and QUANTA, it is clear that quantum computing represents both a profound technological leap and a complex security challenge. This book has sought not only to demystify quantum computing and its implications for security but also to provide readers with practical, structured tools for mitigating its risks.

We began by exploring the fundamentals of quantum computing. Unlike classical systems reliant on bits in states of 0 or 1, quantum computers use qubits, which exploit superposition and entanglement to encode and process information in ways that offer exponential speed-up for certain problem classes. This unique computational paradigm threatens the security of widely used cryptographic systems. Algorithms such as Shor's can factor large integers efficiently, compromising RSA and ECC, while Grover's algorithm can reduce the brute-force search space for symmetric keys.

These risks are not abstract. The notion of "harvest now, decrypt later" highlights the critical urgency. Adversaries are already intercepting and storing encrypted communications with the intention of decrypting them once sufficiently powerful quantum computers emerge. This risk is particularly acute for sensitive data with long-term confidentiality requirements, such as government communications, critical infrastructure control systems and financial transactions.

To address this, the book surveyed the emerging field of post-quantum cryptography (PQC). We examined the NIST standardisation process that has produced a suite of algorithms designed to withstand quantum attacks, including CRYSTALS-Kyber for key establishment and Dilithium and SPHINCS+ for digital

signatures. These standards form the backbone of future cryptographic migration strategies and their adoption is already being promoted by institutions such as the NCSC in the United Kingdom.

However, cryptographic migration alone is insufficient. Organisations need a holistic approach that encompasses people, processes and technology. This is where the core contributions of this book lie: the Q-SLICE™ threat model and the QUANTA framework.

Q-SLICE™ was developed to address a critical gap in existing threat modelling methodologies such as STRIDE. While STRIDE effectively categorises classical threats, it overlooks quantum-specific challenges. Q-SLICE™ introduces six categories designed to highlight the unique threats of a quantum-capable adversary:

Q - Quantum Exploitation, including algorithmic decryption of classical crypto.

S - Subversion of Trust, such as compromising QKD or PQC implementations.

L - Legacy Exploitation, targeting systems unprepared for PQC migration.

I - Integrity Disruption, including attacks on quantum states or AI-enhanced spoofing.

C - Coherence Attacks, exploiting the physical fragility of quantum systems.

E - Ecosystem Abuse, attacking interdependencies in hybrid quantum-classical environments.

Q-SLICE™ offers a systematic way to model quantum-relevant threats and identify controls to mitigate them, supporting security architects and risk analysts in their planning.

Complementing Q-SLICE™, the QUANTA framework offers a modular, domain-based set of security controls aligned with best practices for quantum resilience. QUANTA domains include Governance, Risk and Compliance, Identity and Access Management, Cryptography and Data Protection, Network Security, Security

Operations and Incident Response, among others. Within each domain, the framework recommends practical, actionable controls—such as enforcing cryptographic agility, adopting PQC-ready VPNs, or deploying Zero Trust Architecture—to prepare for the coming quantum era.

Throughout the book, real-world scenarios were used to demonstrate these tools in action. Notably, the SATCOM risk mitigation scenario illustrated the application of Q-SLICE to secure military satellite communications against a quantum-capable adversary. It demonstrated a phased approach combining PQC migration, QKD deployment, Zero Trust Architecture and continuous red teaming to validate defences. This scenario underscored the importance of proactive planning, cryptographic agility and continuous monitoring in achieving quantum resilience.

The book also discussed the broader implications of quantum computing beyond cryptography. The technology's potential to disrupt critical infrastructure, challenge supply chains, exacerbate geopolitical tensions and widen technological inequalities was considered. These ethical, societal and regulatory dimensions remind us that quantum security is not merely a technical challenge but a governance and policy one as well.

In closing, the central message of this book is clear: quantum computing is coming. Its power will be harnessed for good—advancing medicine, materials science and secure communication—but it will also be weaponised to undermine today's cryptographic foundations. Organisations must prepare now, not later.

Key takeaways include:

- Quantum computers threaten classical cryptography with specific risks to RSA, ECC and Diffie-Hellman protocols.
- The window of opportunity to prepare before cryptographically relevant quantum computers arrive may be as short as 5-10 years.
- Post-Quantum Cryptography is a necessary but not sufficient defence. Organisations also need cryptographic agility and governance structures that anticipate quantum threats.

- Q-SLICE™ provides a clear, structured threat model tailored to quantum challenges.
- The QUANTA framework offers a comprehensive, modular approach to implementing quantum-resilient controls across the security stack.
- Threat modelling, risk assessment and migration planning need to account for both technological and human factors, integrating with existing standards and best practices.

Finally, security leaders must ensure that quantum security is not an afterthought but an integral part of their organisational strategy, aligning investments, policies and culture to face this transformative risk.

Quantum security is not simply about installing new encryption algorithms; it is about building resilience into our systems, our processes and our thinking. It demands foresight, collaboration and a willingness to adapt in the face of emerging technological realities.

Conclusion

- Quantum computing is both an opportunity and a systemic risk.
- CRQC readiness will determine which organisations remain secure in the quantum era.
- Governance, cryptography and resilience must be treated as board-level priorities.
- Frameworks like Q-SLICE and QUANTA provide actionable paths to quantum security.
- Leaders must act now as waiting until Q-Day is too late.

ABBREVIATIONS

AES	Advanced Encryption Standard
AEAD	(Authenticated Encryption with Associated Data)
AI	Artificial Intelligence
C2	Command and Control
CRQC	Cryptographically Relevant Quantum Computer
CT	Certificate Transparency
ECDHE	Elliptic Curve Diffie-Hellman Ephemeral
ECC	Elliptic Curve Cryptography
E2EE	End-to-End Encryption
HN DL	Harvest Now, Decrypt Later
HSM	Hardware Security Module
IAM	Identity and Access Management
IoT	Internet of Things
KEM	Key Encapsulation Mechanism
MFA	Multi-Factor Authentication
ML-DSA	Module-Lattice-Based Digital Signature Algorithm
ML-KEM	Module-Lattice-Based Key Encapsulation Mechanism
NCSC	National Cyber Security Centre
NIST	National Institute of Standards and Technology
NSA	National Security Agency
OTS	One-Time Signature
P2P	Point-to-Point
PAM	Privileged Access Management
PQC	Post-Quantum Cryptography
QKD	Quantum Key Distribution
RBAC	Role-Based Access Control

RSA	Rivest-Shamir-Adleman (cryptographic algorithm)
SATCOM	Satellite Communications
SHA	Secure Hash Algorithm
SIKE	Supersingular Isogeny Key Encapsulation
SLH-DSA	Stateless Hash-Based Digital Signature Algorithm
TLS	Transport Layer Security
VPN	Virtual Private Network
ZTA	Zero Trust Architecture

GLOSSARY

Algorithm

A step-by-step procedure for solving a problem. In cryptography, algorithms define how encryption and decryption are performed.

AEAD (Authenticated Encryption with Associated Data) is a cryptographic mode of operation that simultaneously ensures the confidentiality, integrity and authenticity of data. AEAD schemes encrypt plaintext while also producing an authentication tag that verifies both the encrypted content and any unencrypted associated data (AAD) that needs to be authenticated but not encrypted. This prevents tampering or forgery attacks.

Asymmetric Cryptography

Encryption that uses a pair of keys—public and private. Widely used for secure key exchange but vulnerable to quantum attacks.

BB84 Protocol

A quantum key distribution (QKD) protocol using quantum states (like polarised photons) to securely exchange keys.

Cryptographic Agility

The ability of systems to rapidly switch between cryptographic algorithms to adapt to evolving threats.

CRQC (Cryptographically Relevant Quantum Computing)

A benchmark describing when a quantum computer has sufficient scale, stability and throughput to break widely used public-key cryptographic systems (e.g., RSA-2048, ECC). A CRQC score of 1.0 indicates practical breakability within one week.

Decoherence

Loss of quantum information due to interaction with the environment, making qubits behave classically.

Entanglement

A quantum phenomenon where two particles remain linked so that the state of one instantly influences the other, regardless of distance.

Harvest Now, Decrypt Later (HNDL)

The strategy of intercepting and storing encrypted data today to decrypt it in the future when quantum computers can break classical encryption.

Hybrid Key Exchange

Combines classical and post-quantum algorithms to maintain security during the migration period.

Key Exchange

The process of securely sharing cryptographic keys between parties.

Lattice-Based Cryptography

A form of cryptography believed to be resistant to quantum attacks, using mathematical lattices.

LOB (Logical Operations Budget)

The maximum number of reliable operations (circuit depth) that can be executed on logical qubits before errors accumulate beyond correction. This reflects the effective computational “depth” available for running complex algorithms such as Shor’s.

LQC (Logical Qubit Capacity)

The number of error-corrected logical qubits available for computation. Logical qubits are built from many physical qubits using error correction codes and represent the usable, stable units required for fault-tolerant quantum algorithms.

Post-Quantum Cryptography (PQC)

Algorithms designed to resist attacks from both classical and quantum computers.

QOT (Quantum Operations Throughput)

The rate at which logical operations can be performed per second. Throughput determines how quickly a quantum computer can execute large circuits and is critical for assessing whether cryptographic workloads can be completed within practical timeframes.

Qubit

The basic unit of quantum information. Unlike classical bits, qubits can be in superposition, representing 0 and 1 simultaneously.

Quantum Algorithm

An algorithm designed to run on a quantum computer, exploiting quantum principles like superposition and entanglement.

Quantum Key Distribution (QKD)

A method to securely share encryption keys using quantum mechanics.

Eavesdropping alters the quantum state, revealing the intrusion.

Quantum Threat Modelling

Analysing and anticipating security risks specific to quantum technologies and their impact on systems.

Quantum Risk Assessment

Evaluating potential impacts of quantum computing on an organisation's security posture.

Quantum Safe

Systems or cryptographic approaches that remain secure even when quantum computers are capable of large-scale cryptanalysis.

Quantum Teleportation

Transmitting a quantum state from one location to another using entanglement and classical communication.

Q-SLICE

A threat modelling approach specifically designed to identify quantum-relevant security threats, complementing traditional models.

QUANTA Framework

A modular control framework providing structured, quantum-resilient security controls across domains like governance, cryptography and incident response.

REFERENCES

Post-Quantum Cryptography Standards and Guidance

National Institute of Standards and Technology (NIST). (2022). NIST Announces First Four Quantum-Resistant Cryptographic Algorithms.

<https://www.nist.gov/news-events/news/2022/07/nist-announces-first-four-quantum-resistant-cryptographic-algorithms>

NIST. (2023). Post-Quantum Cryptography Standardization. Ongoing project.

<https://csrc.nist.gov/projects/post-quantum-cryptography>

Bernstein, D. J., et al. (2009). Post-Quantum Cryptography. Springer. DOI: 10.1007/978-3-540-88702-7

Shor, P.W., 1994. Algorithms for quantum computation: Discrete logarithms and factoring. Proceedings of the 35th Annual Symposium on Foundations of Computer Science, Santa Fe, NM, USA, 20-22 November 1994, pp.124-134. IEEE. Available at: <https://doi.org/10.1109/SFCS.1994.365700>

Grover, L.K., 1996. A fast quantum mechanical algorithm for database search. arXiv:quant-ph/9605043. Available at: <https://arxiv.org/abs/quant-ph/9605043>

Cryptographic Agility and Migration

National Cyber Security Centre (NCSC UK). (2020). Cryptographic Agility.

<https://www.ncsc.gov.uk/whitepaper/cryptographic-agility>

European Union Agency for Cybersecurity (ENISA). (2021). Post-Quantum Cryptography: Current state and quantum mitigation. <https://www.enisa.europa.eu/publications/post-quantum-cryptography-current-state-and-quantum-mitigation>

Quantum Threat Models and Risk

Mosca, M. (2018). Cybersecurity in an era with quantum computers: Will we be ready?. IEEE Security & Privacy, 16(5), 38-41. DOI: 10.1109/MSEC.2018.053591658

Chen, L., et al. (2016). Report on Post-Quantum Cryptography. NISTIR 8105. NIST. <https://nvlpubs.nist.gov/nistpubs/ir/2016/NIST.IR.8105.pdf>

Standards and Control Frameworks

NIST. (2024). Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework>

Center for Internet Security (CIS). (2021). CIS Controls v8.

<https://www.cisecurity.org/controls/v8>

International Organization for Standardization (ISO). (2022). ISO/IEC 27001:2022 Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements. <https://www.iso.org/standard/82875.html>

Quantum Key Distribution (QKD)

Scarani, V., et al. (2009). The security of practical quantum key distribution. Reviews of Modern Physics, 81(3), 1301. DOI: 10.1103/RevModPhys.81.1301

National Academies of Sciences, Engineering and Medicine. (2019). Quantum Computing: Progress and Prospects. The National Academies Press.

<https://doi.org/10.17226/25196>

General Cryptography and Security Operations

Ferguson, N., Schneier, B., & Kohno, T. (2010). *Cryptography Engineering: Design Principles and Practical Applications*. Wiley.

Anderson, R. (2020). *Security Engineering: A Guide to Building Dependable Distributed Systems*, 3rd ed. Wiley.

Javadi-Abhari, A., Treinish, M., Krsulich, K., Wood, C.J., et al., 2024. *Quantum computing with Qiskit*. arXiv preprint arXiv:2405.08810. Available at: <https://arxiv.org/abs/2405.08810>

Marin, A. (2024) End-to-end multimodal deep learning for real-time decoding of months-long neural activity from the same cells. bioRxiv. Available at: <https://www.biorxiv.org/content/10.1101/2024.10.14.618046v1>

IBM (2025) Introducing Relay-BP: The world's fastest, most accurate decoder for qLDPC error correction codes. IBM Quantum Blog. Available at: <https://www.ibm.com/quantum/blog/relay-bp-error-correction-decoder>

Swayne, D. (2024) 2024 General Election Results: New Forest West won by Desmond Swayne. UKPOL. Available at: <https://www.ukpol.co.uk/2024-general-election-results-new-forest-west-won-by-desmond-swayne/>